

Chapter 01

2026 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드

Unix 서버

1. 계정 관리	12
2. 파일 및 디렉토리 관리	39
3. 서비스 관리	68
4. 패치 관리	160
5. 로그 관리	164

01 Unix 서버 취약점 분석 · 평가 항목

1. 계정 관리

점검항목	항목 중요도	항목코드
root 계정 원격 접속 제한	상	U-01
비밀번호 관리정책 설정	상	U-02
계정 잠금 임계값 설정	상	U-03
비밀번호 파일 보호	상	U-04
root 이외의 UID가 '0' 금지	상	U-05
사용자 계정 su 기능 제한	상	U-06
불필요한 계정 제거	하	U-07
관리자 그룹에 최소한의 계정 포함	중	U-08
계정이 존재하지 않는 GID 금지	하	U-09
동일한 UID 금지	중	U-10
사용자 Shell 점검	하	U-11
세션 종료 시간 설정	하	U-12
안전한 비밀번호 암호화 알고리즘 사용	중	U-13

2. 파일 및 디렉토리 관리

점검항목	항목 중요도	항목코드
root 홈, 패스 디렉터리 권한 및 패스 설정	상	U-14
파일 및 디렉터리 소유자 설정	상	U-15
/etc/passwd 파일 소유자 및 권한 설정	상	U-16
시스템 시작 스크립트 권한 설정	상	U-17
/etc/shadow 파일 소유자 및 권한 설정	상	U-18

01. Unix 서버

점검항목	항목 중요도	항목코드
/etc/hosts 파일 소유자 및 권한 설정	상	U-19
/etc/(x)inetd.conf 파일 소유자 및 권한 설정	상	U-20
/etc/(r)syslog.conf 파일 소유자 및 권한 설정	상	U-21
/etc/services 파일 소유자 및 권한 설정	상	U-22
SUID, SGID, Sticky bit 설정 파일 점검	상	U-23
사용자, 시스템 환경변수 파일 소유자 및 권한 설정	상	U-24
world writable 파일 점검	상	U-25
/dev에 존재하지 않는 device 파일 점검	상	U-26
\$HOME/.rhosts, hosts.equiv 사용 금지	상	U-27
접속 IP 및 포트 제한	상	U-28
hosts.lpd 파일 소유자 및 권한 설정	하	U-29
UMASK 설정 관리	중	U-30
홈 디렉토리 소유자 및 권한 설정	중	U-31
홈 디렉토리로 지정한 디렉토리의 존재 관리	중	U-32
숨겨진 파일 및 디렉토리 검색 및 제거	하	U-33

3. 서비스 관리

점검항목	항목 중요도	항목코드
Finger 서비스 비활성화	상	U-34
공유 서비스에 대한 익명 접근 제한 설정	상	U-35
r 계열 서비스 비활성화	상	U-36
crontab 설정파일 권한 설정 미흡	상	U-37
DoS 공격에 취약한 서비스 비활성화	상	U-38
불필요한 NFS 서비스 비활성화	상	U-39
NFS 접근 통제	상	U-40
불필요한 automountd 제거	상	U-41

점검항목	항목 중요도	항목코드
불필요한 RPC 서비스 비활성화	상	U-42
NIS, NIS+ 점검	상	U-43
tftp, talk 서비스 비활성화	상	U-44
메일 서비스 버전 점검	상	U-45
일반 사용자의 메일 서비스 실행 방지	상	U-46
스팸 메일 릴레이 제한	상	U-47
expn, vrfy 명령어 제한	중	U-48
DNS 보안 버전 패치	상	U-49
DNS Zone Transfer 설정	상	U-50
DNS 서비스의 취약한 동적 업데이트 설정 금지	중	U-51
Telnet 서비스 비활성화	중	U-52
FTP 서비스 정보 노출 제한	하	U-53
암호화되지 않는 FTP 서비스 비활성화	중	U-54
FTP 계정 Shell 제한	중	U-55
FTP 서비스 접근 제어 설정	하	U-56
Ftpusers 파일 설정	중	U-57
불필요한 SNMP 서비스 구동 점검	중	U-58
안전한 SNMP 버전 사용	상	U-59
SNMP Community String 복잡성 설정	중	U-60
SNMP Access Control 설정	상	U-61
로그인 시 경고 메시지 설정	하	U-62
sudo 명령어 접근 관리	중	U-63

4. 패치 관리

점검항목	항목 중요도	항목코드
주기적 보안 패치 및 벤더 권고사항 적용	상	U-64

5. 로그 관리

점검항목	항목 중요도	항목코드
NTP 및 시각 동기화 설정	중	U-65
정책에 따른 시스템 로깅 설정	중	U-66
로그 디렉터리 소유자 및 권한 설정	중	U-67

U-01 (상)	UNIX > 1. 계정 관리
	root 계정 원격 접속 제한
개요	
점검 내용	시스템 정책에 root 계정의 원격터미널 접속 차단 설정이 적용 여부 점검
점검 목적	관리자 계정 탈취로 인한 시스템 장악을 방지하기 위해 외부 비인가자의 root 계정 접근 시도를 원천적으로 차단하기 위함
보안 위협	root 계정은 운영체제의 모든 기능을 설정 및 변경이 가능하여(프로세스, 커널 변경 등) root 계정을 탈취하여 외부에서 원격을 이용한 시스템 장악 및 각종 공격으로(무차별 대입 공격, 사전 대입 공격 등) 인한 root 계정 사용 불가 위험이 존재함
참고	※ root 계정: 여러 사용자가 사용하는 컴퓨터에서 모든 기능을 관리할 수 있는 총괄 권한을 가진 유일한 특별 계정. 유닉스 시스템의 루트(root)는 시스템 관리자인 운용 관리자(Super User)로서 윈도우의 Administrator보다 높은 System 계정에 해당하며, 사용자 계정을 생성하거나 소프트웨어를 설치하고, 환경 및 설정을 변경하거나 시스템의 동작을 감시 및 제어할 수 있음 ※ 무차별 대입 공격(Brute Force Attack): 특정한 암호를 풀기 위해 가능한 모든 값을 대입하는 공격 방법 ※ 사전 대입 공격(Dictionary Attack): 사전에 있는 단어를 입력하여 암호를 알아내거나 암호를 해독하는 데 사용되는 컴퓨터 공격 방법 ※ tty(terminal-teletype): 서버와 연결된 모니터, 키보드 등을 통해 사용자가 콘솔로 직접 로그인함 ※ pts(pseudo-terminal): 가상터미널을 뜻하며, Telnet, SSH 등을 이용하여 접속함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 원격터미널 서비스를 사용하지 않거나, 사용 시 root 직접 접속을 차단한 경우
	취약 : 원격터미널 서비스 사용 시 root 직접 접속을 허용한 경우
조치 방법	원격 접속 시 root 계정으로 접속할 수 없도록 파일 내용 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

[Telnet]

Step 1) /etc/default/login 파일 내에 CONSOLE 설정값 수정

CONSOLE=/dev/console

[SSH]

Step 1) /etc/ssh/sshd_config 파일 내의 PermitRootLogin 설정값 수정

PermitRootLogin No

● **LINUX****[Telnet]**

Step 1) /etc/pam.d/login 파일 내에 auth required /lib/security/pam_securetty.so 입력

Step 2) /etc/securetty 파일 내에 pts/ 설정값 주석 처리 및 제거

#pts/0

#pts/1

#pts/2

Step 3) /etc/pam.d/login 파일 내에 모듈 추가

auth required /lib/security/pam_securetty.so

※ /etc/securetty 파일 내 pts/x 관련 설정이 존재하는 경우 PAM 모듈 설정과 관계없이 root 계정 접속을 허용하므로 반드시 제거 필요

※ CentOS 8, Ubuntu 20.04 이상부터 /etc/securetty 파일이 존재하지 않으며 기본적으로 Telnet 서비스가 비활성화됨

[SSH]

Step 1) /etc/ssh/sshd_config 파일에 PermitRootLogin 값 수정

PermitRootLogin No

● **AIX****[Telnet]**

Step 1) /etc/security/user 파일에 rlogin 설정값 수정

rlogin = false

[SSH]

Step 1) /etc/ssh/sshd_config 파일에 PermitRootLogin 값 수정

PermitRootLogin No

● HP-UX

[Telnet]

Step 1) `etc/securetty` 파일 내에 `console` 값 수정

`console`

※ `/etc/securetty` 파일은 기본적으로 존재하지 않으므로 해당 파일이 존재하지 않는 경우 생성 후 설정할 것

[SSH]

Step 1) `/opt/ssh/etc/sshd_config` 파일 내에 `PermitRootLogin` 값 수정

`PermitRootLogin No`

01. Unix 서버

U-02 (상)	UNIX > 1. 계정 관리
	비밀번호 관리정책 설정
개요	
점검 내용	비밀번호 관리 정책 설정 여부 점검
점검 목적	사용자의 비밀번호 복잡성과 주기적 변경을 통해 시스템 보안을 강화하기 위함
보안 위협	비밀번호 관련 정책이 설정되지 않을 경우, 비인가자의 각종 공격(무차별 대입 공격, 사전 대입 공격 등)에 의해 비밀번호가 노출될 위험이 존재함
참고	※ 비밀번호 관리 정책 : 비밀번호 복잡성 및 길이, 변경 주기 등을 포함한 비밀번호 정책 ※ 비밀번호 복잡성 : 비밀번호 설정 시 영문, 숫자, 특수문자를 포함하여 최소 8자리 이상
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 비밀번호 관리 정책이 설정된 경우
	취약 : 비밀번호 관리 정책이 설정되지 않은 경우
조치 방법	root 계정을 포함한 사용자 계정의 비밀번호를 영문, 숫자, 특수문자를 포함하여 최소 8자리 이상 및 최소 사용 기간 1일, 최대 사용 기간 90일, 최근 비밀번호 기억 4회 이상으로 설정
조치 시 영향	비밀번호 변경 시 Web, WAS, DB 연동 구간에서 문제가 발생할 수 있으므로 연동 구간에 미칠 수 있는 영향을 고려하여 적용 필요

점검 및 조치 사례

● SOLARIS

Step 1) /etc/default/passwd 파일 내에 비밀번호 설정값 수정

```
HISTORY=4
PASSLENGTH=8
MINDIGIT=1
MINUPPER=1
MINLOWER=1
MINSPECIAL=1
WHITESPACE=NO
```

권고값	기능	설명
HISTORY= 10	이전 비밀번호 기억 개수	이전 10개의 암호를 기억함
MINDIFF= 4	이전 암호와 차이	이전 암호와 4자 이상 차이 요구
MINALPHA= 1	최소 문자 요구	최소 1자 이상 문자 요구
MINNONALPHA= 1	최소 숫자 또는 특수문자 요구	숫자 또는 특수문자 1자 이상 요구
MINUPPER= 1	최소 대문자 요구	최소 1자 이상 대문자 요구
MINLOWER= 1	최소 소문자 요구	최소 1자 이상 소문자 요구
MAXREPEATS= 0	연속 문자 사용 허용	0일 경우 문자 연속 사용이 불가
MINSPECIAL= 1	최소 특수문자 요구	최소 1자 이상 특수문자 요구
MINDIGIT= 1	최소 숫자 요구	최소 1자 이상 숫자 요구
NAMECHECK= YES	아이디와 비밀번호 동일 검증	아이디와 동일한 비밀번호 사용 불가
MAXDAYS= 90	비밀번호 최대 유효일 수	최대 90일 비밀번호가 유효
MINDAYS= 1	비밀번호 변경 최소일 수	비밀번호 최소 1일 후 변경 가능
MAXWEEKS= 12	비밀번호 최대 유효 주 수	최대 12주 비밀번호가 유효
MINWEEKS= 1	비밀번호 변경 최소일 수	비밀번호 최소 일주일 후 변경 가능
WARNWEEKS= 1	비밀번호 만료 전 알림 주 수	비밀번호 만료 일주일 전 알림
PASSLENGTH= 8	비밀번호 최소 길이	비밀번호 최소 길이 8
WHITESPACE= NO	비밀번호 공백문자 사용 여부	비밀번호에 공백문자 사용 금지 설정

※ MINDIGIT, MINSPECIAL 설정이 적용되어 있는 경우 MINNONALPHA 설정은 적용되지 않음

※ MINDAYS 설정이 적용되어야 MAXDAYS 설정이 적용됨

※ 비밀번호 유효일 설정과 비밀번호 유효 주 설정은 중복 설정 불가함

※ WHITESPACE 기본값: YES

● LINUX

[Redhat]

Step 1) /etc/login.defs 파일에 PASS_MAX_DAYS / PASS_MIN_DAYS 값 수정

```
PASS_MAX_DAYS 90
```

```
PASS_MIN_DAYS 0
```

Step 2) /etc/security/pwquality.conf 파일에 정책 값 수정

```
minlen = 8
```

```
dcredit = -1
```

```
ucredit = -1
```

```
lcredit = -1
```

```
ocredit = -1
```

```
enforce_for_root
```

Step 3) /etc/security/pwhistory.conf 파일에 값 추가 및 수정

```
enforce_for_root
```

```
remember=4
```

```
file = /etc/security/opasswd
```

Step 4) /etc/pam.d/system-auth 파일에 값 수정

Step 5) /etc/login.defs 파일에 PASS_MAX_DAYS / PASS_MIN_DAYS 값 수정

```
PASS_MAX_DAYS 90
```

```
PASS_MIN_DAYS 1
```

※ pam_pwquality.so, pam_pwhistory.so 모듈은 pam_unix.so 모듈 위에 위치해야 적용됨

※ /etc/security/pwquality.conf 파일과 /etc/pam.d/system-auth 파일 중 어느 하나라도 비밀번호 관리 정책이 설정되어 있으면 양호

※ 비밀번호 복잡성 설정에서 최소 요구 항목의 값은 반드시 -1로 설정되어야 함

※ /etc/pam.d/system-auth 파일에 enforce_for_root 추가

[Debian]

Step 1) /etc/security/pwquality.conf 파일에 정책 값 수정

```
minlen = 8
```

```
dcredit = -1
```

```

ucredit = -1
lcredit = -1
ocredit = -1
enforce_for_root

```

Step 2) /etc/pam.d/common-password 파일에 정책 값 수정

pam_pwquality.so, pam_pwhistory.so 모듈은 pam_unix.so 모듈 위에 위치해야 적용됨

Step 3) /etc/login.defs 파일에 값 수정

```

PASS_MAX_DAYS 90
PASS_MIN_DAYS 1

```

권고값	기능	설명
difok = N	기존 비밀번호와 비교	기존 비밀번호에 포함되지 않는 문자를 최소 N개 이상 포함하도록 설정
minlen = 8	최소 비밀번호 길이 설정	최소 8자리 이상 설정
dcredit = -1	최소 숫자 요구	최소 숫자 1자 이상 요구
ucredit = -1	최소 대문자 요구	최소 대문자 1자 이상 요구
lcredit = -1	최소 소문자 요구	최소 소문자 1자 이상 요구
ocredit = -1	최소 특수문자 요구	최소 특수문자 1자 이상 요구
remember = N	최근 비밀번호 기억	최근 변경한 비밀번호를 N개 이상 기억하여 동일한 비밀번호로 변경하지 못하도록 설정
PASS_MIN_DAYS = 1	비밀번호 최소 사용 기간 설정	비밀번호 최소 사용 기간 설정 (단위 : 일)
PASS_MAX_DAYS = 90	비밀번호 최대 사용 기간 설정	비밀번호 최대 사용 기간 설정 (단위 : 일)

※ /etc/security/pwquality.conf 파일과 /etc/pam.d/common-password(/etc/pam.d/system-auth) 파일 중 어느 하나라도 비밀번호 관리 정책이 설정되어 있으면 양호

※ 비밀번호 복잡성 설정에서 최소 요구 항목의 값은 반드시 -1로 설정되어야 함

※ /etc/pam.d/system-auth 파일에 enforce_for_root 추가

● AIX

Step 1) etc/security/user 파일에 정책 값 수정

```

default :
    minage = 1
    maxage = 12
    minalpha = 2
    minother = 2

```

01. Unix 서버

```
minspecialchar = 1
```

```
minlen = 8
```

```
mindiff = 4
```

```
histsize = 4
```

권고값	기능	설명
histexpire= N	동일한 비밀번호 재사용 기간	비밀번호 재사용에 필요한 시간 (단위 : 주)
histsize= 4	이전 비밀번호 기억 개수	허용 비밀번호 반복 횟수
maxrepeats= 2	반복 가능한 동일 문자의 최대 수	비밀번호에서 반복될 수 있는 최대 문자 수
minalpha= 2	최소 알파벳 문자 포함	비밀번호에 필요한 최소 영문자 수
minother= 2	최소 알파벳 문자 이외의 문자 수	비밀번호에 필요한 최소 알파벳을 제외한 문자 수
minspecialchar= 1	최소 특수문자 포함	비밀번호에 필요한 최소 특수문자 수
mindiff= 4	이전 비밀번호와 동일 문자 수	이전 비밀번호와 구별되는 새 비밀번호의 최소 문자 수
minlen= 8	비밀번호 최소 길이	최소 비밀번호 길이
minage= 1	비밀번호 최소 사용 기간	비밀번호 변경에 필요한 최소 기간 (단위 : 주)
maxage= 12	비밀번호 최대 사용 기간	비밀번호 변경에 필요한 최대 시간 (단위 : 주)

● HP-UX

Step 1) /etc/default/security 파일에 정책 값 수정

```
MIN_PASSWORD_LENGTH=8
```

```
PASSWORD_MIN_UPPER_CASE_CHARS=1
```

```
PASSWORD_MIN_LOWER_CASE_CHARS=1
```

```
PASSWORD_MIN_DIGIT_CASE_CHARS=1
```

```
PASSWORD_MIN_SPECIAL_CASE_CHARS=1
```

```
PASSWORD_MAXDAYS=90
```

```
PASSWORD_MINDAYS=1
```

```
HISTORY=4
```

권고값	기능	설명
MIN_PASSWORD_LENGTH= 8	비밀번호 최소 길이	최소 비밀번호 길이
PASSWORD_MIN_UPPER_CASE_CHARS= 1	최소 대문자 필요 개수	비밀번호에 필요한 최소 대문자 수
PASSWORD_MIN_LOWER_CASE_CHARS= 1	최소 소문자 필요 개수	비밀번호에 필요한 최소 소문자 수

권고값	기능	설명
R_CASE_CHARS= 1		
PASSWORD_MIN_DIGIT_CHARS= 1	최소 숫자 필요 개수	비밀번호에 필요한 최소 숫자 수
PASSWORD_MIN_SPECIAL_CHARS= 1	최소 특수문자 필요 개수	비밀번호에 필요한 최소 특수문자 수
PASSWORD_MIN_DAYS= 1	비밀번호 최소 사용 기간	비밀번호 변경에 필요한 최소 기간 (단위 : 일)
PASSWORD_MAX_DAYS= 90	비밀번호 최대 사용 기간	비밀번호 변경에 필요한 최대 시간 (단위 : 일)
HISTORY= 4	이전 비밀번호 기억 개수	허용 비밀번호 반복 횟수

[부적절한 비밀번호 유형]

사전에 나오는 단어나 이들의 조합

길이가 너무 짧거나 NULL(공백)인 비밀번호

키보드 자판의 일련의 나열(예시 : abcd, qwert 등)

사용자 계정 정보에서 유추 가능한 단어들(예시 : 지역명, 부서명, 계정명, 사용자 이름 이니셜, root, admin 등)

[비밀번호 관리 방법]

영문, 숫자, 특수문자를 조합하여 계정명과 다른 8자 이상의 비밀번호 설정

1. 다음 각 항목의 문자 종류 중 2종류 이상을 조합하여 최소 10자리 이상 또는 3종류 이상을 조합하여 최소 8자리 이상의 길이로 구성

가. 영문 대문자(26개)

나. 영문 소문자(26개)

다. 숫자(10개)

라. 특수문자(32개)

2. 시스템마다 다른 비밀번호 사용

3. 비밀번호를 기록해 놓는 경우 변형하여 기록

01. Unix 서버

U-03 (상)	UNIX > 1. 계정 관리
	계정 잠금 임계값 설정
개요	
점검 내용	사용자 계정 로그인 실패 시 계정 잠금 임계값이 설정 여부 점검
점검 목적	계정 탈취 목적의 무차별 대입 공격 시 해당 계정을 잠금으로써 인증 요청에 응답하는 리소스 낭비를 차단하고 대입 공격으로 인한 비밀번호 노출 공격을 무력화하기 위함
보안 위협	계정 잠금 임계값이 설정되어 있지 않을 경우, 비밀번호 탈취 공격(무차별 대입 공격, 사전 대입 공격, 추측 공격 등)의 인증 요청에 대해 설정된 비밀번호가 일치할 때까지 지속적으로 응답하여 해당 계정의 비밀번호가 유출될 위험이 존재함
참고	※ 사용자 로그인 실패 임계값 : 시스템에 로그인 시 몇 번의 로그인 실패에 로그인을 차단할 것인지 결정하는 값
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 계정 잠금 임계값이 10회 이하의 값으로 설정된 경우
	취약 : 계정 잠금 임계값이 설정되어 있지 않거나, 10회 이하의 값으로 설정되지 않은 경우
조치 방법	계정 잠금 임계값을 10회 이하로 설정
조치 시 영향	- HP-UX: Trusted Mode로 전환 시 파일 시스템 구조가 변경되어 운영 중인 서비스에 문제가 발생할 수 있으므로 충분한 테스트를 거친 후 Trusted Mode로의 전환이 필요함 - LINUX: /etc/pam.d/system-auth 파일 설정 시 라이브러리(/lib/security/pam_tally.so)가 해당 경로에 존재하는지 확인 필요 (존재하지 않는 파일의 경로로 설정하는 경우 시스템 로그인에 장애가 발생할 수 있음) - PAM 모듈을 이용하여 설정할 때 해당 순서를 지키지 않을 경우, 로그인 실패 또는 인증 실패 등 예기치 못한 상황이 발생할 수 있으므로 반드시 순서에 맞게 설정해야 함

점검 및 조치 사례

● SOLARIS

[5.9 미만 버전]

Step 1) /etc/default/login 파일에 RETRIES 값 수정

RETRIES=10

[5.9 이상 버전]

Step 1) /etc/security/policy.conf 파일에 LOCK_AFTER_RETRIES 값 수정

LOCK_AFTER_RETRIES=YES

UNLOCK_AFTER =2m

옵션	설명
RETRIES	로그인 시도 횟수
LOCK_AFTER_RETRIES	로그인 시도 횟수와 같거나 초과 되면 잠금 여부
UNLOCK_AFTER	잠금시간 분(m), 시(h), 일(d), w(주) 단위로 설정 가능

● LINUX

[Redhat 계열의 pam_tally.so 또는 pam_tally2.so]

Step 1) /etc/pam.d/system-auth 파일에 deny 값 수정

auth required /lib/security/pam_tally.so 또는 /lib/security/pam_tally2.so deny=10 unlock_time=120 no_magic_root

account required /lib/security/pam_tally.so 또는 /lib/security/pam_tally2.so no_magic_root reset

※ /etc/pam.d/system-auth 파일 수정 시 모듈이 해당 경로에 존재하지 않을 경우, 모든 계정의 로그인에 되지 않는 등 예기치 못한 상황이 발생할 수 있으므로 반드시 올바른 경로를 작성해야 함

[Redhat 계열의 authselect]

Step 1) # authselect enable-feature with-faillock 입력하여 faillock 적용

authselect current

Profile ID: sssd

Enabled features:

- with-fingerprint
- with-silent-lastlog
- with-faillock

Step 2) etc/securiy/faillock.conf 파일에 정책 값 수정

silent

deny = 10

unlock_time = 120

[Redhat 계열의 pam_faillock.so]

Step 1) /etc/pam.d/system-auth 파일에 모듈 값 수정

```
auth required pam_faillock.so preauth silent audit deny=10 unlock_time=120
```

Step 2) /etc/pam.d/password-auth 파일에 모듈 값 수정

```
auth required pam_faillock.so preauth silent audit deny=10 unlock_time=120
```

※ RHEL 8 이상부터 authselect 명령어를 이용하여 설정하는 것을 권장함

[Debian 계열의 pam_tally.so 또는 pam_tally2.so]

Step 1) /etc/pam.d/common-auth 파일에 모듈 값 수정

```
auth required /lib/security/pam_tally.so 또는 /lib/security/pam_tally2.so deny=10 unlock_time=120
no_magic_root
account required /lib/security/pam_tally.so 또는 /lib/security/pam_tally2.so no_magic_root reset
```

[Debian 계열의 pam_faillock.so]

Step 1) /etc/pam.d/common-auth 파일에 pam_faillock.so 모듈 값 수정

```
# here are the per-package modules (the "Primary" block)
auth      required      pam_faillock.so preauth audit deny=10 unlock_time=120
auth      [success=2 default=ignore] pam_unix.so nullok
auth      [success=1 default=ignore] pam_sss.so use_first_pass
# here's the fallback if no module succeeds
auth      [default=die]    pam_faillock.so authfail audit deny=10 unlock_time=120
auth      sufficient      pam_faillock.so authsucc audit deny=10 unlock_time=120
auth      requisite       pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
auth      required       pam_permit.so
```

[/etc/pam.d/common-auth]

Step 2) etc/pam.d/common-account 파일에 pam_faillock.so 모듈 값 수정

```
account required pam_permit.so
# and here are more per-package modules (the "Additional" block)
account sufficient pam_localuser.so
account [default=bad success=ok user_unknown=ignore] pam_sss.so
# end of pam-auth-update config
account required pam_faillock.so
```

[/etc/pam.d/common-account]

- ※ /etc/pam.d/* 파일 수정 시 모듈이 해당 경로에 존재하지 않을 경우, 모든 계정의 로그인에 되지 않는 등 예기치 못한 상황이 발생할 수 있으므로 반드시 올바른 경로를 작성해야 함
- ※ no_magic_root, reset 옵션은 pam_faillock.so 모듈에서 기본으로 작동함
- ※ audit : 실패한 로그인 시도, 잠금 조치, 계정 차단 등의 이벤트를 로그에 기록하는 옵션
- ※ silent : 비밀번호 인증 실패 시 사용자에게 세부적인 오류 메시지를 표시하지 않는 옵션

● AIX

Step 1) /etc/security/user 파일에 loginretries 값 수정

```
loginretries = 3
```

● HP-UX

[11.v2 이하 버전]

Step 1) /tcb/files/auth/system/default 파일에 u_maxtries 값 수정

```
u_maxtries#3
```

- ※ HP-UX 서버에 계정 잠금 정책 설정을 위해서는 HP-UX 서버가 Trusted Mode로 동작하고 있어야 하므로 Trusted Mode로 전환 후 잠금 정책 적용

[11.v3 이상 버전]

Step 1) /etc/default/security 파일에 AUTH_MAXTRIES 값 수정

```
AUTH_MAXTRIES=3
```

- ※ Standard 모드와 Shadow 모드만 적용 가능

옵션	설명
no_magic_root	root 계정은 비밀번호 잠금 설정을 적용하지 않음
deny=N	N회 입력 실패 시 계정 잠금
unlock_time	계정이 잠긴 경우, 마지막 계정 실패 시간부터 설정된 시간이 지나면 자동으로 계정 잠금 해제 (단위 : 초)
reset	접속 시도 성공 시 실패한 횟수 초기화

01. Unix 서버

U-04 (상)	UNIX > 1. 계정 관리
	비밀번호 파일 보호
개요	
점검 내용	시스템의 사용자 계정(root, 일반 사용자) 정보가 저장된 파일(/etc/passwd, /etc/shadow 등)에 사용자 계정 비밀번호가 암호화 저장 여부 점검
점검 목적	일부 오래된 시스템의 경우 /etc/passwd 파일에 비밀번호가 평문으로 저장되므로 사용자 계정 비밀번호가 암호화되어 저장되어 있는지 점검하여 비인가자의 비밀번호 파일 접근 시에도 사용자 계정 비밀번호가 안전하게 관리되고 있는지 확인하기 위함
보안 위협	사용자 계정 비밀번호가 저장된 파일이 유출 또는 탈취 시 평문으로 저장된 비밀번호 정보가 노출 위험이 존재함
참고	※ pwconv: 쉘도우 비밀번호 정책 ※ pwunconv: 일반 비밀번호 정책
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 쉘도우 비밀번호를 사용하거나, 비밀번호를 암호화하여 저장하는 경우
	취약 : 쉘도우 비밀번호를 사용하지 않고, 비밀번호를 암호화하여 저장하지 않는 경우
조치 방법	비밀번호 암호화 저장·관리 설정
조치 시 영향	HP-UX 경우 Trusted Mode로 전환 시 파일 시스템 구조가 변경되어 운영 중인 서비스에 문제가 발생할 수 있으므로 충분한 테스트를 거친 후 Trusted Mode로의 전환이 필요함

점검 및 조치 사례

● SOLARIS, LINUX

Step 1) /etc/passwd 입력 후 파일 내 두 번째 필드가 x 표시되는지 확인

```
root:x:0:0:root:/root:/bin/bash
```

Step 2) # pwconv 명령으로 쉘도우 비밀번호 적용

※ SOLARIS 11은 pwunconv 명령어가 존재하지 않음

● AIX

Step 1) /etc/security/passwd 파일에 암호화 여부 확인

※ AIX는 기본적으로 /etc/security/passwd 파일에 비밀번호를 암호화하여 저장·관리함

● HP-UX

Step 1) /etc/passwd 파일에 암호화 확인

Step 2) # pwconv 명령으로 쉘도우 비밀번호 적용

※ HP-UX 서버는 Trusted Mode로 전환할 경우 비밀번호를 암호화하여 /tcb/files/auth 디렉터리에 계정 이니셜과 계정 이름에 따라 파일로 저장·관리할 수 있으므로 Trusted Mode인지 확인 후 UnTrusted Mode인 경우 모드를 전환함

※ Trusted mode 전환 방법 : root계정으로 아래 명령어 실행

/etc/tsconvert

※ UnTrusted mode 전환 방법 : root계정으로 아래 명령어 실행

/etc/tsconvert -r

※ HP-UX 11.11의 경우 Shadow Password Bundle을 설치하여야 /etc/shadow 파일 생성됨

01. Unix 서버

U-05 (상)	UNIX > 1. 계정 관리
	root 이외의 UID가 '0' 금지
개요	
점검 내용	사용자 계정 정보가 저장된 파일(/etc/passwd, /etc/shadow 등)에 root(UID=0) 계정과 동일한 UID를 가진 계정이 존재 여부 점검
점검 목적	root 계정과 동일한 UID가 존재하는지 점검하여 root 권한이 일반 사용자 계정이나 비인가자의 접근 위협에 안전하게 보호되고 있는지 확인하기 위함
보안 위협	- root 계정과 동일한 UID가 설정되어 있는 일반 사용자 계정도 root 권한을 부여받아 관리자가 실행할 수 있는 모든 작업이 가능한 위험이 존재함(서비스 시작, 중지, 재부팅, root 권한 파일 편집 등) - root 계정과 동일한 UID를 사용하므로 사용자 감사 추적 시 어려움 발생 위험이 존재함
참고	※ UID(User Identification): 여러 명의 사용자가 동시에 사용하는 시스템에서 사용자가 자신을 대표하기 위해 쓰는 이름 ※ OS마다 UID 체계가 달라 시스템 계정 및 일반 사용자 계정이 부여받는 값의 범위에 차이가 있으나, 관리자는 공통으로 UID=0을 부여받음
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : root 계정과 동일한 UID를 갖는 계정이 존재하지 않는 경우
	취약 : root 계정과 동일한 UID를 갖는 계정이 존재하는 경우
조치 방법	- UID가 0으로 설정된 계정을 0 이외의 중복되지 않은 UID로 변경 또는 불필요한 계정인 경우 제거하도록 설정 (사용 중인 계정인 경우 명령어를 통한 조치가 적용되지 않을 수 있으므로 /etc/passwd 파일을 통해 변경)
조치 시 영향	해당 계정에 관리자 권한이 필요하지 않으면 일반적으로 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) usermod 명령어를 이용하여 # usermod -u <변경할 UID> <사용자 이름> 명령으로 0 이외의 중복되지 않는 UID로 변경

계정명	UID값	GID값	홈디렉토리 위치
Test	x	500	500
Gen-User	/home/test	/usr/bin/bash	
패스워드	설명(comment)	지정된 셸	

[/etc/passwd 파일 구조]

※ “:”(콜론)을 사용하여 필드를 구분함

※ 세 번째 필드(UID)가 0인 경우 슈퍼 유저 권한을 가지며, 0 이외의 계정은 일반, 시스템 계정으로 볼 수 있음

U-06 (상)	UNIX > 1. 계정 관리
	사용자 계정 su 기능 제한
개요	
점검 내용	su 명령어 사용을 허용하는 사용자를 지정한 그룹이 설정 여부 점검
점검 목적	su 관련 그룹만 su 명령어 사용 권한이 부여되어 있는지 점검하여 su 그룹에 포함되지 않은 일반 사용자의 su 명령 사용을 원천적으로 차단하는지 확인하기 위함
보안 위협	무분별한 사용자 변경으로 타 사용자 소유의 파일을 변경할 수 있으며 root 계정으로 변경하는 경우 관리자 권한을 획득할 수 있는 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : su 명령어를 특정 그룹에 속한 사용자만 사용하도록 제한된 경우 ※ 일반 사용자 계정 없이 root 계정만 사용하는 경우 su 명령어 사용 제한 불필요
	취약 : su 명령어를 모든 사용자가 사용하도록 설정된 경우
조치 방법	PAM 모듈 설정 또는 su 명령어 허용 그룹 생성 후 su 명령어 일반 사용자 권한 제거하도록 설정
조치 시 영향	그룹에 추가된 계정들은 모든 Session 종료 후 재 로그인 시 su 명령어 사용 가능

점검 및 조치 사례

● SOLARIS, AIX, HP-UX

Step 1) /etc/group 파일 내 wheel 그룹 (su 명령어 사용 그룹) 및 그룹 내 구성원 존재 여부 확인

Step 2) ls -l /usr/bin/su 입력 후 wheel 그룹이 su 명령어를 사용할 수 있는지 설정 여부 확인

Step 3) wheel group 생성 (wheel 그룹이 존재하지 않는 경우)

```
# groupadd wheel
su 명령 그룹 변경
# chgrp wheel /usr/bin/su
su 명령어 권한 변경
# chmod 4750 /usr/bin/su
wheel 그룹에 su 명령 허용 계정 등록
# usermod -G wheel <username>
또는 직접 /etc/group 파일을 수정하여 필요한 계정 등록
wheel:x:10: -> wheel:x:10:root,admin
```

● LINUX

[PAM 모듈 이용 중이지 않을 경우]

Step 1) /etc/group 파일 내 wheel 그룹(su 명령어 사용 그룹) 확인

Step 2) ls 명령어를 이용하여 # ls -l /usr/bin/su 입력 후 su 명령어 그룹과 권한 확인

Step 3) wheel group 생성 (wheel 그룹이 존재하지 않는 경우)

```
# groupadd wheel
```

su 명령 그룹 변경

```
# chgrp wheel /usr/bin/su
```

su 명령어 권한 변경

```
# chmod 4750 /usr/bin/su
```

wheel 그룹에 su 명령 허용 계정 등록

```
# usermod -G wheel <username>
```

※ /etc/group 파일에서 기본 그룹의 경우 사용자 이름은 생략되며 자동으로 포함됨

[PAM 모듈 이용 중인 경우]

Step 1) /etc/group 입력 후 wheel 그룹(su 명령어 사용 그룹) 확인

예시) wheel:x:1002:

Step 2) etc/pam.d/su 파일 내 su 명령어 허용 그룹 확인

Step 3) usr/bin/su 파일 내 su 명령어 그룹과 권한 확인

Step 4) /etc/pam.d/su 파일에 모듈 값 수정

```
auth                required pam_wheel.so use_uid
```

또는

```
auth                required pam_wheel.so group=wheel
```

01. Unix 서버

U-07 (하)	UNIX > 1. 계정 관리
	불필요한 계정 제거
개요	
점검 내용	시스템 계정 중 불필요한 계정(퇴직, 전직, 휴직 등의 이유로 사용하지 않는 계정 및 장기적으로 사용하지 않는 계정 등)이 존재 여부 점검
점검 목적	불필요한 계정이 존재하는지 점검하여 관리되지 않은 계정에 의한 침입에 대비하는지 확인하기 위함
보안 위협	로그인이 가능하고 현재 사용하지 않는 불필요한 계정은 사용 중인 계정보다 상대적으로 관리가 취약하여 공격자의 목표가 되어 계정이 탈취될 수 있는 위험이 존재함(퇴직, 전직, 휴직 등의 사유 발생 시 즉시 권한을 회수하는 것을 권고함)
참고	※ 기본 계정 : OS나 Package 설치 시 기본적으로 생성되는 계정(lp, uucp, nuucp 등) ※ 불필요한 기본 계정 제거 시 발생할 업무 영향도를 파악한 후 제거 권고
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 불필요한 계정이 존재하지 않는 경우
	취약 : 불필요한 계정이 존재하는 경우
조치 방법	시스템에 존재하는 계정 확인 후 불필요한 계정 제거하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

[/etc/passwd 파일을 이용하여 점검]

Step 1) /etc/passwd 파일 내 계정을 확인 후 “# userdel <사용자 이름>” 명령으로 불필요한 사용자 계정 제거

※ AIX 경우 rmuser 명령어 사용

※ /etc/passwd 파일에서 계정 앞에 #을 삽입하여도 주석으로 처리되지 않으므로 조치 시에는 반드시 계정을 제거하도록 권고함

[log를 이용하여 점검]

Step 1) last 명령어로 불필요한 계정 확인 후 제거

U-08 (중)	UNIX > 1. 계정 관리
	관리자 그룹에 최소한의 계정 포함
개요	
점검 내용	시스템 관리자 그룹에 최소한(root 계정과 시스템 관리에 허용된 계정)의 계정만 존재 여부 점검
점검 목적	관리자 그룹에 최소한의 필요 계정만 존재하는지 확인하여 불필요한 권한 남용을 점검하기 위함
보안 위험	시스템을 관리하는 root 계정이 속한 그룹은 시스템 운영 파일에 대한 접근 권한이 부여되어 있으므로 해당 관리자 그룹에 속한 계정이 비인가자에게 유출될 경우, 관리자 권한으로 시스템에 접근하여 계정정보 유출, 환경설정 파일 및 디렉터리 변조 등의 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 관리자 그룹에 불필요한 계정이 등록되어 있지 않은 경우
	취약 : 관리자 그룹에 불필요한 계정이 등록된 경우
조치 방법	관리자 그룹에 등록된 계정 확인 후 불필요한 계정 제거하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/group 파일에 root 그룹에 포함된 계정 확인

Step 2) 불필요한 계정을 그룹원에서 제거

```
# gpasswd -d <사용자 이름> root
```

※ AIX의 경우 chgrpmem -m - <사용자 이름> root 명령어 사용

U-09 (하)	UNIX > 1. 계정 관리
	계정이 존재하지 않는 GID 금지
개요	
점검 내용	그룹 설정 파일(/etc/group)에 불필요한 그룹이 존재 여부 점검
점검 목적	시스템에 불필요한 그룹이 존재하는지 점검하여 불필요한 그룹의 소유권으로 설정된 파일의 노출로 인해 발생할 수 있는 위험에 대해 대비를 하기 위함
보안 위협	계정이 존재하지 않거나 불필요한 그룹이 존재하는 경우, 해당 그룹의 소유로 설정된 파일을 통한 권한 남용 또는 의도치 않은 권한 부여, 보안 감사 및 관리의 어려움 등의 위험이 존재함
참고	※ GID(Group Identification) : 다수의 사용자가 특정 개체를 공유할 수 있게 연계시키는 특정 그룹의 이름으로 주로 계정처리 목적으로 사용되며, 한 사용자는 여러 개의 GID를 가질 수 있음
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 시스템 관리나 운용에 불필요한 그룹이 제거된 경우
	취약 : 시스템 관리나 운용에 불필요한 그룹이 존재하는 경우
조치 방법	불필요한 그룹이 존재하는 경우 관리자와 검토하여 제거하도록 설정 ※ /etc/group 파일과 /etc/passwd 파일을 비교하여 점검하기를 권고함
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/group, /etc/gshadow 파일에 계정이 존재하지 않거나, 불필요한 그룹 확인

Step 2) 불필요한 그룹 제거

```
# groupdel <그룹 이름>
```

※ 해당 그룹 제거 시 그룹 권한으로 존재하는 파일이 존재하는지 확인이 필요하며, 사용자가 없는 그룹이더라도 추후 권한 할당을 위해 그룹을 먼저 생성하였을 가능성도 존재하므로 확인 필요

U-10 (중)	UNIX > 1. 계정 관리
	동일한 UID 금지
개요	
점검 내용	/etc/passwd 파일 내 UID가 동일한 사용자 계정 존재 여부 점검
점검 목적	UID가 동일한 사용자 계정을 점검함으로써 타 사용자 계정 소유의 파일 및 디렉터리로의 악의적 접근 예방 및 침해사고 시 명확한 감사 추적을 하기 위함
보안 위협	중복된 UID가 존재할 경우, 시스템은 동일한 사용자로 인식하여 소유자의 권한이 중복되어 불필요한 권한이 부여되며 시스템 로그를 이용한 감사 추적 시 사용자가 구분되지 않는 위험이 존재함
참고	※ 비밀번호 파일 수정 변경 및 신규 사용자 추가 시 UID가 동일한 계정이 존재하는지 확인해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 동일한 UID로 설정된 사용자 계정이 존재하지 않는 경우
	취약 : 동일한 UID로 설정된 사용자 계정이 존재하는 경우
조치 방법	동일한 UID를 가진 사용자 계정의 UID를 중복되지 않도록 변경하도록 설정
조치 시 영향	운영 목적으로 동일한 UID 값을 부여하였다면 해당 계정이 사용하고 있는 파일 및 디렉터리를 검토하여 권한이 제거되어도 서비스 영향이 없는지 확인 필요

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/passwd 파일에 동일한 UID가 존재하는지 확인

Step 2) 명령으로 중복된 UID로 변경

```
# usermod -u <변경할 UID> <사용자 이름>
```

※ AIX의 경우 chuser id=<변경할 UID> <사용자 이름> 명령어 사용

01. Unix 서버

U-11 (하)	UNIX > 1. 계정 관리
	사용자 shell 점검
개요	
점검 내용	로그인이 불필요한 계정(adm, sys, daemon 등)에 셸 부여 여부 점검
점검 목적	로그인이 불필요한 계정에 부여된 셸을 제거하여, 로그인에 필요하지 않은 계정을 통한 시스템 명령어를 실행하지 못하게 하기 위함
보안 위험	로그인이 불필요한 계정에 셸이 부여될 경우, 비인가자가 해당 기본 계정으로 시스템에 접근 위험이 존재함
참고	※ 셸(Shell) : 대화형 사용자 인터페이스로써, 운영체제(OS) 가장 외곽계층에 존재하여 사용자의 명령어를 이해하고 실행함 ※ /bin/false : 시스템 접근을 항상 실패로 처리해 로그인을 차단하고, 사용자에게 메시지를 출력하지 않으며, 서비스 계정의 직접 접근 차단에 사용됨 ※ /sbin/nologin : 로그인 시 “This account is currently not available” 메시지를 출력하며 접근을 차단하고, FTP와 같은 일부 서비스의 접근은 허용됨
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 로그인이 필요하지 않은 계정에 /bin/false(/sbin/nologin) 셸이 부여된 경우
	취약 : 로그인이 필요하지 않은 계정에 /bin/false(/sbin/nologin) 셸이 부여되지 않은 경우
조치 방법	로그인이 필요하지 않은 계정에 대해 /bin/false(/sbin/nologin) 셸 부여 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/passwd 파일을 참고하여 로그인이 불필요한 계정에 /bin/false(/sbin/nologin) 셸 부여 여부 확인

```
# cat /etc/passwd | grep -E “^daemon|^bin|^sys|^adm|^listen|^nobody|^nobody4|^noaccess|^diag|^operator|^games|^gopher” | grep -v admin
```

Step 2) 로그인이 불필요한 계정에 /bin/false 또는 /sbin/nologin 셸 부여

```
# usermod -s /bin/false <계정명>
```

```
# usermod -s /sbin/nologin <계정명>
```

로그인이 불필요한 계정 목록

deamon, bin, sys, adm, listen, nobody, nobody4, noaccess, diag, operator, games, gopher

U-12 (하)	UNIX > 1. 계정 관리
	세션 종료 시간 설정
개요	
점검 내용	사용자 쉘에 대한 환경설정 파일에서 Session Timeout 설정 여부 점검
점검 목적	사용자의 고의 또는 실수로 시스템에 계정이 접속된 상태로 방치됨을 차단하기 위함
보안 위협	Session timeout 값이 설정되지 않을 경우, 유효 시간 내 비인가자가 시스템에 접근하여 불필요한 내부 정보를 노출할 위험이 존재함
참고	※ Session : 프로세스들 사이에 통신을 수행하기 위해서 메시지 교환을 통해 서로를 인식한 이후부터 통신을 마칠 때까지의 시간
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : Session Timeout이 600초(10분) 이하로 설정된 경우
	취약 : Session Timeout이 600초(10분) 이하로 설정되지 않은 경우
조치 방법	600초(10분) 동안 입력이 없는 경우 접속된 Session을 끊도록 설정
조치 시 영향	모니터링 용도일 경우 세션 타임 설정 시 모니터링 업무가 불가할 수 있으므로 예외 처리 필요

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

[sh, ksh, bash]

Step 1) /etc/profile 파일 내 TMOUT 값 설정

```
TMOUT=600
export TMOUT
```

[csh]

Step 1) /etc/csh.cshrc 또는 /etc/csh.login 파일 내 autologout 값 설정

```
set autologout=10
```

01. Unix 서버

U-13 (중)	UNIX > 1. 계정 관리
	안전한 비밀번호 암호화 알고리즘 사용
개요	
점검 내용	안전한 비밀번호 암호화 알고리즘을 사용 여부 점검
점검 목적	안전한 비밀번호 암호화 알고리즘을 사용하여 사용자 계정정보를 보호하기 위함
보안 위협	취약한 비밀번호 암호화 알고리즘을 사용할 경우, 노출된 계정에 대해 비인가자가 암호 복호화 공격을 통해 비밀번호를 획득할 위험이 존재함
참고	※ 비밀번호 암호화 알고리즘 저장 방식을 바꾸어도 passwd 명령을 이용하여 재설정해야 변경된 비밀번호 암호화 알고리즘이 적용되므로 취약한 비밀번호 암호화 알고리즘을 사용하고 있는 모든 계정 비밀번호 재설정 필요 ※ 비밀번호 암호화 알고리즘: \$1 : MD5 / \$2 : Blowfish / \$5 : SHA-256 / \$6 : SHA-512
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : SHA-2 이상의 안전한 비밀번호 암호화 알고리즘을 사용하는 경우
	취약 : 취약한 비밀번호 암호화 알고리즘을 사용하는 경우
조치 방법	SHA-2 이상의 안전한 비밀번호 암호화 알고리즘 적용 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) /etc/passwd 파일 내 암호화 필드 값 확인

Step 2) /etc/security/policy.conf 파일 내 CRYPT_DEFAULT 값 설정

CRYPT_DEFAULT = 5 또는 6

※ CRYPT_DEFAULT = 5: SHA-256 / 6 : SHA-512

● LINUX

[Redhat]

Step 1) /etc/shadow(또는 /etc/passwd) 파일 내 암호화 필드 값 확인

Step 2) /etc/login.defs 파일 내 ENCRYPT_METHOD 값 설정

ENCRYPT_METHOD <SHA-2 이상 암호화 알고리즘(SHA-256 또는 SHA-512)>

Step 3) /etc/pam.d/system-auth 파일 내 안전한 알고리즘 설정

password sufficient pam_unix.so <SHA-2 이상 암호화 알고리즘>

[Debian]

Step 1) /etc/shadow(또는 /etc/passwd) 파일 내의 암호화 필드 값 확인

Step 2) /etc/login.defs 파일 내 ENCRYPT_METHOD 값 설정

ENCRYPT_METHOD <SHA-2 이상 암호화 알고리즘(SHA-256 또는 SHA-512 또는 yescrypt)>

Step 3) /etc/pam.d/common-password 파일 내 안전한 알고리즘 설정

password[success=2 default=ignore] pam_unix.so <SHA-2 이상 암호화 알고리즘>

● AIX

Step 1) /etc/security/passwd 파일 내 비밀번호 암호화 알고리즘 확인

password = {<암호화 알고리즘>}<해시값>

Step 2) 안전한 암호화 알고리즘 설정

chsec -f /etc/security/login.cfg -s usw -a pwd_algorithm=<SHA-2 이상 암호화 알고리즘(SHA-256 또는 SHA-512)>

※ /etc/security/pwddalg.cfg 파일을 참조하여 OS에서 정의된 암호화 알고리즘 확인 가능

● HP-UX

Step 1) /etc/shadow 파일 내의 암호화 필드 값 확인

Step 2) /etc/default/security 파일 내 CRYPT_DEFAULT 값 설정

CRYPT_DEFAULT = 5 또는 6

※ HP-UX 11i v2 이상이며, PHI 및 shadow password를 사용하지 않는 경우 취약

※ CRYPT_DEFAULT = 5: SHA-256 / 6 : SHA-512

01. Unix 서버

U-14 (상)	UNIX > 2. 파일 및 디렉토리 관리
	root 홈, 패스 디렉터리 권한 및 패스 설정
개요	
점검 내용	root 계정의 PATH 환경변수에 “.”(마침표)이 포함 여부 점검
점검 목적	비인가자가 불법적으로 생성한 디렉터리 및 명령어를 우선으로 실행되지 않도록 설정하기 위함
보안 위험	root 계정의 PATH 환경변수에 정상적인 관리자 명령어(ls, mv, cp 등)의 디렉터리 경로보다 현재 디렉터리를 지칭하는 “.” 표시가 우선하면 현재 디렉터리에 변조된 명령어를 삽입하여 관리자 명령어 입력 시 악의적인 기능이 실행될 수 있는 위험이 존재함
참고	※ 환경변수 : 프로세스가 컴퓨터에서 동작하는 방식에 영향을 미치는 동적인 값들의 집합으로 PATH 환경변수는 실행 파일을 찾는 경로에 대한 변수를 뜻함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : PATH 환경변수에 “.” 이 맨 앞이나 중간에 포함되지 않은 경우
	취약 : PATH 환경변수에 “.” 이 맨 앞이나 중간에 포함된 경우
조치 방법	root 계정의 환경설정 파일(/.profile, /.bashrc 등)과 시스템 환경설정 파일(/etc/profile 등)에 설정된 PATH 환경변수에서 현재 디렉터리를 나타내는 “.”을 PATH 환경변수의 마지막으로 이동하도록 설정 ※ /etc/profile 파일, root 계정, 일반 사용자 계정의 환경설정 파일을 순차적으로 검색하여 확인
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) PATH 환경변수 확인

echo \$PATH

Step 2) 환경설정 파일 내 PATH 변수값 수정

PATH=\$PATH:\$HOME/bin:<상대 경로> 또는 상대 경로 삭제

Shell 종류별 환경설정 파일	
Bourne Shell(sh)	/etc/profile, \$HOME/.profile
C Shell(csh)	/etc/csh.cshrc, /etc/csh.login, \$HOME/.cshrc, \$HOME/.login
Korn Shell(ksh)	/etc/profile, \$HOME/.profile, \$HOME/.kshrc
Bash Shell(bash)	/etc/profile, \$HOME/.bash_profile, \$HOME/.bashrc, /etc/bash.bashrc

U-15 (상)	UNIX > 2. 파일 및 디렉토리 관리
	파일 및 디렉터리 소유자 설정
개요	
점검 내용	소유자가 존재하지 않는 파일 및 디렉터리의 존재 여부 점검
점검 목적	소유자가 존재하지 않는 파일 및 디렉터리를 제거 또는 관리하여 임의의 사용자가 해당 파일을 열람, 수정하는 행위를 사전에 차단하기 위함
보안 위협	소유자가 존재하지 않는 파일의 UID와 동일한 값으로 특정 계정의 UID를 변경하면 해당 파일의 소유자가 되어 모든 작업이 가능한 위험이 존재함
참고	※ 소유자가 존재하지 않는 파일 및 디렉터리는 일반적으로 퇴직자의 자료, 관리 소홀로 인해 생긴 파일 또는 해킹으로 인한 공격자가 만들어 놓은 악의적인 파일임
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 소유자가 존재하지 않는 파일 및 디렉터리가 존재하지 않는 경우
	취약 : 소유자가 존재하지 않는 파일 및 디렉터리가 존재하는 경우
조치 방법	소유자가 존재하지 않는 파일 및 디렉터리 제거 또는 소유자 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) 소유자와 그룹이 존재하지 않는 파일 및 디렉터리 확인

```
# find /\( -nouser -o -nogroup \) -xdev -ls 2>/dev/null
```

Step 2) 소유자가 존재하지 않는 파일 또는 디렉터리 제거

```
# rm <파일 이름>
```

```
# rm -r <디렉터리 이름>
```

Step 3) 사용 중인 파일 및 디렉터리의 경우 소유자 및 그룹 변경

```
# chown <사용자 이름> <파일 및 디렉터리 이름>
```

```
# chgrp <그룹 이름> <파일 및 디렉터리 이름>
```

※ 소유자 또는 그룹이 존재하지 않는 파일은 파일 속성의 해당 필드에 UID, GID가 숫자로 표시됨

01. Unix 서버

U-16 (상)	UNIX > 2. 파일 및 디렉토리 관리
	/etc/passwd 파일 소유자 및 권한 설정
개요	
점검 내용	/etc/passwd 파일 권한 적절성 여부 점검
점검 목적	/etc/passwd 파일을 관리자만 제어할 수 있게 하여 비인가자들의 임의적인 파일 변조를 방지하기 위함
보안 위협	비인가자가 /etc/passwd 파일의 사용자 정보를 변조하여 Shell 변경, 사용자 추가/제거 등 root 계정을 포함한 사용자 권한 획득 위험이 존재함
참고	※ /etc/passwd : 사용자의 ID, UID, GID, 홈 디렉터리, 셸 정보를 담고 있는 파일
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : /etc/passwd 파일의 소유자가 root이고, 권한이 644 이하인 경우
	취약 : /etc/passwd 파일의 소유자가 root가 아니거나, 권한이 644 이하가 아닌 경우
조치 방법	/etc/passwd 파일 소유자 및 권한 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/passwd 파일 소유자 및 권한 확인

ls -l /etc/passwd

Step 2) /etc/passwd 파일 소유자 및 권한 변경

chown root /etc/passwd

chmod 644 /etc/passwd

U-17 (상)	UNIX > 2. 파일 및 디렉토리 관리
	시스템 시작 스크립트 권한 설정
개요	
점검 내용	시스템 시작 스크립트 파일 권한 적절성 여부 점검
점검 목적	시스템 시작 스크립트 파일을 관리자만 제어할 수 있게 하여 비인가자들의 임의적인 파일 변조를 방지하기 위함
보안 위협	시스템 시작 스크립트 파일의 소유권 및 권한 설정이 미흡할 경우, 비인가자가 스크립트의 내용 변경 등을 통해 시스템 침입 등 악용할 위험이 존재함
참고	※ 시스템 시작 스크립트 : 운영체제 부팅 시 자동으로 실행되어 시스템 초기화 작업을 수행하고, 필요한 서비스와 데몬을 시작하는 스크립트
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 시스템 시작 스크립트 파일의 소유자가 root이고, 일반 사용자의 쓰기 권한이 제거된 경우
	취약 : 시스템 시작 스크립트 파일의 소유자가 root가 아니거나, 일반 사용자의 쓰기 권한이 부여된 경우
조치 방법	시스템 시작 스크립트 파일 소유자 및 권한 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) 시스템 시작 스크립트 파일 소유자 및 권한 확인

```
# ls -al `readlink -f /etc/rc*.d/` | sed 's/$/*/'`
```

Step 2) 시스템 시작 스크립트 파일 소유자 및 권한 변경

```
# chown root <파일 이름>
```

```
# chmod o-w <파일 이름>
```

● LINUX

[init]

Step 1) 시스템 시작 스크립트 파일 소유자 및 권한 확인

```
# ls -al `readlink -f /etc/rc.d/*` | sed 's/$/*/'`
```

Step 2) 시스템 시작 스크립트 파일 소유자 및 권한 변경

```
# chown root <파일 이름>
```

```
# chmod o-w <파일 이름>
```

[systemd]

Step 1) 시스템 시작 스크립트 파일 소유자 및 권한 확인

```
# ls -al `readlink -f /etc/systemd/system/*` | sed 's/$/*/'
```

Step 2) 시스템 시작 스크립트 파일 소유자 및 권한 변경

```
# chown root /etc/systemd/system/<파일 이름>
```

```
# chmod o-w /etc/systemd/system/<파일 이름>
```

● AIX

Step 1) 시스템 시작 스크립트 파일 소유자 및 권한 확인

```
# find /etc/rc.d/*/* -type l -exec ls -l {} +
```

Step 2) 시스템 시작 스크립트 파일 소유자 및 권한 변경

```
# chown root <파일 이름>
```

```
# chmod o-w <파일 이름>
```

● HP-UX

Step 1) 시스템 시작 스크립트 파일 소유자 및 권한 확인

```
# find /sbin/rc*.d/ -type l -exec ls -l {} +
```

Step 2) 시스템 시작 스크립트 파일 소유자 및 권한 변경

```
# chown root <파일 이름>
```

```
# chmod o-w <파일 이름>
```

U-18 (상)	UNIX > 2. 파일 및 디렉토리 관리
	/etc/shadow 파일 소유자 및 권한 설정
개요	
점검 내용	/etc/shadow 파일 권한 적절성 여부 점검
점검 목적	/etc/shadow 파일을 관리자만 제어할 수 있게 하여 비인가자들의 임의적인 파일 변조를 방지하기 위함
보안 위협	/etc/shadow 파일에 저장된 암호화된 해시값을 복호화하여(크래킹) 비밀번호를 탈취할 위험이 존재함
참고	※ /etc/shadow : 시스템에 등록된 모든 계정의 비밀번호를 암호화된 형태로 저장 및 관리하는 파일
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : /etc/shadow 파일의 소유자가 root이고, 권한이 400 이하인 경우
	취약 : /etc/shadow 파일의 소유자가 root가 아니거나, 권한이 400 이하가 아닌 경우
조치 방법	/etc/shadow 파일 소유자 및 권한 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX

Step 1) /etc/shadow 파일 소유자 및 권한 변경

```
# chown root /etc/shadow
# chmod 400 /etc/shadow
```

● AIX

Step 1) /etc/security/passwd 파일 소유자 및 권한 변경

```
# chown root /etc/security/passwd
# chmod 400 /etc/security/passwd
```

● HP-UX

Step 1) /tcb/files/auth/ 디렉터리 소유자 및 권한 변경

```
# chown root /tcb/files/auth
# chmod 400 /tcb/files/auth
```

01. Unix 서버

U-19 (상)	UNIX > 2. 파일 및 디렉토리 관리
	/etc/hosts 파일 소유자 및 권한 설정
개요	
점검 내용	/etc/hosts 파일의 권한 적절성 여부 점검
점검 목적	/etc/hosts 파일을 관리자만 제어할 수 있게 하여 비인가자들의 임의적인 파일 변조를 방지하기 위함
보안 위협	• /etc/hosts 파일에 비인가자가 쓰기 권한이 부여된 경우, 공격자는 /etc/hosts 파일에 악의적인 시스템을 등록하여, 이를 통해 정상적인 DNS를 우회하여 악성 사이트로의 접속을 유도하는 파밍(Pharming) 공격 등에 악용될 수 있는 위험이 존재함 • /etc/hosts 파일에 소유자의 쓰기 권한이 부여된 경우, 일반 사용자 권한으로 /etc/hosts 파일에 변조된 IP주소를 등록하여 정상적인 DNS를 방해하고 악성 사이트로의 접속을 유도하는 파밍(Pharming) 공격 등에 악용될 수 있는 위험이 존재함
참고	※ /etc/hosts: IP주소와 호스트 이름을 매핑하는 파일. 일반적으로 인터넷 통신 시 주소를 찾기 위해 도메인 네임 서비스(DNS)보다 /etc/hosts 파일을 먼저 참조함. /etc/hosts 파일은 문자열 주소로부터 IP주소를 수신받는 DNS 서버와는 달리 파일 내에 직접 문자열 주소와 IP주소를 매핑하여 기록하며, DNS 서버 접근 이전에 확인하여 해당 문자열 주소가 목록에 존재할 시 그 문자열 주소에 해당하는 IP주소로 연결함 ※ 파밍(Pharming): 사용자의 DNS 또는 /etc/hosts 파일을 변조함으로써 정상적인 사이트로 오인하여 접속하도록 유도한 뒤 개인정보를 훔치는 새로운 컴퓨터 범죄 수법
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : /etc/hosts 파일의 소유자가 root이고, 권한이 644 이하인 경우
	취약 : /etc/hosts 파일의 소유자가 root가 아니거나, 권한이 644 이하가 아닌 경우
조치 방법	/etc/hosts 파일 소유자 및 권한 변경 설정
조치 시 영향	/etc/hosts 파일에 시스템 정보가 설정된 경우 해당 파일을 참조하는 서비스에 영향을 미칠 수 있음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/hosts 파일 소유자 및 권한 변경

chown root /etc/hosts

chmod 644 /etc/hosts

U-20 (상)	UNIX > 2. 파일 및 디렉토리 관리
	/etc/(x)inetd.conf 파일 소유자 및 권한 설정
개요	
점검 내용	/etc/(x)inetd.conf 파일 권한 적절성 여부 점검
점검 목적	/etc/(x)inetd.conf 파일을 관리자만 제어하여 비인가자들의 임의적인 파일 변조를 방지하기 위함
보안 위협	/etc/(x)inetd.conf 파일에 소유자 외 쓰기 권한이 부여된 경우, 일반 사용자 권한으로 해당 파일에 등록된 서비스를 변조하거나 악의적인 프로그램(서비스)을 등록할 수 있는 위험이 존재함
참고	※ (x)inetd(슈퍼데몬): 자주 사용하지 않는 서비스가 상시 실행되어 메모리를 점유하는 것을 방지하기 위해 (x)inetd(슈퍼데몬)에 자주 사용하지 않는 서비스를 등록하여 요청이 있을 시에만 해당 서비스를 실행하고 요청이 끝나면 서비스를 종료하는 역할 수행
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : /etc/(x)inetd.conf 파일의 소유자가 root이고, 권한이 600 이하인 경우
	취약 : /etc/(x)inetd.conf 파일의 소유자가 root가 아니거나, 권한이 600 이하가 아닌 경우
조치 방법	/etc/(x)inetd.conf 파일 소유자 및 권한 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, AIX, HP-UX

Step 1) /etc/inetd.conf 파일 소유자 및 권한 변경

```
# chown root /etc/inetd.conf
```

```
# chmod 600 /etc/inetd.conf
```

● LINUX

[inetd]

Step 1) /etc/inetd.conf 파일 소유자 및 권한 변경

```
# chown root /etc/inetd.conf
```

```
# chmod 600 /etc/inetd.conf
```

[xinetd]

Step 1) /etc/xinetd.conf 파일 소유자 및 권한 변경

```
# chown root /etc/xinetd.conf
```

```
# chmod 600 /etc/xinetd.conf
```

Step 2) /etc/xinetd.d/ 디렉터리 내 모든 파일의 소유자 및 권한 변경

```
# chown -R root /etc/xinetd.d/
```

```
# chmod -R 600 /etc/xinetd.d/
```

[systemd]

Step 1) /etc/systemd/system.conf 파일 소유자 및 권한 변경

```
# chown root /etc/systemd/system.conf
```

```
# chmod 600 /etc/systemd/system.conf
```

Step 2) /etc/systemd/ 디렉터리 내 모든 파일의 소유자 및 권한 변경

```
# chown -R root /etc/systemd/
```

```
# chmod -R 600 /etc/systemd/
```

U-21 (상)	UNIX > 2. 파일 및 디렉토리 관리
	/etc/(r)syslog.conf 파일 소유자 및 권한 설정
개요	
점검 내용	/etc/(r)syslog.conf 파일 권한 적절성 여부 점검
점검 목적	/etc/(r)syslog.conf 파일의 권한 적절성을 점검하여, 비인가자의 임의적인 /etc/(r)syslog.conf 파일 변조를 방지하기 위함
보안 위협	/etc/(r)syslog.conf 파일의 설정 내용을 참조하여 로그의 저장 위치가 노출되며 로그를 기록하지 않도록 설정하거나 대량의 로그를 기록하게 하여 시스템 과부하를 유도할 수 있는 위험이 존재함
참고	※ /etc/(r)syslog.conf : (r)syslogd 데몬 실행 시 참조되는 설정 파일로 시스템 로그 기록의 종류, 위치 및 Level을 설정할 수 있음
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : /etc/(r)syslog.conf 파일의 소유자가 root(또는 bin, sys)이고, 권한이 640 이하인 경우
	취약 : /etc/(r)syslog.conf 파일의 소유자가 root(또는 bin, sys)가 아니거나, 권한이 640 이하가 아닌 경우
조치 방법	/etc/(r)syslog.conf 파일 소유자 및 권한 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/(r)syslog.conf 파일 소유자 및 권한 변경

```
# chown root /etc/(r)syslog.conf
```

```
# chmod 640 /etc/(r)syslog.conf
```

01. Unix 서버

U-22 (상)	UNIX > 2. 파일 및 디렉토리 관리
	/etc/services 파일 소유자 및 권한 설정
개요	
점검 내용	/etc/services 파일 권한 적절성 여부 점검
점검 목적	/etc/services 파일을 관리자만 제어할 수 있게 하여 비인가자들의 임의적인 파일 변조를 방지하기 위함
보안 위협	/etc/services 파일의 접근 권한이 적절하지 않을 경우, 비인가 사용자가 운영 포트 번호를 변경하여 정상적인 서비스를 제한하거나 허용되지 않은 포트를 오픈하여 악성 서비스를 의도적으로 실행할 수 있는 위험이 존재함
참고	※ /etc/services : 서비스 관리를 위해 사용되는 파일. 해당 파일에 서버에서 사용하는 모든 포트에 대해 정의되어 있으며, 필요시 서비스 기본 사용 포트를 변경하여 네트워크 서비스를 운용할 수 있음
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : /etc/services 파일의 소유자가 root(또는 bin, sys)이고, 권한이 644 이하인 경우
	취약 : /etc/services 파일의 소유자가 root(또는 bin, sys)가 아니거나, 권한이 644 이하가 아닌 경우
조치 방법	/etc/ services 파일 소유자 및 권한 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/services 파일 소유자 및 권한 변경

chown root /etc/services

chmod 644 /etc/services

U-23 (상)	UNIX > 2. 파일 및 디렉토리 관리
	SUID, SGID, Sticky bit 설정 파일 점검
개요	
점검 내용	불필요하거나 악의적인 파일에 SUID, SGID, Sticky bit 설정 여부 점검
점검 목적	불필요한 SUID, SGID, Sticky bit 설정 제거로 악의적인 사용자의 권한 상승을 방지하기 위함
보안 위협	SUID, SGID, Sticky bit 설정이 적절하지 않을 경우, SUID, SGID, Sticky bit가 설정된 파일로 특정 명령어를 실행하여 root 권한 획득이 가능한 위험이 존재함
참고	※ SUID : 설정된 파일 실행 시, 특정 작업 수행을 위하여 일시적으로 파일 소유자의 권한을 얻게 됨 ※ SGID : 설정된 파일 실행 시, 특정 작업 수행을 위하여 일시적으로 파일 소유 그룹의 권한을 얻게 됨 ※ Sticky bit : 설정된 파일의 수정/삭제는 소유자만 가능한 권한
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 주요 실행 파일의 권한에 SUID와 SGID에 대한 설정이 부여되어 있지 않은 경우
	취약 : 주요 실행 파일의 권한에 SUID와 SGID에 대한 설정이 부여된 경우
조치 방법	• 불필요한 SUID, SGID 권한 또는 해당 파일 제거하도록 설정 • 애플리케이션에서 생성한 파일이나 사용자가 임의로 생성한 파일 등 의심스럽거나 특이한 파일에 SUID 권한이 부여된 경우 제거하도록 설정
조치 시 영향	SUID, SGID, Sticky bit 설정 파일 제거 시, OS 및 응용프로그램 등 서비스 정상 작동 확인 필요

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) SUID, SGID가 설정된 파일 확인

```
# find / -user root -type f \( -perm -04000 -o -perm -02000 \) -xdev -exec ls -al {} \;
```

Step 2) 불필요한 특수 권한 제거

```
# chmod -s <파일 이름>
```

Step 3) 반드시 사용이 필요한 경우 특정 그룹에서만 사용하도록 제한하여 일반 사용자의 Setuid 사용 제한

```
# chgrp <그룹 이름> <SUID를 설정할 파일>
```

```
# chmod 4750 <SUID를 설정할 파일>
```

U-24 (상)	UNIX > 2. 파일 및 디렉토리 관리
	사용자, 시스템 환경변수 파일 소유자 및 권한 설정
개요	
점검 내용	홈 디렉터리 내의 환경변수 파일에 대한 소유자 및 접근 권한이 관리자 또는 해당 계정으로 설정 여부 점검
점검 목적	비인가자의 환경변수 조작으로 인한 보안 위험이 존재함
보안 위험	홈 디렉터리 내의 사용자 파일 및 사용자별 시스템 시작 파일 등과 같은 환경변수 파일의 접근 권한 설정이 적절하지 않을 경우, 비인가자가 환경변수 파일을 변조하여 정상 사용 중인 사용자의 서비스가 제한될 수 있는 위험이 존재함
참고	※ 환경변수 파일 종류 : .profile, .kshrc, .cshrc, .bashrc, .bash_profile, .login, .exrc, .netrc 등
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 홈 디렉터리 환경변수 파일 소유자가 root 또는 해당 계정으로 지정되어 있고, 홈 디렉터리 환경변수 파일에 root 계정과 소유자만 쓰기 권한이 부여된 경우
	취약 : 홈 디렉터리 환경변수 파일 소유자가 root 또는 해당 계정으로 지정되지 않거나, 홈 디렉터리 환경변수 파일에 root 계정과 소유자 외에 쓰기 권한이 부여된 경우
조치 방법	환경변수 파일의 일반 사용자 쓰기 권한 제거하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) 홈 디렉터리 환경변수 파일 소유자 및 권한 확인

```
# ls -l <홈 디렉터리 환경변수 파일>
```

환경변수 파일 종류: .profile, .kshrc, .cshrc, .bashrc, .bash_profile, .login, .exrc, .netrc 등

Step 2) 홈 디렉터리 환경변수 파일 소유자 및 권한 변경

```
# chown <root 또는 파일 소유자> <홈 디렉터리 환경변수 파일>
```

```
# chmod o-w <홈 디렉터리 환경변수 파일>
```

U-25 (상)	UNIX > 2. 파일 및 디렉토리 관리
	world writable 파일 점검
개요	
점검 내용	불필요한 world writable 파일 여부 점검
점검 목적	world writable 파일을 이용한 시스템 접근 및 악의적인 코드 실행을 방지하기 위함
보안 위협	시스템 파일과 같은 중요 파일에 world writable이 적용될 경우, 일반 사용자 및 비인가자가 해당 파일을 임의로 수정, 제거할 위험이 존재함
참고	※ world writable 파일 : 모든 사용자에게 쓰기 권한이 부여된 파일 (예시 : -rwxrwxrwx root root <파일명>)
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : world writable 파일이 존재하지 않거나, 존재 시 설정 이유를 인지하고 있는 경우
	취약 : world writable 파일이 존재하나 설정 이유를 인지하지 못하고 있는 경우
조치 방법	world writable 파일 존재 여부를 확인하고 불필요한 경우 제거하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

[일반 사용자 쓰기 권한 제거]

Step 1) world writable 파일 확인

```
# find / -type f -perm -2 -exec ls -l {} \;
```

Step 2) 일반 사용자 쓰기 권한 제거

```
# chmod o-w <파일 이름>
```

Step 3) 불필요한 world writable 파일 제거

```
# rm <파일 이름>
```

01. Unix 서버

U-26 (상)	UNIX > 2. 파일 및 디렉토리 관리
	/dev에 존재하지 않는 device 파일 점검
개요	
점검 내용	허용할 호스트에 대한 접속 IP주소 제한 및 포트 제한 설정 여부 점검
점검 목적	허용한 호스트만 서비스를 사용하게 하여 서비스 취약점을 이용한 외부자 공격을 방지하기 위함
보안 위협	공격자는 rootkit 설정 파일들을 서버 관리자가 쉽게 발견하지 못하도록 /dev 디렉터리에 device 파일인 것처럼 위장하는 수법을 사용하는 위험이 존재함
참고	※ /dev 디렉터리: 논리적 장치 파일을 담고 있는 디렉터리이며 /devices 디렉터리에 있는 물리적 장치 파일에 대한 심볼릭 링크임. 예를 들어 rmt0를 rmt로 잘못 입력한 경우, rmt0 파일이 새로 생성되는 것과 같이 디바이스 이름 입력 오류 시 root 파일 시스템이 에러를 일으킬 때까지 /dev 디렉터리에 계속해서 파일을 생성함 ※ /dev 디렉터리 내 mqueue, shm 파일은 시스템에서 생성 또는 제거가 주기적으로 일어나므로 예외
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : /dev 디렉터리에 대한 파일 점검 후 존재하지 않는 device 파일을 제거한 경우
	취약 : /dev 디렉터리에 대한 파일 미점검 또는 존재하지 않는 device 파일을 방치한 경우
조치 방법	major, minor number를 가지지 않는 device 파일 제거하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /dev 디렉터리 내 불필요하거나 존재하지 않는 device 파일 확인 및 삭제

```
# find /dev -type f -exec ls -l {} \;
```

```
# rm <파일 이름>
```

U-27 (상)	UNIX > 2. 파일 및 디렉토리 관리
	\$HOME/.rhosts, hosts.equiv 사용 금지
개요	
점검 내용	\$HOME/.rhosts 및 /etc/hosts.equiv 파일에 대해 적절한 소유자 및 접근 권한 설정 여부 점검
점검 목적	r-command를 통한 별도의 인증 없는 관리자 권한 원격 접속을 차단하기 위함
보안 위험	- r-command(rlogin, rsh 등)에 보안 설정이 적용되지 않을 경우, 원격지의 공격자가 관리자 권한으로 목표 시스템상 임의의 명령을 수행시킬 수 있으며, 명령어 원격실행을 통해 중요 정보유출 및 시스템 장애를 유발 또는 공격자의 백도어 등으로도 활용될 수 있는 위험이 존재함 - 해당 파일은 r-command 서비스의 접근통제에 관련된 파일이며, 권한 설정이 부적절한 경우 r-command 서비스 사용 권한을 임의로 등록하여 무단 사용 위험이 존재함
참고	※ /etc/hosts.equiv: 서버 설정 파일 ※ \$HOME/.rhosts: 개별 사용자의 설정 파일 ※ + +: 모든 호스트의 계정 신뢰 ※ + <사용자 이름>: 모든 호스트의 해당 사용자 계정 신뢰 ※ <호스트 이름> +: 해당 호스트의 모든 계정 신뢰
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : rlogin, rsh, rexec 서비스를 사용하지 않거나, 사용 시 아래와 같은 설정이 적용된 경우 1. /etc/hosts.equiv 및 \$HOME/.rhosts 파일 소유자가 root 또는 해당 계정인 경우 2. /etc/hosts.equiv 및 \$HOME/.rhosts 파일 권한이 600 이하인 경우 3. /etc/hosts.equiv 및 \$HOME/.rhosts 파일 설정에 "+" 설정이 없는 경우
	취약 : rlogin, rsh, rexec 서비스를 사용하며 아래와 같은 설정이 적용되지 않은 경우 1. /etc/hosts.equiv 및 \$HOME/.rhosts 파일 소유자가 root 또는 해당 계정이 아닌 경우 2. /etc/hosts.equiv 및 \$HOME/.rhosts 파일 권한이 600을 초과한 경우 3. /etc/hosts.equiv 및 \$HOME/.rhosts 파일 설정에 "+" 설정이 존재하는 경우
조치 방법	/etc/hosts.equiv, \$HOME/.rhosts 파일 소유자 및 권한 변경, 허용 호스트 및 계정 등록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/hosts.equiv, \$HOME/.rhosts 파일 소유자 및 권한 변경

```
# chown <root 또는 해당 계정> /etc/hosts.equiv
```

```
# chmod 600 /etc/hosts.equiv
```

01. Unix 서버

```
# chown <root 또는 해당 계정> $HOME/.rhosts
```

```
# chmod 600 $HOME/.rhosts
```

Step 2) /etc/hosts.equiv, \$HOME/.rhosts 파일 내 “+” 옵션이 부여된 계정 확인

Step 3) /etc/hosts.equiv, vi \$HOME/.rhosts 파일 내 “+” 옵션 제거 후 허용 호스트 및 계정 등록

U-28 (상)	UNIX > 2. 파일 및 디렉토리 관리
	접속 IP 및 포트 제한
개요	
점검 내용	허용할 호스트에 대한 접속 IP주소 제한 및 포트 제한 설정 여부 점검
점검 목적	허용한 호스트만 서비스를 사용하게 하여 서비스 취약점을 이용한 외부자 공격을 방지하기 위함
보안 위협	허용할 호스트에 대한 IP 및 포트 제한이 적용되지 않을 경우, Telnet, FTP 같은 보안에 취약한 네트워크 서비스를 통하여 불법적인 접근 및 시스템 침해사고가 발생할 수 있는 위험이 존재함
참고	※ TCP Wrapper : 네트워크 서비스에 관련한 트래픽을 제어하고 모니터링할 수 있는 UNIX 기반의 방화벽 툴 ※ IPFilter : 유닉스 계열에서 사용하는 공개형 방화벽 프로그램으로써 Packet Filter로 시스템 및 네트워크 보안에 아주 강력한 기능을 보유한 프로그램 ※ IPtables : 리눅스 커널 방화벽이 제공하는 테이블들과 그것을 저장하는 체인, 규칙들을 구성할 수 있게 해주는 응용프로그램
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 접속을 허용할 특정 호스트에 대한 IP주소 및 포트 제한을 설정한 경우
	취약 : 접속을 허용할 특정 호스트에 대한 IP주소 및 포트 제한을 설정하지 않은 경우
조치 방법	OS에 기본으로 제공하는 방화벽 애플리케이션이나 TCP Wrapper와 같은 호스트별 서비스 제한 애플리케이션을 사용하여 접근 허용 IP 등록 설정
조치 시 영향	허용되지 않은 IP는 서비스 사용이 불가함

점검 및 조치 사례

● SOLARIS

[TCP Wrapper]

Step 1) TCP Wrapper에 설정된 접근제한 확인

Step 2) 서비스 차단 및 허용 설정값 수정

```
# vi /etc/hosts.deny
```

```
ALL:ALL
```

```
# vi /etc/hosts.allow
```

```
<허용할 서비스> : <허용할 IP주소>
```

```
예시) sshd : 192.168.18.129, 192.168.18.180
```

※ TCP Wrapper 접근제어 가능 서비스 : SYSTAT, FINGER, FTP, TELNET, RLOGIN, RSH, TALK, EXEC, TFTP, SSH

※ hosts.allow, hosts.deny 두 파일이 존재하지 않는 경우 모든 접근을 허용함

[Packet Filter]

Step 1) Packet Filter에 설정된 접근제한 확인 및 수정

Step 2) /etc/firewall/pf.conf 파일에 허용할 IP 및 포트 정책 추가

예시) SSH 서비스 제한

```
# pass in quick proto tcp from 192.168.1.0/24 to any port = 22 keep state
```

```
# block in quick proto tcp from any to any port = 22 keep state
```

Step 3) 설정한 접근제한 정책 적용

```
# svcadm refresh svc:/network/firewall:default
```

● LINUX

[TCP Wrapper]

Step 1) TCP Wrapper에 설정된 접근제한 확인

Step 2) 서비스 차단 및 허용 설정값 수정

```
# vi /etc/hosts.deny
```

```
ALL:ALL
```

```
# vi /etc/hosts.allow
```

```
<허용할 서비스> : <허용할 IP주소>
```

예시) sshd : 192.168.18.129, 192.168.18.180

※ TCP Wrapper 접근제어 가능 서비스 : SYSTAT, FINGER, FTP, TELNET, RLOGIN, RSH, TALK, EXEC, TFTP, SSH

※ hosts.allow, hosts.deny 두 파일이 존재하지 않는 경우 모든 접근을 허용함

[Iptables]

Step 1) Iptables에 설정된 접근제한 확인

```
# iptables -L
```

Step 2) Iptables에 허용할 IP 및 포트 정책 추가

```
# iptables -A INPUT -p <프로토콜> -s <IP주소> --dport <목적지 포트> -j ACCEPT
```

Step 3) 설정한 접근제한 정책 적용

```
# iptables-save
```

[Firewalld]

Step 1) Firewalld에 설정된 접근제한 확인

```
# firewall-cmd --list-all
```

Step 2) 허용할 IP 및 포트 정책 추가

```
# firewall-cmd --permanent --add-rich-rule="rule family="ipv4" source address="<IP주소>" port protocol  
="<프로토콜>" port="<포트 번호>" accept"
```

Step 3) 설정한 접근제한 정책 적용

```
# firewall-cmd --reload
```

[UFW]

Step 1) UFW에 설정된 접근제한 확인

```
# ufw status numbered
```

Step 2) 허용할 IP 및 포트 정책 추가

```
# ufw allow from <IP주소> to any <포트 번호>
```

Step 3) 설정한 접근제한 정책 적용

```
# ufw reload
```

● AIX

[TCP Wrapper]

Step 1) TCP Wrapper에 설정된 접근제한 확인

Step 2) 서비스 차단 및 허용 설정값 수정

```
# vi /etc/hosts.deny
```

```
ALL:ALL
```

```
# vi /etc/hosts.allow
```

```
<허용할 서비스> : <허용할 IP주소>
```

```
예시) sshd : 192.168.18.129, 192.168.18.180
```

※ TCP Wrapper 접근제어 가능 서비스 : SYSTAT, FINGER, FTP, TELNET, RLOGIN, RSH, TALK, EXEC, TFTP, SSH

※ hosts.allow, hosts.deny 두 파일이 존재하지 않는 경우 모든 접근을 허용함

[IPfilter]

Step 1) IPfilter에 설정된 접근제한 확인 및 수정

```
# vi /etc/ipf/ipf.conf
```

Step 2) /etc/ipf/ipf.conf 파일에 허용할 IP 및 포트 정책 추가

예시) SSH 서비스 제한

```
# pass in quick proto tcp from 192.168.1.0/24 to any port = 22 keep state
```

```
# block in quick proto tcp from any to any port = 22 keep state
```

Step 3) IPfilter 서비스 재시작

● HP-UX

[/var/adm/inetd.sec]

Step 1) inetd.sec에 설정된 접근제한 확인 및 수정

```
# vi /var/adm/inetd.sec
```

Step 2) 아래와 같이 수정 또는 삽입

특정 서비스로의 모든 IP 접근 차단 시 : <서비스> deny *.*.*

특정 서비스로의 일부 IP 접근 허용 시 : <서비스> allow <접속을 허용할 IP주소>

[TCP Wrapper]

Step 1) TCP Wrapper에 설정된 접근제한 확인

Step 2) 서비스 차단 및 허용 설정값 수정

```
# vi /etc/hosts.deny
```

```
ALL:ALL
```

```
# vi /etc/hosts.allow
```

<허용할 서비스> : <허용할 IP주소>

예시) sshd : 192.168.18.129, 192.168.18.180

※ TCP Wrapper 접근제어 가능 서비스 : SYSTAT, FINGER, FTP, TELNET, RLOGIN, RSH, TALK, EXEC, TFTP, SSH

※ hosts.allow, hosts.deny 두 파일이 존재하지 않는 경우 모든 접근을 허용함

[IPfilter]

Step 1) IPfilter에 설정된 접근제한 확인

Step 2) /etc/ipf/ipf.conf 파일에 허용할 IP 및 포트 정책 추가

예시) SSH 서비스 제한

pass in quick proto tcp from 192.168.1.0/24 to any port = 22 keep state

block in quick proto tcp from any to any port = 22 keep state

Step 3) IPfilter 서비스 재시작

01. Unix 서버

U-29 (하)	UNIX > 2. 파일 및 디렉토리 관리
	hosts.lpd 파일 소유자 및 권한 설정
개요	
점검 내용	/etc/hosts.lpd 파일의 제거 및 권한 적절성 여부 점검
점검 목적	비인가자의 임의적인 /etc/hosts.lpd 변조를 막기 위해 /etc/hosts.lpd 파일 제거 또는 소유자 및 권한 관리하기 위함
보안 위협	/etc/hosts.lpd 파일의 접근 권한이 적절하지 않을 경우, 비인가자가 /etc/hosts.lpd 파일을 수정하여 허용된 사용자의 서비스를 방해할 수 있으며, 호스트 정보를 획득할 수 있는 위험이 존재함
참고	※ /etc/hosts.lpd 파일 : 로컬 프린트 서비스를 사용할 수 있는 허가된 호스트(사용자) 정보를 담고 있는 파일 (hostname 또는 IP주소를 포함하고 있음)
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : /etc/hosts.lpd 파일이 존재하지 않거나, 불가피하게 사용 시 /etc/hosts.lpd 파일의 소유자가 root이고, 권한이 600 이하인 경우
	취약 : /etc/hosts.lpd 파일이 존재하며, 파일의 소유자가 root가 아니거나, 권한이 600 이하가 아닌 경우
조치 방법	/etc/hosts.lpd 파일 제거 또는 /etc/hosts.lpd 파일 소유자 및 권한 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/hosts.lpd 파일 소유자 및 권한 확인 및 수정

```
# ls -l /etc/hosts.lpd
# chown root /etc/hosts.lpd
# chmod 600 /etc/hosts.lpd
```

U-30 (중)	UNIX > 2. 파일 및 디렉토리 관리
	UMASK 설정 관리
개요	
점검 내용	시스템 UMASK 값이 022 이상 설정 여부 점검
점검 목적	잘못 설정된 UMASK 값으로 인해 신규 파일에 대한 권한이 과도하게 부여되는 것을 방지하기 위함
보안 위협	잘못 설정된 UMASK로 인해 파일 및 디렉터리 생성 시 과도한 권한이 부여되어 무단 액세스 및 데이터 유출의 위험이 존재함
참고	※ UMASK : 파일 및 디렉터리 생성 시 기본 권한을 지정해 주는 명령어 ※ 시스템 내에서 사용자가 새로 생성하는 파일의 접근 권한은 UMASK 값에 따라 정해지며, 계정의 환경설정 파일에 설정을 변경하면 사용자가 로그인한 후에도 변경된 UMASK 값을 적용받게 됨 ※ Start Profile : /etc/profile, /etc/default/login, .cshrc, .kshrc, .bashrc, .login, .profile 등
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : UMASK 값이 022 이상으로 설정된 경우
	취약 : UMASK 값이 022 미만으로 설정된 경우
조치 방법	설정 파일에 UMASK 값을 022로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

[/etc/profile]

Step 1) /etc/profile 파일 내 UMASK 설정 확인 및 수정

```
# vi /etc/profile
umask 022
export umask
```

[/etc/default/login]

Step 1) /etc/default/login 파일 내 UMASK 설정 확인 및 수정

```
# vi /etc/default/login
UMASK=022
```

● LINUX

[/etc/profile]

Step 1) /etc/profile 파일 내 UMASK 설정 확인 및 수정

```
# vi /etc/profile
umask 022
export umask
```

[/etc/login.defs]

Step 1) /etc/login.defs 파일 내 UMASK 설정 확인 및 수정

```
# vi /etc/login.defs
UMASK 022
```

● AIX

[/etc/profile]

Step 1) /etc/profile 파일 내 UMASK 설정 확인 및 수정

```
# vi /etc/profile
umask 022
export umask
```

[/etc/security/user]

Step 1) /etc/security/user 파일 내 UMASK 설정 확인 및 수정

```
# vi /etc/security/user
default : umask = 022 또는 <사용자 이름> : umask = 022
```

● HP-UX

[/etc/profile]

Step 1) /etc/profile 파일 내 UMASK 설정 확인 및 수정

```
# vi /etc/profile
umask 022
export umask
```

[/etc/default/securitiz]

Step 1) /etc/default/securitiz 파일 내 UMASK 설정 수정

```
UMASK = 022
```

● FTP UMASK 설정

[vsFTP]

Step 1) {설치경로}/vsftpd.conf 파일 내 UMASK 설정 확인 및 수정

```
# cat vsftpd.conf | grep local_umask
```

```
local_umask=022
```

[ProFTP]

Step 2) {설치경로}/proftpd.conf 파일 내 UMASK 설정 확인 및 수정

```
# cat proftpd.conf | grep umask
```

```
Umask    022
```

U-31 (중)	UNIX > 2. 파일 및 디렉토리 관리
	홈디렉토리 소유자 및 권한 설정
개요	
점검 내용	홈 디렉토리의 소유자 외 타 사용자가 해당 홈 디렉토리를 수정할 수 없도록 제한 설정 여부 점검
점검 목적	사용자 홈 디렉토리 내 설정 파일이 비인가자에 의한 변조를 방지하기 위함
보안 위협	홈 디렉토리 내 설정 파일 변조 시 정상적인 서비스 이용이 제한될 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 홈 디렉토리 소유자가 해당 계정이고, 타 사용자 쓰기 권한이 제거된 경우
	취약 : 홈 디렉토리 소유자가 해당 계정이 아니거나, 타 사용자 쓰기 권한이 부여된 경우
조치 방법	사용자별 홈 디렉토리 소유주를 해당 계정으로 변경하고, 타 사용자의 쓰기 권한 제거하도록 설정 (/etc/passwd 파일에서 홈 디렉토리 확인, 사용자 홈 디렉토리 외 개별적으로 만들어 사용하는 사용자 디렉토리 존재 여부 확인하여 점검)
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) 사용자별 홈 디렉토리 확인

```
# cat /etc/passwd
```

Step 2) 사용자별 홈 디렉토리 소유자 및 권한 확인

```
# ls -ald <사용자 홈 디렉토리>
```

Step 3) 사용자별 홈 디렉토리 소유자를 해당 사용자로 변경 및 일반 사용자 권한 제거

```
# chown <사용자 이름> <사용자 홈 디렉토리>
```

```
# chmod o-w <사용자 홈 디렉토리>
```

U-32 (중)	UNIX > 2. 파일 및 디렉토리 관리
	홈 디렉토리로 지정한 디렉토리의 존재 관리
개요	
점검 내용	사용자 계정과 홈 디렉토리의 일치 여부 점검
점검 목적	/home 디렉토리 이외의 사용자의 홈 디렉토리 존재 여부를 점검하여 비인가자가 시스템 명령어의 무단 사용을 방지하기 위함
보안 위협	/etc/passwd 파일에 설정된 홈 디렉토리가 존재하지 않는 경우, 해당 계정으로 로그인 시 홈 디렉토리가 루트 디렉토리(/)로 할당되어 접근이 가능한 위험이 존재함
참고	※ 홈 디렉토리 : 사용자가 로그인한 후 작업을 수행하는 디렉토리 ※ 일반 사용자의 홈 디렉토리 위치 : /home/<user 명>
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 홈 디렉토리가 존재하지 않는 계정이 발견되지 않는 경우
	취약 : 홈 디렉토리가 존재하지 않는 계정이 발견된 경우
조치 방법	홈 디렉토리가 존재하지 않는 계정에 홈 디렉토리 설정 또는 계정 제거하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) 사용자별 홈 디렉토리 확인

```
# cat /etc/passwd
```

Step 2) 홈 디렉토리가 존재하지 않는 사용자 계정이 불필요한 계정일 경우, 해당 계정 삭제

```
# userdel <사용자 이름>
```

Step 3) 사용중인 계정일 시, 해당 계정의 홈 디렉토리 설정

```
# vi /etc/passwd
```

예시) example:x:1000:1000::/home/example:/bin/bash

U-33 (하)	UNIX > 2. 파일 및 디렉토리 관리
	숨겨진 파일 및 디렉토리 검색 및 제거
개요	
점검 내용	숨겨진 파일 및 디렉토리 내 의심스러운 파일 존재 여부 점검
점검 목적	숨겨진 파일 및 디렉토리 중 의심스러운 내용은 정상 사용자가 아닌 공격자에 의해 생성되었을 가능성이 높으므로 이를 제거하여 보안 위협을 방지하기 위함
보안 위협	숨겨진 파일 및 디렉토리를 방지할 경우, 비인가자가 생성한 악성 파일 또는 백도어 등을 탐지하지 못할 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 불필요하거나 의심스러운 숨겨진 파일 및 디렉토리를 제거한 경우
	취약 : 불필요하거나 의심스러운 숨겨진 파일 및 디렉토리를 제거하지 않은 경우
조치 방법	ls -al 명령어로 숨겨진 파일 존재 파악 후 불법적이거나 의심스러운 파일을 제거하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) 특정 디렉토리 내 불필요한 파일 확인

```
# ls -al <디렉토리 이름>
```

Step 2) 숨겨진 파일 및 디렉토리 확인

```
# find / -type f -name ".*"
```

```
# find / -type d -name ".*"
```

Step 3) 불필요하거나 의심스러운 숨겨진 파일 및 디렉토리 제거

```
# rm <파일 이름>
```

```
# rm -r <디렉토리 이름>
```

U-34 (상)	UNIX > 3. 서비스 관리
	Finger 서비스 비활성화
개요	
점검 내용	Finger 서비스 비활성화 여부 점검
점검 목적	Finger 서비스를 통해 네트워크 외부에서 해당 시스템에 등록된 사용자 정보를 확인할 수 있어 비인가자에게 사용자 정보가 조회되는 것을 방지하기 위함
보안 위협	Finger 서비스가 활성화되어 있을 경우, 비인가자가 Finger 서비스를 사용하여 사용자 정보를 조회한 후 비밀번호 공격을 통해 계정을 탈취할 위험이 존재함
참고	※ Finger(사용자 정보 확인 서비스) : who 명령어가 현재 사용 중인 사용자들에 대한 간단한 정보만을 보여주는 데 반해 Finger 명령은 옵션에 따른 시스템에 등록된 사용자뿐만 아니라 네트워크를 통하여 연결되어 있는 다른 시스템에 등록된 사용자들에 대한 자세한 정보를 보여줌
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : Finger 서비스가 비활성화된 경우
	취약 : Finger 서비스가 활성화된 경우
조치 방법	Finger 서비스 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS(5.9 이하 버전)

Step 1) /etc/inetd.conf 파일 내 Finger 서비스 활성화 여부 확인 및 비활성화

Finger 서비스 항목 주석 처리

예시) #finger stream tcp nowait bin /usr/sbin/fingerd fingerd

Step 2) inetd 서비스 재시작

● SOLARIS(5.10 이상 버전)

Step 1) Finger 서비스 활성화 여부 확인

inetadm | grep finger

Step 2) Finger 서비스 데몬 중지

#inetadm -d svc:/network/finger:default

● LINUX

[inetd]

Step 1) /etc/inetd.conf 파일 내 Finger 서비스 활성화 여부 확인 및 비활성화

Finger 서비스 항목 주석 처리

예시) #finger stream tcp nowait bin /usr/sbin/fingerd fingerd

Step 2) inetd 서비스 재시작

[xinetd]

Step 1) /etc/xinetd.d/finger 파일 내 Finger 서비스 활성화 여부 확인 및 비활성화

finger의 disable 옵션을 yes로 수정

Step 2) 설정 적용 및 xinetd 서비스 재시작

systemctl restart xinetd

● AIX, HP-UX

Step 1) /etc/inetd.conf 파일 내 Finger 서비스 활성화 여부 확인 및 비활성화

Finger 서비스 항목 주석 처리

예시) #finger stream tcp nowait bin /usr/sbin/fingerd fingerd

Step 2) inetd 서비스 재시작

U-35 (상)	UNIX > 3. 서비스 관리
	공유 서비스에 대한 익명 접근 제한 설정
개요	
점검 내용	공유 서비스의 익명 접근 제한 설정 여부 점검
점검 목적	공유 서비스의 익명 접근을 제한하여 중요 정보의 노출을 방지하기 위함
보안 위협	공유 서비스의 익명 접근을 허용할 경우, 비인가자의 무단 접근으로 인한 중요 정보 탈취 또는 변조, 악성 코드 유포 등의 위험이 존재함
참고	※ 익명 접속이 허용된 서버에 익명 사용자에게 쓰기 권한이 부여되어 있는 경우, 정상 파일에 대해 변조가 가능하므로 공개된 디렉터리 내 중요 데이터 여부를 주기적으로 확인해야 함 ※ 공유 서비스를 사용하지 않는 경우 양호 또는 N/A
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 공유 서비스에 대해 익명 접근을 제한한 경우
	취약 : 공유 서비스에 대해 익명 접근을 허용한 경우
조치 방법	공유 서비스의 익명 접근 제한 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

[기본 FTP]

Step 1) FTP 계정 확인

```
# cat /etc/passwd | grep ftp
# cat /etc/passwd | grep anonymous
```

Step 2) FTP 계정 제거

```
# userdel ftp
# userdel anonymous
```

[vsFTP]

Step 1) Anonymous FTP 활성화 여부 확인

```
# cat /etc/vsftpd/vsftpd.conf | grep anonymous_enable
```

Step 2) Anonymous FTP 비활성화

```
# vi /etc/vsftpd/vsftpd.conf
anonymous_enable 옵션을 NO로 수정
```

[ProFTP]

Step 1) Anonymous FTP 활성화 여부 확인

```
# sed -n '/<Anonymous ~ftp>/,/<\Anonymous>/p' /etc/proftpd/proftpd.conf
```

Step 2) Anonymous FTP 비활성화

```
# vi /etc/proftpd/proftpd.conf
Anonymous 필드 주석 처리
```

※ User, UserAlias 옵션이 설정된 경우 익명 접근이 활성화되어 있는 상태

[NFS]

Step 1) 익명 접근 활성화 여부 확인

```
# cat /etc/dfs/dfstab | grep anon
```

Step 2) 익명 접근 비활성화

```
# vi /etc/dfs/dfstab
anon 옵션을 -1로 수정
예시) share -F nfs -o rw, anon=-1 /home/example
```

Step 3) NFS 서비스 재시작

```
# exportfs -u
# exportfs -a
```

[Samba]

Step 1) 익명 접근 허용 여부 확인

```
# cat /etc/samba/smb.conf | grep "guest ok"
```

Step 2) 익명 사용자 접근 비활성화

```
# vi /etc/samba/smb.conf
guest ok 옵션을 no로 수정
```

Step 3) 변경된 설정 적용 및 재시작

```
# svcadm refresh samba
```

● LINUX

[기본 FTP]

Step 1) FTP 계정 확인

```
# cat /etc/passwd | grep ftp
```

```
# cat /etc/passwd | grep anonymous
```

Step 2) FTP 계정 제거

```
# userdel ftp
```

```
# userdel anonymous
```

[vsFTP]

Step 1) Anonymous FTP 활성화 여부 확인

```
# cat /etc/vsftpd.conf | grep anonymous_enable
```

```
# cat /etc/vsftpd/vsftpd.conf | grep anonymous_enable
```

Step 2) Anonymous FTP 비활성화

```
# vi /etc/vsftpd/vsftpd.conf
```

anonymous_enable 옵션을 NO로 수정

Step 3) 변경된 설정 적용 및 재시작

```
# systemctl restart vsftpd
```

[ProFTP]

Step 1) Anonymous FTP 활성화 여부 확인

```
# sed -n '/<Anonymous ~ftp>/,/<\VAnonymous>/p' /etc/proftpd.conf
```

```
# sed -n '/<Anonymous ~ftp>/,/<\VAnonymous>/p' /etc/proftpd/proftpd.conf
```

Step 2) Anonymous FTP 비활성화

```
# vi /etc/proftpd/proftpd.conf
```

Anonymous 필드 주석 처리

Step 3) 변경된 설정 적용 및 재시작

```
# systemctl restart proftpd
```

※ User, UserAlias 옵션이 설정된 경우 익명 접근이 활성화되어 있는 상태

[NFS]

Step 1) 익명 접근 활성화 여부 확인

```
# cat /etc/exports | grep -E "anonuid|anongid"
```

Step 2) 익명 접근 비활성화

```
# vi /etc/exports
```

anon 옵션값 삭제

예시) /home/nfs-server *(rw,sync,no_subtree_check)

Step 3) NFS 서비스 재시작

```
# exportfs -ra
```

※ anon 옵션이 설정된 경우 익명 접근이 활성화되어 있는 상태

[Samba]

Step 1) 익명 접근 허용 여부 확인

```
# cat /etc/samba/smb.conf | grep "guset ok"
```

Step 2) 익명 사용자 접근 비활성화

```
# vi /etc/samba/smb.conf
```

guest ok 옵션을 no로 수정

Step 3) 변경된 설정 적용 및 재시작

```
# smbcontrol all reload-config
```

● **AIX****[기본 FTP]**

Step 1) FTP 계정 확인

```
# cat /etc/passwd | grep ftp
```

```
# cat /etc/passwd | grep anonymous
```

Step 2) FTP 계정 제거

```
# rmuser ftp
```

```
# rmuser anonymous
```

[vsFTP]

Step 1) Anonymous FTP 활성화 여부 확인

```
# cat /etc/vsftpd.conf | grep anonymous_enable
```

Step 2) Anonymous FTP 비활성화

```
# vi /etc/vsftpd.conf
```

anonymous_enable 옵션을 NO로 수정

Step 3) 서비스 재시작

```
# kill -1 <PID>
```

[ProFTP]

Step 1) Anonymous FTP 활성화 여부 확인

```
# sed -n '/<Anonymous ~ftp>/,/<\Anonymous>/p' /etc/proftpd.conf
```

Step 2) Anonymous FTP 비활성화

```
# vi /etc/proftpd.conf
```

Anonymous 필드 주석 처리

Step 3) 서비스 재시작

```
# kill -1 <PID>
```

※ User, UserAlias 옵션이 설정된 경우 익명 접근이 활성화되어 있는 상태

[NFS]

Step 1) 익명 접근 활성화 여부 확인

```
# cat /etc/exports | grep anon
```

Step 2) 익명 접근 비활성화

```
# vi /etc/exports
```

anon 옵션을 -1로 수정

예시) /home/example -sec=sys:krb5p:krb5i:krb5:dh,ro=host1, access=host1, anon=-1

Step 3) NFS 서비스 재시작

```
# exportfs -u
```

```
# exportfs -a
```

※ anon 옵션이 -1이 아닌 경우 익명 접근이 활성화되어 있는 상태

[Samba]

Step 1) 익명 접근 허용 여부 확인

```
# cat /usr/lib/smb.conf | grep "guest ok"
```

Step 2) 익명 사용자 접근 비활성화

```
# vi /usr/lib/smb.conf
```

guest ok 옵션을 no로 수정

Step 3) Samba 서비스 중지 및 재실행

```
# stopsrc -s smbd
```

```
# startsrc -s smbd
```

● HP-UX

[기본 FTP]

Step 1) FTP 계정 확인

```
# cat /etc/passwd | grep ftp
```

```
# cat /etc/passwd | grep anonymous
```

Step 2) FTP 계정 제거

```
# userdel ftp
```

```
# userdel anonymous
```

[vsFTP]

Step 1) Anonymous FTP 활성화 여부 확인

```
# cat /etc/vsftpd.conf | grep anonymous_enable
```

Step 2) Anonymous FTP 비활성화

```
# vi /etc/vsftpd.conf
```

anonymous_enable 옵션을 NO로 수정

Step 3) 서비스 재시작

```
# kill -1 <PID>
```

[ProFTP]

Step 1) Anonymous FTP 활성화 여부 확인

```
# sed -n '/<Anonymous ~ftp>/,/<\/Anonymous>/p' /etc/proftpd.conf
```

Step 2) Anonymous FTP 비활성화

```
# vi /etc/proftpd.conf
```

Anonymous 필드 주석 처리

Step 3) 서비스 재시작

```
# kill -1 <PID>
```

[NFS]

Step 1) 익명 접근 활성화 여부 확인

```
# cat /etc/exports | grep anon
```

```
# cat /etc/dfs/dfstab | grep anon
```

Step 2) 익명 접근 비활성화

```
# vi /etc/exports
```

```
# vi /etc/dfs/dfstab
```

anon 옵션을 -1로 수정

예시) /home/example -access=bear,anon=-1,ro

예시) share -F nfs -o rw, anon=-1 /home/example

Step 3) NFS 서비스 재시작

```
# exportfs -u
```

```
# exportfs -a
```

※ HP-UX 11i v3에서는 /etc/dfs/dfstab 파일을 사용함

※ anon 옵션이 -1이 아닌 경우 익명 접근이 활성화되어 있는 상태

[Samba]

Step 1) 익명 접근 허용 여부 확인

```
# cat /usr/lib/smb.conf | grep "guset ok"
```

Step 2) 익명 사용자 접근 비활성화

```
# vi /usr/lib/smb.conf
```

guest ok 옵션을 no로 수정

Step 3) 서비스 재시작

```
# kill -1 <PID>
```

01. Unix 서버

U-36 (상)	UNIX > 3. 서비스 관리
	r 계열 서비스 비활성화
개요	
점검 내용	r-command 서비스 비활성화 여부 점검
점검 목적	r-command 사용을 통한 원격 접속은 NET Backup 또는 클러스터링 등 용도로 사용되기도 하나, 인증 없이 관리자 원격 접속이 가능하여 이에 대한 보안 위협을 방지하기 위함
보안 위협	rlogin, rsh, rexec 등의 r-command를 이용하여 원격에서 인증 절차 없이 터미널 접속, 셸 명령어를 실행이 가능한 위험이 존재함
참고	※ r-command : 인증 없이 관리자의 원격 접속을 가능하게 하는 명령어들로 rsh(remsh), rlogin, rexec, rsync 등이 있음
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 불필요한 r 계열 서비스가 비활성화된 경우
	취약 : 불필요한 r 계열 서비스가 활성화된 경우
조치 방법	불필요한 r 계열 서비스 중지 및 비활성화 설정 ※ NET Backup 등 특별한 용도로 사용하지 않는다면 shell(514), login(513), exec(512) 서비스 중지 ※ rlogin, rsh, rexec 서비스는 backup, 클러스터링 등의 용도로 종종 사용되고 있으므로 해당 서비스 사용 유무를 확인하여 미사용시 서비스 중지 ※ /etc/hosts.equiv 또는 \$HOME/.rhosts 파일을 통해 해당 서비스 사용 여부 확인 (파일이 존재하지 않거나 해당 파일 내에 설정이 없다면 사용하지 않는 것으로 간주)
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS(5.9 이하 버전)

Step 1) /etc/inetd.conf 파일 내 불필요한 r 계열 서비스 활성화 여부 확인

```
# vi /etc/inetd.conf
```

Step 2) 불필요한 r 계열 서비스 관련 필드 주석처리

```
예시) #shell stream tcp nowait root /usr/sbin/in.rshd in.rshd
```

Step 3) 서비스 재시작

```
# kill -HUP [inetd PID]
```

● SOLARIS(5.10 이상 버전)

Step 1) 불필요한 r 계열 서비스 활성화 여부 확인

```
# inetadm | egrep "shell|rlogin|rexec"
```

Step 2) 불필요한 r 계열 서비스 데몬 중지

```
# inetadm -d <rcommand 데몬>
```

● LINUX

[inetd]

Step 1) /etc/inetd.conf 파일 내 불필요한 r 계열 서비스 활성화 여부 확인

Step 2) 불필요한 r 계열 서비스 관련 필드 주석 처리

```
# vi /etc/inetd.conf
```

```
예시) # rlogin stream tcp nowait root /usr/sbin/in.rlogind in.rlogind
```

Step 3) inetd 서비스 재시작

[xinetd]

Step 1) /etc/xinetd.d/<파일 이름> 파일 내 불필요한 r 계열 서비스 활성화 여부 확인

Step 2) 불필요한 r 계열 서비스 비활성화

```
disable 값을 yes로 수정
```

Step 3) 설정 적용 및 서비스 재시작

```
# systemctl restart xinetd
```

[systemd]

Step 1) 불필요한 r 계열 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep -E "rlogin|rsh|rexec"
```

Step 2) 현재 가동되고 있는 r 계열 서비스 중지

```
# systemctl stop <서비스 이름>
```

Step 3) 불필요한 r 계열 서비스 비활성화

```
# systemctl disable <서비스 이름>
```

- AIX, HP-UX

[inetd]

Step 1) /etc/inetd.conf 파일 내 불필요한 r 계열 서비스 활성화 여부 확인

Step 2) 불필요한 r 계열 서비스 관련 필드 주석 처리

```
# vi /etc/inetd.conf
```

```
예시) #login stream tcp6 nowait root /usr/sbin/rlogind rlogind
```

Step 3) 변경된 설정 적용

```
- AIX : # refresh -s inetd
```

```
-HP-UX : # inetd -c
```

[r-command]

Step 1) /etc/inetd.conf 파일 내 불필요한 r 계열 서비스 활성화 여부 확인

Step 2) /etc/hosts.equiv, \$HOME/.rhosts 파일에 접근을 허용할 사용자 이름 또는 IP주소 설정

Step 3) /etc/hosts.equiv, \$HOME/.rhosts 파일 권한을 600 이하로 설정

U-37 (상)	UNIX > 3. 서비스 관리
	crontab 설정파일 권한 설정 미흡
개요	
점검 내용	crontab 및 at 서비스 관련 파일의 권한 적절성 여부 점검
점검 목적	관리자 외에는 서비스를 사용할 수 없도록 설정하고 있는지 점검하기 위함
보안 위협	일반 사용자가 crontab 및 at 서비스를 사용할 수 있을 경우, 고의 또는 실수로 불법적인 예약 파일 실행으로 시스템 피해를 일으킬 수 있는 위험이 존재함
참고	※ cron 시스템 : 특정 작업을 정해진 시간에 주기적이고 반복적으로 실행하기 위한 데몬 및 설정 ※ cron.allow : 사용자 ID를 등록하면 등록된 사용자는 crontab 명령어 사용이 가능함 ※ cron.deny : 사용자 ID를 등록하면 등록된 사용자는 crontab 명령어 사용이 불가능함 ※ at 서비스(일회성 작업 예약) : 지정한 시간에 어떠한 작업이 실행될 수 있도록 작업 스케줄을 예약 처리해 주는 기능을 제공함. /etc/at.allow 파일에 등록된 사용자만이 at 명령을 사용할 수 있음 ※ 기반시설 시스템에서 at 서비스의 이용은 원칙적으로 금지하나, 불가피하게 사용 시 소유자 및 권한 설정 등의 보안 조치를 반드시 적용해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : crontab 및 at 명령어에 일반 사용자 실행 권한이 제거되어 있으며, cron 및 at 관련 파일 권한이 640 이하인 경우
	취약 : crontab 및 at 명령어에 일반 사용자 실행 권한이 부여되어 있으며, cron 및 at 관련 파일 권한이 640 이상인 경우
조치 방법	crontab 및 at 명령어 파일 권한 750 이하, cron 및 at 관련 파일 소유자 및 파일 권한 640 이하 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) crontab, cron 작업 목록 파일, cron 관련 파일 소유자 및 권한 확인

```
# ls -l /usr/bin/crontab
# ls -l /var/spool/cron/crontabs/<cron 작업 목록 파일>
# ls -l /etc/cron.d/<cron 관련 파일>
```

Step 2) at, at 작업 목록 파일 소유자 및 권한 확인

```
# ls -l /usr/bin/at
# ls -l /var/spool/cron/atjobs/<at 작업 목록 파일>
```

Step 3) crontab 파일 및 at 파일 소유자를 root로, 파일 권한을 750으로 변경

Step 4) cron 작업 목록 파일, cron 관련 파일 및 at 작업 목록 파일 소유자를 root로, 파일 권한을 640으로 변경

※ crontab 및 at 명령어는 SUID가 설정되어 있으므로 SUID 설정 제거 필요

● LINUX

Step 1) crontab, cron 작업 목록 파일, cron 관련 파일 소유자 및 권한 확인

```
# ls -l /usr/bin/crontab
```

```
# ls -l /var/spool/cron/<cron 작업 목록 파일>, # ls -l /var/spool/cron/crontabs/<cron 작업 목록 파일>
```

```
# ls -l /etc/<cron 관련 파일>
```

Step 2) at, at 작업 목록 파일 소유자 및 권한 확인

```
# ls -l /usr/bin/at
```

```
# ls -l /var/spool/at/<at 작업 목록 파일>, # ls -l /var/spool/cron/atjobs/<at 작업 목록 파일>
```

Step 3) crontab 파일 및 at 파일 소유자를 root로, 파일 권한을 750으로 변경

Step 4) cron 작업 목록 파일, cron 관련 파일 및 at 작업 목록 파일 소유자를 root로, 파일 권한을 640으로 변경

※ crontab 및 at 명령어는 SUID가 설정되어 있으므로 SUID 설정 제거 필요

● AIX, HP-UX

Step 1) crontab, cron 작업 목록 파일, cron 관련 파일 소유자 및 권한 확인

```
# ls -l /usr/bin/crontab
```

```
# ls -l /var/spool/cron/crontabs/<cron 작업 목록 파일>
```

```
# ls -l /var/adm/cron/<cron 관련 파일>
```

Step 2) at, at 작업 목록 파일 소유자 및 권한 확인

```
# ls -l /usr/bin/at
```

```
# ls -l /var/spool/cron/atjobs/<at 작업 목록 파일>
```

Step 3) crontab 파일 및 at 파일 소유자를 root로, 파일 권한을 750으로 변경

Step 4) cron 작업 목록 파일, cron 관련 파일 및 at 작업 목록 파일 소유자를 root로, 파일 권한을 640으로 변경

※ crontab 및 at 명령어는 SUID가 설정되어 있으므로 SUID 설정 제거 필요

cron 관련 설정 파일	설명
crontab	예약 작업을 등록하는 파일
cron.hourly	시간 단위 예약 실행 스크립트 등록 파일
cron.daily	일 단위 예약 실행 스크립트 등록 파일
cron.weekly	주 단위 예약 실행 스크립트 등록 파일
cron.monthly	월 단위 예약 실행 스크립트 등록 파일
cron.allow	crontab 명령어 허용 사용자 등록 파일
cron.deny	crontab 명령어 차단 사용자 등록 파일
/var/spool/cron 또는 /var/spool/cron/crontab	사용자별 설정된 cron 작업 목록

※ cron.allow, cron.deny 두 파일 모두 존재하지 않을 시, root 계정만 cron 등록 가능

at 관련 설정 파일	설명
at	예약 작업을 등록하는 파일
at.allow	at 명령어 허용 사용자 등록 파일
at.deny	at 명령어 차단 사용자 등록 파일
/var/spool/at 또는 /var/spool/cron/atjobs	사용자별 설정된 at 작업 목록

※ at.allow, at.deny 두 파일 모두 존재하지 않을 시, root 계정만 at 등록 가능

01. Unix 서버

U-38 (상)	UNIX > 3. 서비스 관리
	DoS 공격에 취약한 서비스 비활성화
개요	
점검 내용	사용하지 않는 DoS 공격에 취약한 서비스의 실행 여부 점검
점검 목적	많은 취약점을 가진 echo, discard, daytime, chargen, ntp, snmp 등의 서비스를 중지하여 시스템의 보안성을 높이기 위함
보안 위험	해당 서비스가 활성화된 경우, 시스템 정보 유출 및 DoS 공격의 대상이 될 수 있는 위험이 존재함
참고	※ DoS(Denial of Service attack) : 시스템을 악의적으로 공격해 해당 시스템의 자원을 부족하게 하여 원래 의도된 용도로 사용하지 못하게 하는 공격. 특정 서버에게 수많은 접속 시도를 만들어 다른 이용자가 정상적으로 서비스 이용을 하지 못하게 하거나, 서버의 TCP 연결을 바닥내는 등의 공격이 이 범위에 포함됨
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : DoS 공격에 취약한 서비스가 비활성화된 경우
	취약 : DoS 공격에 취약한 서비스가 활성화된 경우
조치 방법	echo, discard, daytime, chargen, ntp, dns, snmp 등의 서비스 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) 서비스 데몬 활성화 여부 확인

inetadm | grep enable | egrep "echo|discard|daytime|chargen"

Step 2) 불필요한 서비스 데몬 중지

inetadm -d <중지하고자 하는 서비스 데몬>

● LINUX

[inetd]

Step 1) /etc/inetd.conf 파일 내 서비스 활성화 여부 확인

서비스 대상: echo, discard, daytime, chargen

Step 2) /etc/inetd.conf 파일 수정(주석 제거)

예시) echo stream tcp nowait root internal

Step 3) inetd 서비스 재시작

inetd

[xinetd]

Step 1) /etc/xinetd.d/<파일명> 파일 내 서비스 활성화 여부 확인

예시) service echo {
 disable = no
 ...
 }

Step 2) 서비스 비활성화

disable = yes

Step 3) 설정 적용 및 서비스 재시작

service xinetd restart

[systemd]

Step 1) 서비스 활성화 여부 확인

systemctl list-units --type=service | grep -E "echo|discard|daytime|chargen"

Step 2) 서비스 중지

systemctl stop <서비스명>

Step 3) 서비스 비활성화

systemctl disable <서비스명>

● AIX, HP-UX

Step 1) /etc/inetd.conf 파일 내 서비스 활성화 여부 확인

대상 서비스: echo, discard, daytime, chargen

Step 2) /etc/inetd.conf 파일 수정(주석 처리)

echo stream tcp nowait root internal
 # discard stream tcp nowait root internal
 # chargen stream tcp nowait root internal
 # daytime stream tcp nowait root internal

01. Unix 서버

```
# echo dgram udp wait root internal
# discard dgram udp wait root internal
# chargen dgram udp wait root internal
# daytime dgram udp wait root internal
```

Step 3) 설정 적용

[AIX]

```
refresh -s inetd
```

[HP-UX]

```
inetd -c
```

DoS 공격에 취약한 서비스 예시	
서비스 (포트)	설명
echo (7)	클라이언트에서 보내는 메시지를 단순히 재전송하는 서비스
discard (9)	수신되는 임의 사용자의 데이터를 폐기하는 서비스
daytime (13)	클라이언트의 질의에 응답하여 아스키 형태로 현재 시간과 날짜를 출력하는 서비스
chargen (19)	임의 길이의 문자열을 반환하는 서비스
NTP (123)	네트워크로 연결되어 있는 컴퓨터들끼리 시각을 동기화하는 서비스
DNS (53)	호스트의 도메인 이름을 호스트의 네트워크 주소로 바꾸거나 그 반대의 변환을 수행하는 서비스
SNMP (161/162)	네트워크 장비들로부터 필요한 정보를 가져와 장비 상태를 모니터링하거나, 설정값을 변경하는 등의 작업을 하여 네트워크 장비를 관리하는데 사용되는 서비스
SMTP (25)	인터넷에서 메일을 보내기 위해 사용되는 서비스

U-39 (상)	UNIX > 3. 서비스 관리
	불필요한 NFS 서비스 비활성화
개요	
점검 내용	불필요한 NFS 서비스 사용 여부 점검
점검 목적	NFS(Network File System) 서비스는 한 서버의 파일을 많은 서비스 서버들이 공유하여 사용할 때 이용하는 서비스지만 이를 이용한 침해사고 위험성이 높으므로 사용하지 않는 경우 중지하기 위함
보안 위협	NFS 서비스는 서버의 디스크를 클라이언트와 공유하는 서비스로 적절한 보안 설정이 적용되어 있지 않다면 불필요한 파일 공유로 인한 유출 위험이 존재함
참고	※ NFS(Network File System) : 원격 컴퓨터의 파일 시스템을 로컬 시스템에 마운트하여 로컬 파일 시스템처럼 사용할 수 있는 프로그램 ※ NFS 서비스 사용은 원칙적으로 금지되어 있지만 불가피하게 사용 시 필요한 경우 U-40 항목을 참조하여 통제해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 불필요한 NFS 서비스 관련 데몬이 비활성화된 경우
	취약 : 불필요한 NFS 서비스 관련 데몬이 활성화된 경우
조치 방법	NFS 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 ※ 로컬 서버에 마운트 되어 있는 디렉터리 제거 및 공유 디렉터리 제거 후 서비스 중지 가능
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) NFS 서비스 데몬 활성화 확인

```
# inetadm | egrep "nfs|statd|lockd"
```

Step 2) 불필요한 서비스 데몬 중지

```
# inetadm -d <중지하고자 하는 서비스 데몬>
```

● LINUX

Step 1) NFS 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep nfs
```

Step 2) 불필요한 NFS 서비스 중지

```
# systemctl stop <서비스명>
```

Step 3) NFS 서비스 비활성화

```
# systemctl disable <서비스명>
```

● AIX

[process 점검]

Step 1) NFS 프로세스 활성화 여부 확인

```
# ps -ef | grep nfsd
```

Step 2) NFS 서비스 관련 데몬 중지

```
# kill -9 <PID>
```

Step 3) NFS 시동 스크립트 위치 확인

```
# ls -al /etc/rc.d/rc*.d/* | grep nfs
```

Step 4) NFS 시동 스크립트 이름 변경

```
# mv /etc/rc.d/rc2.d/S60nfs /etc/rc.d/rc2.d/_S60nfs
```

[service 점검]

Step 1) NFS 서비스 활성화 여부 확인

```
# lssrc -a | grep nfs
```

Step 2) NFS 서비스 관련 데몬 중지

```
# stopsrc -g nfs
```

Step 3) /etc/inittab 파일 수정(주석 처리)

```
# rcnfs:23456789:wait:/etc/rc.nfs > /dev/console
```

```
# Start NFS Daemons
```

Step 4) /etc/inittab 파일 설정 적용

```
#init q
```

● HP-UX

Step 1) NFS 서비스 활성화 여부 확인 및 관련 데몬 PID 확인

```
# ps -ef | grep -E "nfsd|statd|lockd"
```

Step 2) NFS 서비스 관련 데몬 중지

```
# kill -9 <PID>
```

Step 3) /etc/rc.config.d/nfsconf 파일 수정

```
NFS_SERVER=0
```

Step 4) 설정 적용

```
# /usr/sbin/nfs.server start
```

U-40 (상)	UNIX > 3. 서비스 관리
	NFS 접근 통제
개요	
점검 내용	NFS(Network File System)의 접근 통제 설정 적용 여부 점검
점검 목적	접근 권한이 없는 비인가자의 접근을 통제하기 위함
보안 위협	접근 통제 설정이 적절하지 않을 경우, 인증 절차 없이 비인가자가 디렉터리나 파일의 접근이 가능하며, 해당 공유 시스템에 원격으로 마운트하여 중요 파일을 변조하거나 유출할 위험이 존재함
참고	※ NFS 서비스 사용 금지가 원칙이나, 불가피하게 사용 시 NFS v2, v3는 평문으로 전송되는 취약점이 있으므로 암호화되는 v4를 사용하는 것을 권고함 ※ NFS 서비스를 사용해야 하는 경우, NFS 설정 파일에 꼭 필요한 디렉터리만 설정하고, 허가된 사용자만 접근할 수 있도록 올바른 접근 통제를 설정해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 접근 통제가 설정되어 있으며 NFS 설정 파일 접근 권한이 644 이하인 경우
	취약 : 접근 통제가 설정되어 있지 않고 NFS 설정 파일 접근 권한이 644를 초과하는 경우
조치 방법	- NFS 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - 불가피하게 사용 시 접근 통제 설정 및 NFS 설정 파일 접근 권한 644 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) 파일 소유자 및 권한 확인

```
# ls -l /etc/dfs/dfstab
```

```
# ls -l /etc/dfs/sharetab
```

Step 2) /etc/dfs/dfstab 파일 내 공유 중인 디렉터리에 접근할 수 있는 사용자 및 부여 권한 확인

Step 3) 파일 소유자를 root로 변경

```
# chown root /etc/dfs/dfstab
```

Step 4) 파일 권한을 644로 변경

```
# chmod 644 /etc/dfs/dfstab
```

Step 5) /etc/dfs/dfstab 파일에 디렉터리 공유를 허용할 사용자 및 해당 사용자의 권한 설정

예시) 사용자의 읽기, 쓰기 권한 접속 허용 : `share -F nfs -o rw, ro /export/home/example`

사용자의 권한 접속 제한 : `share -F nfs -o rw=client1:client2, ro=client1:client2 /export/home/example`

Step 6) NFS 서비스 설정 적용

`# shareall`

※ 읽기(ro), 쓰기(rw) 권한에 각각 사용자를 설정하여야 읽기, 쓰기 권한 모두 제한 가능

● LINUX

Step 1) 파일 소유자 및 권한 확인

`# ls -l /etc/exports`

Step 2) /etc/exports 파일 내 공유 중인 디렉터리에 접근할 수 있는 사용자 및 부여 권한 확인

`# cat /etc/exports`

Step 3) 파일 소유자를 root로 변경

`# chown root /etc/exports`

Step 4) 파일 권한을 644로 변경

`# chmod 644 /etc/exports`

Step 5) /etc/exports 파일에 디렉터리 공유를 허용할 사용자 및 해당 사용자의 권한 설정

예시) `/home/example` `host1 (ro, root_squash)`

Step 6) NFS 서비스 설정 적용

`# exportfs -ra`

● AIX

Step 1) 파일 소유자 및 권한 확인

`# ls -l /etc/exports`

Step 2) /etc/exports 파일 내 공유 중인 디렉터리에 접근할 수 있는 사용자 및 부여 권한 확인

`# cat /etc/exports`

Step 3) 파일 소유자를 root로 변경

`# chown root /etc/exports`

Step 4) 파일 권한을 644로 변경

`# chmod 644 /etc/exports`

Step 5) /etc/exports 파일에 디렉터리 공유를 허용할 사용자 및 해당 사용자의 권한 설정

예시) /home/example -sec=sys:krb5p:krb5i:krb5:dh,ro=host1, access=host1

Step 6) NFS 서비스 재시작

exportfs -u, exportfs -a

● HP-UX

[/etc/dfs/dfstab]

Step 1) 파일 소유자 및 권한 확인

ls -l /etc/dfs/dfstab

ls -l /etc/dfs/sharetab

Step 2) /etc/dfs/dfstab 파일 내 공유 중인 디렉터리에 접근할 수 있는 사용자 및 부여 권한 확인

cat /etc/dfs/dfstab

Step 3) 파일 소유자를 root로 변경

chown root /etc/dfs/dfstab

Step 4) 파일 권한을 644로 변경

chmod 644 /etc/dfs/dfstab

Step 5) /etc/dfs/dfstab 파일에 디렉터리 공유를 허용할 사용자 및 해당 사용자의 권한 설정

예시) 사용자의 읽기, 쓰기 권한 접속 허용 : share -F nfs -o rw, ro /export/home/example

사용자의 권한 접속 제한 : share -F nfs -o rw=client1:client2, ro=client1:client2 /export/home/example

Step 6) NFS 서비스 설정 적용

shareall

※ 읽기(ro), 쓰기(rw) 권한에 각각 사용자를 설정하여야 읽기, 쓰기 권한 모두 제한 가능

[/etc/exports]

Step 1) 파일 소유자 및 권한 확인

ls -l /etc/exports

Step 2) /etc/exports 파일 내 디렉터리에 접근할 수 있는 사용자 및 부여 권한 확인

cat /etc/exports

Step 3) 파일 소유자를 root로 변경

chown root /etc/exports

Step 4) 파일 권한을 644로 변경

```
# chmod 644 /etc/exports
```

Step 5) /etc/exports 파일에 디렉터리 공유를 허용할 사용자 및 해당 사용자의 권한 설정

예시) /home/example host1 (ro, root_squash)

Step 6) NFS 서비스 설정 적용

```
# exportfs -ra
```

01. Unix 서버

U-41 (상)	UNIX > 3. 서비스 관리
	불필요한 automountd 제거
개요	
점검 내용	automountd 서비스 데몬의 실행 여부 점검
점검 목적	로컬 공격자가 automountd 데몬에 RPC(Remote Procedure Call)를 보낼 수 있는 취약점이 존재하기 때문에 해당 서비스를 중지시키기 위함
보안 위협	파일 시스템의 마운트 옵션을 변경하여 root 권한을 획득할 수 있으며, 로컬 공격자가 automountd 프로세스 권한으로 임의의 명령을 실행할 수 있는 위험이 존재함
참고	※ automountd : 클라이언트에서 자동으로 서버에 마운트를 시키고 일정 시간 사용하지 않으면 unmount 시켜 주는 기능을 말함 ※ RPC(Remote Procedure Call) : 별도의 원격 제어를 위한 코딩 없이 다른 주소 공간에서 함수나 프로시저를 실행할 수 있게 하는 프로세스 간 프로토콜
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : automountd 서비스가 비활성화된 경우
	취약 : automountd 서비스가 활성화된 경우
조치 방법	automountd 서비스 비활성화 설정
조치 시 영향	NFS 및 삼바(Samba) 서비스에서 사용 시 automountd 사용 여부 확인이 필요하며, 적용 시 CD-ROM의 자동 마운트는 이뤄지지 않음 (/etc/auto.*, /etc/auto_* 파일을 확인하여 필요 여부 확인)

점검 및 조치 사례

● SOLARIS

Step 1) automount 서비스 데몬 확인

#svcs -a | grep autofs

Step 2) autofs 서비스 데몬 확인

svcs -l svc:/system/filesystem/autofs:default

Step 3) 서비스 데몬 중지

svcadm disable <중지하고자 하는 서비스 데몬>

Step 4) autumount 또는 autofs 데몬 제거

pkg uninstall <삭제할 관련 데몬의 패키지명>

● LINUX

Step 1) automount 또는 autofs 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep -E "automount|autofs"
```

Step 2) automount 또는 autofs 서비스 중지

```
# systemctl stop <서비스명>
```

Step 3) automount 또는 autofs 서비스 비활성화

```
# systemctl disable <서비스명>
```

● AIX

[process 점검]

Step 1) automount 또는 autofs 서비스 활성화 여부 확인

```
# ps -ef | grep automountd
```

```
# ps -ef | grep autofs
```

Step 2) automount 또는 autofs 서비스 중지

```
# kill -9 <PID>
```

Step 3) automount 또는 autofs 데몬 제거

```
# installp -u <삭제할 관련 데몬의 패키지명>
```

[service 점검]

Step 1) automount 또는 autofs 서비스 활성화 여부 확인

```
# lssrc -a | grep -E "automountd|autofs"
```

Step 2) automount 또는 autofs 서비스 중지

```
# stopsrc -s automountd
```

```
# stopsrc -s autofs
```

Step 3) /etc/inittab 파일 수정(주석 처리)

```
#automountd:2:once:/usr/sbin/automountd > /dev/console 2>$1
```

Step 4) /etc/inittab 파일 설정 적용

```
# init q
```

- HP-UX

Step 1) automount 또는 autofs 서비스 활성화 여부 확인

```
# ps -ef | grep automountd
```

```
# ps -ef | grep autofs
```

Step 2) autumount 또는 autofs 서비스 중지

```
# kill -9 <PID>
```

Step 3) /etc/rc.config.d/nfsconf 파일 수정

```
AUTOFS=0
```

U-42 (상)	UNIX > 3. 서비스 관리
	불필요한 RPC 서비스 비활성화
개요	
점검 내용	불필요한 RPC 서비스의 실행 여부 점검
점검 목적	많은 취약점(버퍼 오버플로우, DoS, 원격 실행 등)이 존재하는 RPC 서비스를 비활성화하여 시스템의 보안성을 높이기 위함
보안 위협	RPC 서비스의 취약점을 통해 비인가자가 root 권한 획득 및 각종 공격을 시도할 위험이 존재함
참고	※ 불필요한 RPC 서비스: rpc.cmsd, rpc.ttdbserverd, sadmin, rusersd, walld, sprayd, rstatd, rpc.nisd, rexd, rpc.pcnfsd, rpc.statd, rpc.yppupdated, rpc.rquotad, kcms_server, cachefs
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 불필요한 RPC 서비스가 비활성화된 경우
	취약 : 불필요한 RPC 서비스가 활성화된 경우
조치 방법	불필요한 RPC 서비스 중지 및 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) RPC 서비스 관련 데몬 확인

```
# inetadm | grep rpc | grep enabled | egrep "tttdbserver|rex|rstart|rusers|spray|wall|rquota"
```

Step 2) 불필요한 RPC 서비스 확인

```
# inetadm | egrep "ttbd|rex|rstat|ruser|spray|wall|rquota"
```

Step 3) 서비스 데몬 중지

```
# svcadm disable <서비스 데몬>
```

● LINUX

[inetd]

Step 1) /etc/inetd.conf 파일 내 불필요한 RPC 서비스 활성화 여부 확인

```
# cat /etc/inetd.conf
```

Step 2) `etc/inetd.conf` 파일 수정(주석 처리)

```
#rpc.cmsd/2-4 dgram rpc/udp wait root /usr/dt/bin/rpc.cmsd rpc.cmsd
```

Step 3) `inetd` 서비스 재시작

```
# systemctl restart inetd
```

[xinetd]

Step 1) `/etc/xinetd.d/` 디렉터리 내 존재하는 불필요한 RPC 서비스 활성화 여부 확인

```
#cat /etc/xinetd.d/<파일명>
```

```
예시) service rpc-statd{
        disable      = no
        ...
}
```

Step 2) `/etc/xinetd.d/` 디렉터리 내 존재하는 불필요한 `rpc` 파일을 열어 `disable` 설정값 수정

```
disable = yes
```

Step 3) 설정 적용 및 서비스 재시작

```
# systemctl restart xinetd
```

[systemd]

Step 1) 불필요한 RPC 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep rpc
```

Step 2) 불필요한 RPC 서비스 중지

```
# systemctl stop <서비스명>
```

Step 3) 불필요한 RPC 서비스 비활성화

```
# systemctl disable <서비스명>
```

● AIX, HP-UX

Step 1) `/etc/inetd.conf` 파일 내 불필요한 RPC 서비스 활성화 여부 확인

Step 2) `/etc/inetd.conf` 파일 수정(주석 처리)

```
# rexd sunrpc_tcp tcp wait root /usr/sbin/rpc.rexd rexd 100017 1
```

```
# rstatd sunrpc_udp udp wait root /usr/sbin/rpc.rstatd rstatd 100001 1-3
```

Step 3) `inetd` 설정 적용

[AIX]

refresh -s inetd

[HP-UX]

inetd -c

01. Unix 서버

U-43 (상)	UNIX > 3. 서비스 관리
	NIS, NIS+ 점검
개요	
점검 내용	안전하지 않은 NIS 서비스의 비활성화, 안전한 NIS+ 서비스의 활성화 여부 점검
점검 목적	안전하지 않은 NIS 서비스를 비활성화하고 안전한 NIS+ 서비스를 활성화하여 시스템의 보안성을 높이기 위함
보안 위협	NIS 서비스가 활성화된 경우, 비인가자가 타 시스템의 root 권한까지 탈취할 수 있는 위험이 존재함
참고	※ NIS 주 서버는 정보표를 소유하여 NIS 대응 파일들로 변환하고, 이 대응 파일들이 네트워크를 통해 제공됨으로써 모든 컴퓨터에 정보가 갱신되도록 함. 네트워크를 통한 공유로부터 관리자와 사용자들에게 일관성 있는 시스템 환경을 제공함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : NIS 서비스가 비활성화되어 있거나, 불가피하게 사용 시 NIS+ 서비스를 사용하는 경우
	취약 : NIS 서비스가 활성화된 경우
조치 방법	NIS 관련 서비스 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) NIS 서비스 데몬 구동 여부 확인

svcs -a |grep nis

Step 2) NIS 관련 서비스 데몬 확인

svcs -a | grep nis

Step 3) NIS 서비스 데몬 중지

svcadm disable <서비스 데몬>

● LINUX

Step 1) NIS 관련 서비스 데몬 활성화 여부 확인

systemctl list-units --type=service | grep -E "ypserv|ypbind|ypxfrd|rpc.yppasswdd|rpc.yupdated"

Step 2) NIS 관련 서비스 데몬 중지

```
# systemctl stop <서비스명>
```

Step 3) NIS 관련 서비스 데몬 비활성화

```
# systemctl disable <서비스명>
```

※ Redhat 계열 리눅스는 RHEL 8 버전부터 NIS(yp rpms) 패키지가 제거되었음

● AIX

[process 점검]

Step 1) NIS 관련 서비스 데몬 활성화 여부 확인

```
# ps -ef | grep -E "ypserv|ypbind|ypxfrd|rpc.yppasswdd|rpc.yupdated"
```

Step 2) NIS 관련 서비스 중지

```
# kill -9 <PID>
```

Step 3) NIS 관련 서비스 시동 스크립트 위치 확인

```
# ls -al /etc/rc.d/rc*.d/* | grep -E "ypserv|ypbind|ypxfrd|rpc.yppasswdd|rpc.yupdated"
```

Step 4) NIS 관련 서비스 시동 스크립트 이름 변경

```
# mv /etc/rc.d/rc2.d/S73ypbind /etc/rc.d/rc2.d/_S73ypbind
```

[service 점검]

Step 1) NIS 관련 서비스 데몬 활성화 여부 확인

```
# lssrc -a | grep -E "ypserv|ypbind|ypxfrd|rpc.yppasswdd|rpc.yupdated"
```

Step 2) NIS 관련 서비스 중지

```
# stopsrc -s <NIS 관련 서비스명>
```

Step 3) etc/inittab 파일 수정(주석 처리)

```
#ypserv:2:wait:/usr/lib/netsvc/yp/ypserv >> /dev/console 2>&1
```

```
#ypbind:2:wait:/usr/lib/netsvc/yp/ypbind >> /dev/console 2>&1
```

Step 4) /etc/inittab 파일 설정 적용

```
# init q
```

● HP-UX

Step 1) NIS 관련 서비스 데몬 활성화 여부 확인

01. Unix 서버

```
# ps -ef | grep -E "ypserv|ypbind|ypxfrd|rpc.yppasswdd|rpc.yupdated"
```

Step 2) NIS 관련 서비스 중지

```
# kill -9 <PID>
```

Step 3) etc/rc.config.d/namesrvs 파일 수정

```
NIS_MASTER_SERVER=0
```

```
NIS_SLAVE_SERVER=0
```

```
NIS_CLIENT_SERVER=0
```

NIS 관련 서비스 데몬	설명
ypserv	master와 slave 서버에서 실행되며 클라이언트로부터의 ypbind 요청에 응답
ypbind	모든 NIS 시스템에서 실행되며 클라이언트와 서버를 바인딩하고 초기화함
rpc.yppasswdd	사용자들이 비밀번호를 변경하기 위해 사용
ypxfrd	NIS 마스터 서버에서만 실행되며 고속으로 NIS 맵 전송
rpc.yupdated	NIS 마스터 서버에서만 실행되며 고속으로 암호화하여 NIS 맵 전송

U-44 (상)	UNIX > 3. 서비스 관리
	tftp, talk 서비스 비활성화
개요	
점검 내용	tftp, talk, ntalk 서비스의 활성화 여부 점검
점검 목적	안전하지 않거나 불필요한 서비스를 제거함으로써 시스템 보안성 및 리소스의 효율적 운용하기 위함
보안 위협	사용하지 않는 서비스나 취약점이 발표된 서비스 운용 시 공격 시도 가능한 위험이 존재함
참고	※ tftp : 파일 전송을 위한 프로토콜로서 FTP 서비스보다 구조가 단순하며 적은 양의 데이터를 보낼 때 사용됨. 주로 원격의 부팅 파일을 불러오거나 설치 프로세스를 시작하기 위한 초기 데이터 호출 용도로 사용. 서비스 사용 시 인증 절차가 없어 보안에 취약함 ※ talk : 사용자가 시스템에 원격으로 연결하여 다른 시스템에 로그인하고 있는 사용자와 대화 세션을 시작할 수 있음 ※ ntalk : 서로 다른 시스템 간에 채팅을 가능하게 하는 서비스
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : tftp, talk, ntalk 서비스가 비활성화된 경우
	취약 : tftp, talk, ntalk 서비스가 활성화된 경우
조치 방법	불필요한 tftp, talk, ntalk 서비스 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) tftp, talk 서비스 활성화 여부 확인

```
# inetadm | egrep "tftp|talk"
```

Step 2) 불필요한 서비스 데몬 중지

```
# inetadm -d <서비스 데몬명>
```

● LINUX

[inetd]

Step 1) /etc/inetd.conf 파일 내 tftp, talk, ntalk 서비스 활성화 여부 확인

```
# cat /etc/inetd.conf
```

Step 2) /etc/inetd.conf 파일 수정(주석 처리)

```
#tftp dgram udp nobody /usr/sbin/tftpd tftpd -n
#talk stream tcp wait root /usr/sbin/talkd talkd
#ntalk dgram udp wait root /usr/sbin/talkd talkd
```

Step 3) inetd 서비스 재시작

```
# systemctl restart inetd
```

[xinetd]

Step 1) /etc/xinetd.d/ 디렉터리 내 존재하는 tftp, talk, ntalk 파일에 대해 서비스 활성화 여부 확인

```
예시) service tftp{
    disable      = no
    ...
}
```

Step 2) /etc/xinetd.d/ 디렉터리 내 존재하는 tftp, talk, ntalk 파일에 대한 설정값 변경

```
disable = yes
```

Step 3) 설정 적용 및 서비스 재시작

```
# systemctl restart xinetd
```

[systemd]

Step 1) 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep -E "tftp|talk|ntalk"
```

Step 2) tftp, talk, ntalk 서비스 중지

```
systemctl stop <서비스명>
```

Step 3) tftp, talk, ntalk 서비스 비활성화

```
# systemctl disable <서비스명>
```

※ Redhat 계열 리눅스는 RHEL 7 버전부터 talk 패키지가 제거되었음

● AIX, HP-UX

Step 1) 서비스 활성화 여부 확인

```
# /etc/inetd.conf | grep -E "tftp|talk|ntalk" tftp, talk, ntalk
```

Step 2) /etc/inetd.conf 파일 수정(주석 처리)

```
#tftp dgram udp6 SRC nobody /usr/sbin/tftpd tftpd -n
#talk dgram udp wait root /usr/sbin/talkd talkd
#ntalk dgram udp wait root /usr/sbin/talkd talkd
```

Step 3) inetd 설정 적용

[AIX]

refresh -s inetd

[HP-UX]

inetd -c

서비스 (포트)	설명
TFTP (69)	파일 전송을 위한 프로토콜로써 FTP 서비스보다 구조가 단순하며 적은 양의 데이터를 보낼 때 사용됨. 주로 원격의 부팅 파일을 불러오거나 설치 프로세스를 시작하기 위한 초기 데이터 호출 용도로 사용함. 서비스 사용 시 인증 절차가 없어 보안에 취약함
TALK (517)	사용자가 시스템에 원격으로 연결하여 다른 시스템에 로그인하고 있는 사용자와 대화 세션을 시작할 수 있음
NTALK (518)	서로 다른 시스템과 채팅을 가능하게 하는 서비스

U-45 (상)	UNIX > 3. 서비스 관리
	메일 서비스 버전 점검
개요	
점검 내용	취약한 버전의 메일 서비스 이용 여부 점검
점검 목적	메일 서비스 사용 목적 검토 및 취약점이 없는 버전의 사용 유무 점검으로 최적화된 메일 서비스의 운영하기 위함
보안 위협	취약점이 발견된 메일 버전의 경우 버퍼 오버플로우(Buffer Overflow) 공격에 의한 시스템 권한 획득 및 주요 정보 노출의 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 메일 서비스 버전이 최신 버전인 경우
	취약 : 메일 서비스 버전이 최신 버전이 아닌 경우
조치 방법	• 메일 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 • 메일 서비스 사용 시 패치 관리 정책을 수립하여 주기적으로 패치 적용 설정
조치 시 영향	패치 적용 시 시스템 및 서비스의 영향 정도를 충분히 고려해야 함

점검 및 조치 사례

● SOLARIS

[Sendmail 메일 서비스를 사용하는 경우]

Step 1) Sendmail 버전 확인

```
# /usr/sbin/sendmail -d grep Version
```

Step 2) 최신 버전 확인 및 보안 패치 진행

Sendmail 홈페이지(<http://www.sendmail.org/>)에 접속하여 다운로드 및 보안 패치 적용

[Sendmail 메일 서비스를 사용하지 않는 경우]

Step 1) Sendmail 서비스 활성화 여부 확인

```
# svcs -a | grep sendmail
```

Step 2) Sendmail 서비스 비활성화

```
# svcadm disable sendmail
```

[Postfix 메일 서비스를 사용하는 경우]

Step 1) Postfix 버전 확인

```
# /usr/lib/postfix/postconf | grep mail_version
```

Step 2) 최신 버전 확인 및 보안 패치 진행

postfix 홈페이지(<https://www.postfix.org/packages.html>)에 접속하여 해당 OS 패키지 주소로 접속 후 다운로드 및 보안 패치 적용

[Postfix 메일 서비스를 사용하지 않는 경우]

Step 1) Postfix 서비스 활성화 여부 확인

```
# svcs -a | grep postfix
```

Step 2) Postfix 서비스 비활성화

```
# svcadm disable postfix
```

[Exim 메일 서비스를 사용하는 경우]

Step 1) Exim 버전 확인

```
# usr/sbin/exim -bV
```

Step 2) 최신 버전 확인 및 보안 패치 진행

Exim 홈페이지(<https://www.exim.org/>)에 접속하여 다운로드 및 보안 패치 적용

[Exim 메일 서비스를 사용하지 않는 경우]

Step 1) Exim 서비스 활성화 여부 확인

```
# svcs -a | grep exim
```

Step 2) Exim 서비스 비활성화

```
# svcadm disable exim
```

● LINUX

[Sendmail 메일 서비스를 사용하는 경우]

Step 1) Sendmail 버전 확인

```
# sendmail -d0 -bt
```

Step 2) 최신 버전 확인 및 보안 패치 진행

Sendmail 홈페이지(<http://www.sendmail.org/>)에 접속하여 다운로드 및 보안 패치 적용

[Sendmail 메일 서비스를 사용하지 않는 경우]

Step 1) Sendmail 서비스 활성화 여부 확인

systemctl list-units --type=service | grep sendmail

Step 2) Sendmail 서비스 중지

systemctl stop sendmail

Step 3) Sendmail 서비스 비활성화

systemctl disable sendmail

[Postfix 메일 서비스를 사용하는 경우]

Step 1) Postfix 버전 확인

postconf mail_version

Step 2) 최신 버전 확인 및 보안 패치 진행

postfix 홈페이지(<https://www.postfix.org/packages.html>)에 접속하여 해당 OS 패키지 주소로 접속 후
다운로드 및 보안 패치 적용

[Postfix 메일 서비스를 사용하지 않는 경우]

Step 1) Postfix 서비스 활성화 여부 및 PID 확인

ps -ef | grep postfix

Step 2) Postfix 서비스 종료

kill -9 <PID>

[Exim 메일 서비스를 사용하는 경우]

Step 1) Exim 서비스 활성화 여부 확인

systemctl list-units --type=service | grep exim

Step 2) 최신 버전 확인 및 보안 패치 진행

Exim 홈페이지(<https://www.exim.org/>)에 접속하여 다운로드 및 보안 패치 적용

[Exim 메일 서비스를 사용하지 않는 경우]

Step 1) Exim 서비스 활성화 여부 및 PID 확인

ps -ef | grep exim

Step 2) Exim 서비스 종료

```
# kill -9 <PID>
```

● AIX

[Sendmail 메일 서비스를 사용하는 경우]

Step 1) Sendmail 버전 확인

```
# sendmail -d0 -bt
```

Step 2) 최신 버전 확인 및 보안 패치 진행

Sendmail 홈페이지(<http://www.sendmail.org/>)에 접속하여 다운로드 및 보안 패치 적용

[Sendmail 메일 서비스를 사용하지 않는 경우]

Step 1) Sendmail 서비스 활성화 여부 확인

```
# lssrc -a | grep sendmail
```

Step 2) Sendmail 서비스 중지

```
# stopsrc -s sendmail
```

Step 3) /etc/rc.tcpip 파일 수정(주석 처리)

```
#start /usr/lib/sendmail "$src_running" "-bd -q${qpi}"
```

[Postfix 메일 서비스를 사용하는 경우]

Step 1) Postfix 버전 확인

```
# postconf mail_version
```

Step 2) 최신 버전 확인 및 보안 패치 진행

postfix 홈페이지(<https://www.postfix.org/packages.html>)에 접속하여 해당 OS 패키지 주소로 접속 후
다운로드 및 보안 패치 적용

[Postfix 메일 서비스를 사용하지 않는 경우]

Step 1) Postfix 서비스 활성화 여부 및 PID 확인

```
# ps -ef | grep postfix
```

Step 2) Postfix 서비스 종료

```
# kill -9 <PID>
```

[Exim 메일 서비스를 사용하는 경우]

Step 1) Exim 버전 확인

exim -bV

Step 2) 최신 버전 확인 및 보안 패치 진행

Exim 홈페이지(<https://www.exim.org/>)에 접속하여 다운로드 및 보안 패치 적용**[Exim 메일 서비스를 사용하지 않는 경우]**

Step 1) Exim 서비스 활성화 여부 및 PID 확인

ps -ef | grep exim

Step 2) Exim 서비스 종료

kill -9 <PID>

● HP-UX

[Sendmail 메일 서비스를 사용하는 경우]

Step 1) Sendmail 버전 확인

sendmail -d0 -bt

Step 2) 최신 버전 확인 및 보안 패치 진행

Sendmail 홈페이지(<http://www.sendmail.org/>)에 접속하여 다운로드 및 보안 패치 적용**[Sendmail 메일 서비스를 사용하지 않는 경우]**

Step 1) Sendmail 서비스 활성화 여부 및 PID 확인

ps -ef | grep sendmail

Step 2) Sendmail 서비스 종료

kill -9 <PID>

Step 3) /etc/rc.config.d/mailervs 파일 수정

SENDMAIL_SERVER=0

[Postfix 메일 서비스를 사용하는 경우]

Step 1) Postfix 버전 확인

postconf mail_version

Step 2) 최신 버전 확인 및 보안 패치 진행

postfix 홈페이지(<https://www.postfix.org/packages.html>)에 접속하여 해당 OS 패키지 주소로 접속 후
다운로드 및 보안 패치 적용

[Postfix 메일 서비스를 사용하지 않는 경우]

Step 1) Postfix 서비스 활성화 여부 및 PID 확인

```
# ps -ef | grep postfix
```

Step 2) Postfix 서비스 종료

```
# kill -9 <PID>
```

[Exim 메일 서비스를 사용하는 경우]

Step 1) Exim 버전 확인

```
# exim -bV
```

Step 2) 최신 버전 확인 및 보안 패치 진행

Exim 홈페이지(<https://www.exim.org/>)에 접속하여 다운로드 및 보안 패치 적용

[Exim 메일 서비스를 사용하지 않는 경우]

Step 1) Exim 서비스 활성화 여부 및 PID 확인

```
# ps -ef | grep exim
```

Step 2) Exim 서비스 종료

```
# kill -9 <PID>
```

01. Unix 서버

U-46 (상)	UNIX > 3. 서비스 관리
	일반 사용자의 메일 서비스 실행 방지
개요	
점검 내용	SMTP 서비스 사용 시 일반 사용자의 q 옵션 제한 여부 점검
점검 목적	일반 사용자의 q 옵션을 제한하여 메일 서비스 설정 및 메일 큐를 강제로 drop 시킬 수 없게 하여 비인가자에 의한 SMTP 서비스 오류 방지하기 위함
보안 위협	일반 사용자가 q 옵션을 이용해서 메일 큐, 메일 서비스 설정을 보거나 메일 큐를 강제로 drop 시킬 수 있어 악의적으로 SMTP 서버의 오류를 발생시킬 위험이 존재함
참고	※ SMTP(Simple Mail Transfer Protocol) : 인터넷상에서 전자우편(E-mail)을 전송할 때 이용하게 되는 표준 통신 규약을 말함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 일반 사용자의 메일 서비스 실행 방지가 설정된 경우
	취약 : 일반 사용자의 메일 서비스 실행 방지가 설정되어 있지 않은 경우
조치 방법	• 메일 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 • 메일 서비스 사용 시 메일 서비스의 q 옵션 제한 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

[Sendmail]

Step 1) /etc/mail/sendmail.cf 파일 내 PrivacyOptions 설정에 restrictqrn 값 추가

PrivacyOptions = authwarnings, novrfy, noexpn, restrictqrn

Step 2) Sendmail 서비스 재시작

[Postfix]

Step 1) 일반 사용자 실행 권한 확인

ls -l /usr/sbin/postsuper

Step 2) 일반 사용자 실행 권한 제거

chmod o-x /usr/sbin/postsuper

[Exim]

Step 1) 일반 사용자 실행 권한 확인

```
# ls -l /usr/sbin/exiqgrep
```

Step 2) 일반 사용자 실행 권한 제거

```
# chmod o-x /usr/sbin/exiqgrep
```

01. Unix 서버

U-47 (상)	UNIX > 3. 서비스 관리
	스팸 메일 릴레이 제한
개요	
점검 내용	SMTP 서버의 릴레이 기능 제한 여부 점검
점검 목적	스팸 메일 서버로의 악용 방지 및 서버 과부하를 방지하기 위함
보안 위협	SMTP 서버의 릴레이 기능을 제한하지 않을 경우, 악의적인 사용 목적을 가진 사용자들이 스팸 메일 서버로 사용하거나 DoS 공격의 위험이 존재함
참고	※ SMTP(Simple Mail Transfer Protocol) 서버: SMTP에 의해 전자 메일을 발신하는 서버(server)를 SMTP 서버라고 함 ※ 메일 서비스를 사용하지 않는 경우 양호 또는 N/A
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 릴레이 제한이 설정된 경우
	취약 : 릴레이 제한이 설정되어 있지 않은 경우
조치 방법	- 메일 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - 메일 서비스 사용 시 릴레이 방지 설정 또는 릴레이 대상 접근 제어 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

[Sendmail 8.9 이상 버전]

Step 1) /etc/mail/sendmail.cf 파일 내 릴레이 허용 설정 여부 확인

Step 2) /etc/mail/sendmail.mc 파일 수정

FEATURE(`promiscuous_relay')dnl <해당 설정 제거>

Step 3) sendmail.cf 설정 파일 재생성

m4 /etc/mail/sendmail.mc > /etc/mail/sendmail.cf

Step 4) /etc/mail/access 파일에 특정 IP, Domain, Email 주소, 네트워크에 대한 접근제한 설정

예시) localhost.localdomain RELAY

localhost RELAY

127.0.0.1 RELAY

```
spam.com      REJECT
```

- /etc/mail/access 파일을 생성하거나 수정하였을 경우
makemap hash /etc/mail/access.db < /etc/mail/access 명령으로 DB 파일 생성

Step 5) 설정 적용 및 재시작

```
# systemctl restart sendmail
```

※ Sendmail 8.9 이상 버전부터는 기본적으로 스팸 메일 릴레이 제한 설정이 적용됨

[Sendmail 8.9 미만 버전]

Step 1) /etc/mail/sendmail.cf 파일 내 릴레이 제한 설정 확인

```
# cat /etc/mail/sendmail.cf | grep "R$*" | grep "Relaying denied"
```

Step 2) /etc/mail/sendmail.cf 파일 수정

```
# R$*  $#error $@ 5.7.1 $: "550 Relaying denied"
```

Step 3) /etc/mail/access 파일에 특정 IP, Domain, Email 주소, 네트워크에 대한 접근제한 설정

예시) localhost.localdomain RELAY

```
localhost      RELAY
127.0.0.1      RELAY
spam.com       REJECT
```

Step 4) Sendmail 서비스 재시작

※ 파일이 존재하지 않는 경우 생성하여 설정

※ /etc/mail/access 파일을 생성하거나 수정하였을 경우

```
# makemap hash /etc/mail/access.db < /etc/mail/access 명령으로 DB 파일 생성
```

[Postfix]

Step 1) /etc/postfix/main.cf 파일 내 릴레이 정책 설정 확인

```
# cat /etc/postfix/main.cf | grep -E "smtpd_recipient_restrictions|mynetworks"
```

Step 2) /etc/postfix/main.cf 파일 수정

```
mynetworks = <허용할 네트워크 주소>
```

Step 3) 설정 적용

```
# postfix reload
```

[Exim]

Step 1) /etc/exim/exim.conf, /etc/exim4/exim4.conf 파일 내 릴레이 설정이 허용된 네트워크 주소 확인

```
cat <파일명> | grep -E "relay_from_hosts|hosts ="
```

Step 2) /etc/exim/exim.conf 또는 /etc/exim4/exim4.conf 파일 수정

```
hostlist relay_from_hosts = <허용할 네트워크 주소>
```

```
accept hosts      = +relay_from_hosts 또는 <허용할 네트워크 주소>
```

Step 3) Exim 서비스 재시작

U-48 (중)	UNIX > 3. 서비스 관리
	expn, vrfy 명령어 제한
개요	
점검 내용	SMTP 서비스 사용 시 expn, vrfy 명령어 사용 금지 설정 여부 점검
점검 목적	SMTP 서비스의 expn, vrfy 명령어를 통한 정보 유출을 방지하기 위함
보안 위협	expn, vrfy 명령어를 통하여 특정 사용자 계정의 존재 여부를 알 수 있고, 사용자의 정보를 외부로 유출할 수 있는 위험이 존재함
참고	※ expn(메일링 리스트 확장) : 메일 전송 시 포워딩하기 위한 명령어 ※ vrfy : SMTP 클라이언트가 SMTP 서버에 특정 아이디에 대한 메일이 있는지 검증하기 위해 보내는 명령어 ※ goaway : authwarnings, noexpn, novrfy, noveb, needmailhelo, needexpnhelo, needvrfyhelo, nobodyreturn 옵션을 통합한 단축 옵션 ※ 메일 서비스를 사용하지 않는 경우 양호 또는 N/A
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : noexpn, novrfy 옵션이 설정된 경우
	취약 : noexpn, novrfy 옵션이 설정되어 있지 않은 경우
조치 방법	- 메일 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - 메일 서비스 사용 시 메일 서비스 설정 파일에 noexpn, novrfy 또는 goaway 옵션 추가 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

[Sendmail]

Step 1) /etc/mail/sendmail.cf 파일 내 PrivacyOptions 설정 확인

Step 2) PrivacyOptions 옵션 수정

PrivacyOptions = authwarnings, novrfy, noexpn, restrictqrn

또는

PrivacyOptions = restrictqrn, goaway

Step 3) Sendmail 서비스 재시작

01. Unix 서버

※ goaway : authwarnings, noexpn, novrfy, noveb, needmailhelo, needexpnhelo, needvrfyhelo, nobodyreturn 기능이 통합된 단축 옵션

[Postfix]

Step 1) /etc/postfix/main.cf 파일 내 vrfy 설정 확인

Step 2) disable_vrfy_command 옵션을 yes로 수정

```
disable_vrfy_command = yes
```

Step 3) postfix 설정 적용 및 재시작

```
# postfix reload
```

※ Postfix는 기본적으로 expn 기능 및 설정을 허용하지 않음

[Exim]

Step 1) /etc/exim/exim.conf 또는 /etc/exim4/exim4.conf 파일 내 expn, vrfy 설정 확인

Step 2) 해당 옵션이 허용된 경우 설정 제거

```
acl_smtp_vrfy = acceptacl_smtp_expn = accept 주석 처리 혹은 명령어 줄 삭제
```

Step 3) Exim 서비스 재시작

U-49 (상)	UNIX > 3. 서비스 관리
	DNS 보안 버전 패치
개요	
점검 내용	BIND 최신 버전 사용 유무 및 주기적 보안 패치 여부 점검
점검 목적	취약점이 발표되지 않은 BIND 버전을 사용하여 시스템 보안성을 높이기 위함
보안 위협	취약점이 내포된 BIND 버전을 사용할 경우, DoS 공격, 버퍼 오버플로우(Buffer Overflow) 및 DNS 서버 원격 침입 등의 위험이 존재함
참고	※ BIND(Berkeley Internet Name Domain) : BIND는 BSD 기반의 유닉스 시스템을 위해 설계된 DNS로 서버와 resolver 라이브러리로 구성되어 있음. 네임 서버는 클라이언트들이 이름 자원들이나 Object들에 접근하여, 네트워크 내의 다른 Object들과 함께 정보를 공유할 수 있게 해주는 네트워크 서비스로 사실상 컴퓨터 네트워크 내의 Object들을 위한 분산 데이터베이스 시스템임
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 주기적으로 패치를 관리하는 경우
	취약 : 주기적으로 패치를 관리하고 있지 않은 경우
조치 방법	- DNS 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - DNS 서비스 사용 시 패치 관리 정책 수립 및 주기적으로 패치 적용 설정 ※ DNS 서비스의 경우 대부분의 버전에서 취약점이 보고되고 있으므로 OS 관리자, 서비스 개발자가 패치 적용에 따른 서비스 영향 정도를 정확히 파악하여 주기적인 패치 적용 정책 수립 후 적용
조치 시 영향	패치 적용 시 시스템 및 서비스 영향 정도를 충분히 고려해야 함

점검 및 조치 사례

● SOLARIS

Step 1) DNS 서비스 활성화 여부 확인

```
# svcs -a | grep bind
```

Step 2) DNS 서비스 비활성화

```
# svcadm disable bind
```

Step 3) BIND 버전 확인

```
# named -v
```

Step 4) DNS 서비스 최신 패치 버전 확인 및 업데이트

ISC 홈페이지 <https://www.isc.org/downloads/>

※ BIND 9 취약점 정보(BIND 9 Vulnerability matrix) <https://kb.isc.org/v1/docs/en/aa-00913>

● LINUX

Step 1) DNS 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep named
```

Step 2) DNS 서비스 비활성화

```
# systemctl stop named
```

Step 3) BIND 버전 확인

```
# named -v
```

Step 4) DNS 서비스 최신 패치 버전 확인 및 업데이트

ISC 홈페이지 <https://www.isc.org/downloads/>

※ BIND 9 취약점 정보(BIND 9 Vulnerability matrix) <https://kb.isc.org/v1/docs/en/aa-00913>

● AIX

Step 1) DNS 서비스 활성화 여부 확인

```
lssrc -a | grep named
```

Step 2) DNS 서비스 비활성화

```
# stopsrc -s named
```

Step 3) BIND 버전 확인

```
# named -v
```

Step 4) DNS 서비스 최신 패치 버전 확인 및 업데이트

ISC 홈페이지 <https://www.isc.org/downloads/>

※ BIND 9 취약점 정보(BIND 9 Vulnerability matrix) <https://kb.isc.org/v1/docs/en/aa-00913>

● HP-UX

Step 1) DNS 서비스 활성화 여부 확인

```
# ps -ef | grep named
```

Step 2) DNS 서비스 중지

```
# /sbin/init.d/named stop
```

Step 3) etc/rc.config.d/namesrvs 파일 내 NAMED 값을 0으로 수정

```
NAMED=0
```

Step 4) BIND 버전 확인

```
# named -v
```

Step 5) DNS 서비스 최신 패치 버전 확인 및 업데이트

ISC 홈페이지 <https://www.isc.org/downloads/>

※ BIND 9 취약점 정보(BIND 9 Vulnerability matrix) <https://kb.isc.org/v1/docs/en/aa-00913>

U-50 (상)	UNIX > 3. 서비스 관리
	DNS ZoneTransfer 설정
개요	
점검 내용	Secondary Name Server로만 Zone 정보 전송 제한 여부 점검
점검 목적	DNS Zone Transfer 설정을 통해 비인가자에 대한 무단 접근을 방지하기 위함
보안 위협	Zone Transfer를 모든 사용자에게 허용할 경우, 비인가자에게 <u>호스트</u> 정보, 시스템 정보 등 중요 정보가 유출될 위험이 존재함
참고	※ DNS Zone Transfer는 Primary Name Server와 Secondary Name Server 간에 Zone 정보를 일관성 있게 유지하기 위하여 사용하는 기능
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : Zone Transfer를 허가된 사용자에게만 허용한 경우
	취약 : Zone Transfer를 모든 사용자에게 허용한 경우
조치 방법	- DNS 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - DNS 서비스 사용 시 DNS Zone Transfer를 허가된 사용자에게만 전송 허용하도록 설정
조치 시 영향	Zone Transfer 설정에서 허용할 대상을 정상적으로 등록하였다면 일반적으로 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) xfnets 설정 확인

```
# cat /etc/named.boot | grep xfnets 또는 # cat /etc/bind/named.boot | grep xfnets
```

Step 2) allow-transfer 설정 확인

```
# cat /etc/named.conf | grep allow-transfer 또는 # cat /etc/bind/named.conf.options | grep allow-transfer
```

Step 3) /etc(/bind)/named.boot 파일의 xfnets 설정값 수정

```
xfnets <zone transfer를 허용할 IP>
```

Step 4) /etc(/bind)/named.conf 파일의 allow-transfer 설정값 수정

```
allow-transfer { <zone transfer를 허용할 IP>;
```

Step 5) DNS 서비스 재시작

※ DNS 서비스 Zone 파일명은 임의 지정이 가능하므로 DNS 설정 파일의 Include 구문으로 참조하는 파일명 점검

U-51 (중)	UNIX > 3. 서비스 관리
	DNS 서비스의 취약한 동적 업데이트 설정 금지
개요	
점검 내용	DNS 서비스의 취약한 동적 업데이트 설정 여부 점검
점검 목적	DNS 서비스의 동적 업데이트를 비활성화함으로써 신뢰할 수 없는 원본으로부터 업데이트를 받아들이는 위험을 차단하기 위함
보안 위협	DNS 서버에서 동적 업데이트를 사용할 경우, 악의적인 사용자에 의해 신뢰할 수 없는 데이터가 받아들여질 위험이 존재함
참고	※ DNS 동적 업데이트 : DNS 정보에 변경 사항이 있을 때마다 DNS 클라이언트 컴퓨터가 자신의 리소스 레코드(zone 파일)를 DNS 서버에 자동으로 업데이트하는 기능으로 영역 레코드 수동 관리 작업을 줄일 수 있음
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : DNS 서비스의 동적 업데이트 기능이 비활성화되었거나, 활성화 시 적절한 접근통제를 수행하고 있는 경우
	취약 : DNS 서비스의 동적 업데이트 기능이 활성화 중이며 적절한 접근통제를 수행하고 있지 않은 경우
조치 방법	- DNS 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - DNS 서비스 사용 시 일반적으로 동적 업데이트 기능이 필요 없으나 확인 필요함
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

[DNS 동적 업데이트가 필요하지 않은 경우]

Step 1) allow-update 설정 확인

```
# cat /etc/named.conf | grep allow-update 또는 # cat /etc/bind/named.conf.options | grep allow-update
```

Step 2) /etc(/bind)/named.conf 파일의 allow-update 설정값 수정

```
allow-update { none; };
```

Step 3) DNS 서비스 재시작

[DNS 동적 업데이트가 필요한 경우]

Step 1) allow-update 설정 확인

```
# cat /etc/named.conf | grep allow-update” 또는 # cat /etc/bind/named.conf.options | grep allow-update
```

Step 2) /etc(/bind)/named.conf 파일의 allow-update 설정값 수정

```
allow-update { <DNS update를 허용할 IP>; };
```

Step 3) DNS 서비스 재시작

※ DNS 서비스 Zone 파일명은 임의 지정이 가능하므로 DNS 설정 파일의 Include 구문으로 참조하는 파일명 점검

U-52 (중)	UNIX > 3. 서비스 관리
	Telnet 서비스 비활성화
개요	
점검 내용	원격 접속 시 Telnet 프로토콜 사용 여부 점검
점검 목적	취약한 Telnet 프로토콜을 비활성화함으로써 계정 및 중요 정보 유출 방지하기 위함
보안 위협	원격 접속 시 Telnet 프로토콜을 사용할 경우, 데이터가 평문으로 전송되어 비인가자가 스니핑을 통해 계정 및 중요 정보를 외부로 유출할 위험이 존재함
참고	※ 스니핑 : 컴퓨터 네트워크상에 흘러 다니는 트래픽을 도청하는 행위
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 원격 접속 시 Telnet 프로토콜을 비활성화하고 있는 경우
	취약 : 원격 접속 시 Telnet 프로토콜을 사용하는 경우
조치 방법	Telnet, FTP 등 안전하지 않은 서비스 사용을 중지하고 SSH 설치 및 사용하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) Telnet 서비스 활성화 여부 확인

```
# svcs -a | grep telnet
```

Step 2) Telnet 서비스 비활성화

```
# svcadm disable svc:/network/telnet:default
```

Step 3) SSH 서비스 실행

```
# svcadm enable ssh
```

● LINUX

[inetd]

Step 1) /etc/inetd.conf 파일 내 Telnet 서비스 활성화 여부 확인

Step 2) 해당 옵션이 허용된 경우 설정 제거

예시) telnet stream tcp nowait root /usr/sbin/in.telnetd 주석 처리 혹은 명령어 줄 삭제

Step 3) inetd 서비스 재시작

```
# service inetd restart
```

Step 4) SSH 서비스 실행

```
# service sshd start
```

[xinetd]

Step 1) /etc/xinetd.d/telnet 파일 내 Telnet 서비스 활성화 여부 확인

```
# cat /etc/xinetd.d/telnet
```

Step 2) /etc/xinetd.d/telnet 파일의 disable 설정값 수정

```
disable = yes
```

Step 3) 설정 적용 및 서비스 재시작

```
# systemctl restart xinetd
```

Step 4) SSH 서비스 실행

```
# systemctl start sshd
```

[systemd]

Step 1) Telnet 서비스 활성화 여부 확인

```
# systemctl list-units --type=socket | grep telnet
```

Step 2) Telnet 서비스 중지

```
# systemctl stop telnet.socket
```

Step 3) Telnet 서비스 비활성화

```
# systemctl disable telnet.socket
```

Step 4) SSH 서비스 실행

```
# systemctl start sshd
```

● AIX

Step 1) /etc/inetd.conf 파일 내 Telnet 서비스 활성화 여부 확인

Step 2) 해당 옵션이 허용된 경우 설정 제거

예시) telnet stream tcp6 nowait root /usr/sbin/telnetd telnetd -a 주석 처리 혹은 명령어 줄 삭제

Step 3) inetd 설정 적용

```
# refresh -s inetd
```

Step 4) SSH 서비스 실행

```
# startsrc -s sshd
```

● HP-UX

Step 1) /etc/inetd.conf 파일 내 Telnet 서비스 활성화 여부 확인

```
# cat /etc/inetd.conf | grep telnet
```

Step 2) 해당 옵션이 허용된 경우 설정 제거

```
# telnet stream tcp6 nowait root /usr/sbin/telnetd telnetd -a 주석 처리 혹은 명령어 줄 삭제
```

Step 3) inetd 설정 적용

```
# inetd -c
```

Step 4) SSH 서비스 실행

```
# /sbin/init.d/secsh start
```

01. Unix 서버

U-53 (하)	UNIX > 3. 서비스 관리
	FTP 서비스 정보 노출 제한
개요	
점검 내용	FTP 서비스 정보 노출 여부 점검
점검 목적	FTP 서비스 접속 배너를 통한 불필요한 정보 노출을 방지하기 위함
보안 위협	서비스 접속 배너가 차단되지 않을 경우, 비인가자가 FTP 접속 시도 시 노출되는 접속 배너 정보를 수집하여 악의적인 공격에 이용할 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : FTP 접속 배너에 노출되는 정보가 없는 경우
	취약 : FTP 접속 배너에 노출되는 정보가 있는 경우
조치 방법	- FTP 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - FTP 서비스 사용 시 FTP 설정 파일을 통해 접속 배너 설정 ※ 접속 배너에 서비스 이름이나 버전 정보를 노출하지 않는 것을 권고
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX

[vsFTP]

Step 1) 배너 설정 확인

```
# cat /etc/vsftpd.conf | grep ftpd_banner 또는
```

```
# cat /etc/vsftpd/vsftpd.conf | grep ftpd_banner
```

Step 2) 해당 옵션이 설정되지 않은 경우 주석 제거 및 옵션 설정

```
# ftpd_banner=<변경할 배너>
```

Step 3) vsFTP 서비스 재시작

```
# systemctl restart vsftpd
```

[ProFTP]

Step 1) 배너 설정 확인

```
# cat /etc/proftpd.conf | grep ServerIdent 또는 # cat /etc/proftpd/proftpd.conf | grep ServerIdent
```

Step 2) /etc(/proftpd)/proftpd.conf 파일의 ServerIdent 설정값 수정

ServerIdent off 또는 ServerIdent on “<변경할 배너>”

Step 3) ProFTP 서비스 재시작

```
# systemctl restart proftpd
```

● AIX

[FTP]

Step 1) 메시지 카탈로그 파일 추출

```
# dspcat -g /usr/lib/nls/msg/en_US/ftpd.cat > /tmp/ftpd.msg
```

Step 2) 배너 설정 확인

```
# cat /tmp/ftpd.msg
```

“(%)s FTP server (%)s ready.”

Step 3) /tmp/ftpd.msg 파일 내 배너 설정 변경

“<변경할 배너>”

Step 4) ftpd.cat 파일 생성

```
# gencat /usr/lib/nls/msg/en_US/ftpd.cat /tmp/ftpd.msg
```

[vsFTP]

Step 1) 배너 설정 확인

```
# cat /etc/vsftpd.conf | grep ftpd_banner
```

Step 2) 해당 옵션이 설정되지 않은 경우 주석 제거 및 옵션 설정

ftpd_banner=<변경할 배너>

Step 3) vsFTP 서비스 PID 확인

```
# ps -ef | grep vsftp
```

Step 4) vsFTP 서비스 재시작

```
# kill -1 <PID>
```

[ProFTP]

Step 1) 배너 설정 확인

cat /etc/proftpd.conf | grep ServerIdent

Step 2) /etc/proftpd.conf 파일 내 ServerIdent 설정값 변경

ServerIdent off 또는 ServerIdent on “<변경할 배너>”

Step 3) ProFTP 서비스 PID 확인

ps -ef | grep proftp

Step 4) ProFTP 서비스 재시작

kill -1 <PID>

● HP-UX

[FTP]

Step 1) FTP 설정 파일 경로 확인

cat /etc/inetd.conf | grep ftp

Step 2) ftpaccess 설정 확인

cat /etc/ftpd/ftpaccess

Wu-ftp v2.4 미만 : suppresshostname, suppressversion, banner <파일 경로> 설정 확인

Wu-ftp v2.4 이상 : greeting, banner <파일 경로> 설정 확인

Step 3) 배너 설정 확인

cat <기본 FTP 배너 설정 파일 경로>

Step 4) /etc/inetd.conf 파일 설정값 변경

ftp stream tcp nowait root /usr/sbin/ftpd ftpd -a /etc/ftpd/ftpaccess

Step 5) 배너 파일 수정

vi 편집기를 이용하여 배너 파일을 열어 변경할 배너 작성

Step 6) /etc/ftpd/ftpaccess 파일의 suppresshostname, suppressversion, greeting 옵션 설정값 변경

Wu-ftp v2.4 미만 : suppresshostname yes

suppressversion yes

banner <경고 메시지가 작성된 파일 경로>

Wu-ftp v2.4 이상 : greeting terse

banner <경고 메시지가 작성된 파일 경로>

Step 7) inetd 설정 적용

```
# inetd -c
```

※ 해당 파일이 존재하지 않는 경우 “cp /usr/newconfig/etc/ftpd/examples/ftpaccess /etc/ftpd/ftpaccess”
명령으로 파일 생성

[vsFTP]

Step 1) 배너 설정 확인

```
# cat /etc/vsftpd.conf | grep ftpd_banner
```

Step 2) /etc/vsftpd.conf 파일의 ftpd_banner 설정값 변경

```
ftpd_banner=<변경할 배너>
```

Step 3) vsFTP 서비스 PID 확인

```
# ps -ef | grep vsftp
```

Step 4) vsFTP 서비스 재시작

```
# kill -1 <PID>
```

[ProFTP]

Step 1) 배너 설정 확인

```
# cat /etc/proftpd.conf | grep ServerIdent
```

Step 2) /etc/proftpd.conf 파일의 설정값 변경

```
ServerIdent off 또는 ServerIdent on “<변경할 배너>”
```

Step 3) ProFTP 서비스 PID 확인

```
# ps -ef | grep proftp
```

Step 4) ProFTP 서비스 재시작

```
# kill -1 <PID>
```

01. Unix 서버

U-54 (중)	UNIX > 3. 서비스 관리
	암호화되지 않는 FTP 서비스 비활성화
개요	
점검 내용	암호화되지 않은 FTP 서비스 비활성화 여부 점검
점검 목적	암호화되지 않은 FTP 서비스를 비활성화함으로써 계정 및 중요 정보 유출 방지하기 위함
보안 위협	암호화되지 않은 FTP 서비스를 사용할 경우, 데이터가 평문으로 전송되어 비인가자가 스니핑을 통해 계정 및 중요 정보를 외부로 유출할 위험이 존재함
참고	※ 기반시설 시스템에서 FTP 서비스의 이용은 원칙적으로 금지하나, 불가피하게 사용 시 SFTP 사용 권고 ※ 암호화되지 않은 FTP 서비스 종류 : FTP ※ 암호화되어 있는 FTP 서비스 종류 : SFTP, FTP over SSH(Secure FTP), FTPS
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 암호화되지 않은 FTP 서비스가 비활성화된 경우
	취약 : 암호화되지 않은 FTP 서비스가 활성화된 경우
조치 방법	암호화되지 않은 FTP 서비스 중지 및 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

[vsFTP]

Step 1) FTP 서비스 활성화 여부 확인

svcs -a | grep vsftpd

Step 2) FTP 서비스 비활성화

svcadm disable vsftpd

[ProFTP]

Step 1) FTP 서비스 활성화 여부 확인

svcs -a | grep proftpd

Step 2) FTP 서비스 비활성화

```
# svcadm disable proftpd
```

● LINUX

[inetd]

Step 1) /etc/inetd.conf 파일 내 FTP 서비스 활성화 여부 확인

Step 2) /etc/inetd.conf 파일의 설정값 변경(주석 처리)

```
# ftp stream tcp nowait root /usr/sbin/tcpd /usr/sbin/in.ftpd
```

Step 3) inetd 서비스 재시작

```
# service inetd restart
```

[xinetd]

Step 1) /etc/xinetd.d/ftp 파일 내 FTP 서비스 활성화 여부 확인

service ftp 단락 확인

Step 2) /etc/xinetd.d/ftp 파일의 설정값 변경

```
service ftp{disable = yes}
```

Step 3) 설정 적용 및 재시작

```
# systemctl restart xinetd
```

[vsFTP]

Step 1) FTP 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep vsftpd
```

Step 2) FTP 서비스 중지

```
# systemctl stop vsftpd
```

Step 3) FTP 서비스 비활성화

```
# systemctl disable vsftpd
```

[ProFTP]

Step 1) FTP 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep proftpd
```

Step 2) FTP 서비스 중지

```
# systemctl stop proftpd
```

Step 3) FTP 서비스 비활성화

```
# systemctl disable proftpd
```

● AIX, HP-UX

[FTP]

Step 1) /etc/inetd.conf 파일 내 FTP 서비스 활성화 여부 확인

```
# cat /etc/inetd.conf
```

Step 2) /etc/inetd.conf 파일의 설정값 변경(주석 처리)

```
# ftp stream tcp nowait root /usr/sbin/tcpd /usr/sbin/in.ftpd
```

Step 3) inetd 설정 적용

```
# refresh -s inetd
```

[vsFTP]

Step 1) vsFTP 서비스 활성화 여부 확인

```
# ps -ef | grep vsftp
```

Step 2) vsFTP 서비스 PID 확인

```
# ps -ef | grep vsftp
```

Step 3) vsFTP 서비스 중지

```
# kill -9 <PID>
```

[ProFTP]

Step 1) ProFTP 서비스 활성화 여부 확인

```
# ps -ef | grep proftp
```

Step 2) ProFTP 서비스 PID 확인

```
# ps -ef | grep proftp
```

Step 3) ProFTP 서비스 중지

```
# kill -9 <PID>
```

U-55 (중)	UNIX > 3. 서비스 관리
	FTP 계정 shell 제한
개요	
점검 내용	FTP 기본 계정에 쉘 설정 여부 점검
점검 목적	FTP 계정의 쉘을 통한 시스템 접근을 차단하기 위함
보안 위협	FTP 기본 계정에 쉘이 부여될 경우, 비인가자가 해당 기본 계정으로 시스템에 접근할 위험이 존재함
참고	※ 기반시설 시스템에서 FTP 서비스의 이용은 원칙적으로 금지하나, 불가피하게 사용 시 shell 제한 등의 보안 조치를 반드시 적용해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : FTP 계정에 /bin/false(/sbin/nologin) 쉘이 부여된 경우
	취약 : FTP 계정에 /bin/false(/sbin/nologin) 쉘이 부여되어 있지 않은 경우
조치 방법	- FTP 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - FTP 서비스 사용 시 FTP 계정에 /bin/false 쉘 부여 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) ftp 계정의 일곱 번째 필드에 등록된 로그인 쉘 확인

```
# cat /etc/passwd | grep ftp
```

예시) ftp:x:134:65534::srv/ftp:usr/sbin/nologin

Step 2) ftp 계정 로그인 쉘 변경

/etc/passwd 파일 직접 수정 : ftp:x:134:65534::srv/ftp:/bin/false 또는 /sbin/nologin

usermod 명령어를 사용하여 수정

```
# usermod -s /bin/false <계정>
```

01. Unix 서버

U-56 (하)	UNIX > 3. 서비스 관리
	FTP 서비스 접근 제어 설정
개요	
점검 내용	FTP 서비스에 비인가자의 접근 가능 여부 점검
점검 목적	접근 권한이 없는 비인가자의 접근을 통제하기 위함
보안 위협	FTP 서비스의 접근제한 설정이 적절하지 않을 경우, 인증 절차 없이 비인가자가 디렉터리나 파일에 접근할 수 있어 중요 파일 변조 및 유출을 시도할 위험이 존재함
참고	※ 기반시설 시스템에서 FTP 서비스의 이용은 원칙적으로 금지하나, 불가피하게 사용 시 접근 제어 설정 등의 보안 조치를 반드시 적용해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 특정 IP주소 또는 호스트에서만 FTP 서버에 접속할 수 있도록 접근 제어 설정을 적용한 경우
	취약 : FTP 서버에 접근 제어 설정을 적용하지 않은 경우
조치 방법	- FTP 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - FTP 서비스 사용 시 접근 제어 설정
조치 시 영향	특정 IP주소 또는 호스트에서만 FTP 접속이 가능함

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

[FTP – ftpusers]

Step 1) ftpusers 파일 소유자 및 권한 확인

ls -l /etc/ftpusers 또는 # ls -l /etc/ftpd/ftpusers

Step 2) 접근 제한 설정 확인

cat /etc/ftpusers 또는 # cat /etc/ftpd/ftpusers

Step 3) 파일 소유자를 root로 변경

chown root /etc/ftpusers 또는 # chown root /etc/ftpd/ftpusers

Step 4) 파일 권한을 640으로 변경

chmod 640 /etc/ftpusers 또는 # chmod 640 /etc/ftpd/ftpusers

Step 5) /etc(/ftpd)/ftpusers 파일에 FTP 서비스에 접근을 차단할 사용자 설정

[vsFTP – ftpusers]

Step 1) userlist_enable 설정값 확인

```
# cat /etc/vsftpd.conf | grep userlist_enable 또는 # cat /etc/vsftpd/vsftpd.conf | grep userlist_enable”  
userlist_enable = NO
```

Step 2) 파일 소유자 및 권한 확인

```
# ls -l /etc/vsftpd.ftpusers 또는 # ls -l /etc/vsftpd/ftpusers
```

Step 3) 접근 제한 설정 확인

```
# cat /etc/vsftpd.ftpusers 또는 # cat /etc/vsftpd/ftpusers
```

Step 4) 파일 소유자를 root로 변경

```
# chown root /etc/vsftpd.ftpusers 또는 # chown root /etc/vsftpd/ftpuser
```

Step 5) 파일 권한을 640으로 변경

```
# chmod 640 /etc/vsftpd.ftpusers 또는 # chmod 640 /etc/vsftpd/ftpusers
```

Step 6) /etc/vsftpd.ftpusers 또는 /etc/vsftpd/ftpusers 파일에 FTP 서비스에 접근을 차단할 사용자 설정

[vsFTP – user_list]

Step 1) userlist_enable 설정값 확인

```
# cat /etc/vsftpd.conf | grep userlist_enable 또는 # cat /etc/vsftpd/vsftpd.conf | grep userlist_enable  
userlist_enable = YES
```

Step 2) 파일 소유자 및 권한 확인

```
# ls -l /etc/vsftpd.user_list 또는 # ls -l /etc/vsftpd/user_list
```

Step 3) 접근 제한 설정 확인

```
# cat /etc/vsftpd.user_list 또는 # cat /etc/vsftpd/user_list
```

Step 4) 파일 소유자를 root로 변경

```
# chown root /etc/vsftpd.user_list 또는 # chown root /etc/vsftpd/user_list
```

Step 5) 파일 권한을 640으로 변경

```
# chmod 640 /etc/vsftpd.user_list 또는 # chmod 640 /etc/vsftpd/user_list
```

Step 6) /etc(/vsftpd)/vsftpd.conf 파일의 userlist_deny 옵션 설정

user_list에 등록된 사용자만 접속 허가 : userlist_deny=no

user_list에 등록된 사용자 접속 차단 : userlist_deny=yes

Step 7) /etc(/vsftpd)/vsftpd.conf 파일에 FTP 서비스에 접근을 허가/차단할 사용자 설정

[ProFTP – ftpusers]

Step 1) UseFtpUsers 설정 확인

```
# cat /etc/proftpd.conf | grep UseFtpUsers 또는 # cat /etc/proftpd/proftpd.conf | grep UseFtpUsers
UseFtpUsers on (기본 설정 : on)
```

Step 2) 파일 소유자 및 권한 확인

```
# ls -l /etc/ftpusers 또는 # ls -l /etc/ftpd/ftpusers
```

Step 3) 접근 제한 설정 확인

```
# cat /etc/ftpusers 또는 # cat /etc/ftpd/ftpusers
```

Step 4) 파일 소유자를 root로 변경

```
# chown root /etc/ftpusers 또는 # chown root /etc/ftpd/ftpusers
```

Step 5) 파일 권한을 640으로 변경

```
# chmod 640 /etc/ftpusers 또는 # chmod 640 /etc/ftpd/ftpusers
```

Step 6) /etc/(/ftpd)ftpusers 파일에 FTP 서비스에 접근을 차단할 사용자 설정

[ProFTP – proftpd.conf]

Step 1) UseFtpUsers 설정 확인

```
# cat /etc/proftpd.conf | grep UseFtpUsers 또는 # cat /etc/proftpd/proftpd.conf | grep UseFtpUsers
UseFtpUsers off
```

Step 2) 파일 소유자 및 권한 확인

```
# cat /etc/proftpd.conf 또는 # cat /etc/proftpd/proftpd.conf
```

Step 3) 접근 제한 설정 확인

```
# sed -n '/<Limit LOGIN>/,/<\Limit>/p' /etc/proftpd.conf 또는 # sed -n '/<Limit LOGIN>/,/<\Limit>/p'
/etc/proftpd/proftpd.conf
```

Step 4) 파일 소유자를 root로 변경

```
# chown root /etc/proftpd.conf 또는 # chown root /etc/proftpd/proftpd.conf
```

Step 5) 파일 권한을 640으로 변경

```
# chmod 640 /etc/proftpd.conf 또는 # chmod 640 /etc/proftpd/proftpd.conf
```

Step 6) /etc(/proftpd)/proftpd.conf 파일 수정 및 삽입

```
<Limit LOGIN>
```

```
Order Deny,Allow
```

```
AllowUser <사용자 이름> 또는 Allow from <IP주소>
```

DenyUser <사용자 이름> 또는 Deny from <IP주소>
</Limit>

Step 7) ProFTP 서비스 재시작

※ Order : 먼저 정의된 설정 우선 적용

U-57 (중)	UNIX > 3. 서비스 관리
	Ftpusers 파일 설정
개요	
점검 내용	FTP 서비스에 root 계정 접근 제한 설정 여부 점검
점검 목적	root 계정의 FTP 직접 접속을 제한하여 root 비밀번호 정보 노출을 방지하기 위함
보안 위협	FTP 서비스에 root 계정으로 접근할 경우, 데이터가 평문으로 전송되어 비인가자가 스니핑을 통해 관리자 계정 및 중요 정보를 외부로 유출할 위험이 존재함
참고	※ 기반시설 시스템에서 FTP 서비스의 이용은 원칙적으로 금지하나, 불가피하게 사용 시 root 계정 접근 제한 등의 보안 조치를 반드시 적용해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : root 계정 접속을 차단한 경우
	취약 : root 계정 접속을 허용한 경우
조치 방법	- FTP 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 - FTP 서비스 사용 시 root 계정으로 직접 접속할 수 없도록 설정
조치 시 영향	애플리케이션에서 root 계정으로 직접 접속하여 FTP를 사용하고 있는 경우 확인 필요

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

[기본 FTP – ftpusers]

Step 1) root 계정 접근 제한 설정 확인

```
# cat /etc/ftpusers 또는 # cat /etc/ftpd/ftpusers
```

Step 2) /etc(/ftpd)/ftpusers 파일의 설정값 변경(#root 주석 제거)

[vsFTP – ftpusers]

Step 1) userlist_enable 설정 확인

```
# cat /etc/vsftpd.conf | grep userlist_enable 또는 # cat /etc/vsftpd/vsftpd.conf | grep userlist_enable
userlist_enable = NO
```

Step 2) root 계정 접근제한 설정 확인

```
# cat /etc/ftpusers 또는 # cat /etc/vsftpd/ftpusers
```

Step 3) /etc/vsftpd.ftpusers 또는 /etc/vsftpd/ftpusers 파일의 설정값 변경(#root 주석 제거)

[vsFTP – user_list]

Step 1) userlist_enable 설정 확인

```
# cat /etc/vsftpd.conf | grep userlist_enable 또는 # cat /etc/vsftpd/vsftpd.conf | grep userlist_enable”  
userlist_enable = YES
```

Step 2) root 계정 접근제한 설정 확인

```
# cat /etc/vsftpd.user_list 또는 # cat /etc/vsftpd/user_list
```

Step 3) /etc/vsftpd.user_list 또는 /etc/vsftpd/user_list 파일의 설정값 변경(#root 주석 제거)

※ vsftpd.conf 파일에서 user_list deny 옵션이 yes로 설정된 경우에만 root 계정 차단이 적용됨

[ProFTP – ftpusers]

Step 1) UseFtpUsers 설정 확인

```
# cat /etc/proftpd.conf | grep UseFtpUsers 또는 # cat /etc/proftpd/proftpd.conf | grep UseFtpUsers  
UseFtpUsers on (기본 설정 : on)
```

Step 2) root 계정 접근제한 설정 확인

```
# cat /etc/ftpusers 또는 # cat /etc/ftpd/ftpuser
```

Step 3) /etc(/ftpd)/ftpusers 파일의 설정값 변경(#root 주석 제거)

[ProFTP – proftpd.conf]

Step 1) UseFtpUsers 설정 확인

```
# cat /etc/proftpd.conf | grep UseFtpUsers 또는 # cat /etc/proftpd/proftpd.conf | grep UseFtpUser  
UseFtpUsers off
```

Step 2) root 계정 접근제한 설정 확인

```
# cat /etc/proftpd.conf | grep RootLogin 또는 # cat /etc/proftpd/proftpd.conf | grep RootLogin
```

Step 3) /etc(/proftpd)/proftpd.conf 파일의 설정값 변경

```
RootLogin off
```

Step 4) ProFTP 서비스 재시작

```
# systemctl restart proftpd
```

01. Unix 서버

U-58 (중)	UNIX > 3. 서비스 관리
	불필요한 SNMP 서비스 구동 점검
개요	
점검 내용	SNMP 서비스 활성화 여부 점검
점검 목적	불필요한 SNMP 서비스를 비활성화하여 필요 이상의 정보가 노출되는 것을 방지하기 위함
보안 위협	SNMP 서비스가 활성화되어 있을 경우, 비인가자가 시스템의 중요 정보를 유출하거나 불법적으로 수정할 위험이 존재함
참고	※ SNMP(Simple Network Management Protocol) : TCP/IP 기반 네트워크상의 각 호스트에서 정기적으로 여러 정보를 자동으로 수집하여 네트워크 관리를 하기 위한 프로토콜을 의미함 ※ 기반시설 시스템에서 SNMP 서비스의 이용은 원칙적으로 금지하나, 불가피하게 사용 시 기본 Community String 변경, 네트워크 모니터링 등의 보안 조치를 반드시 적용해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : SNMP 서비스를 사용하지 않는 경우
	취약 : SNMP 서비스를 사용하는 경우
조치 방법	SNMP 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS(5.9 이하 버전)

Step 1) SNMP 서비스 활성화 여부 및 경로 확인

```
# ps -ef | grep snmp
```

Step 2) 서비스 중지 및 이름 변경

```
# /etc/init.d/init.snmpdx stop
```

```
# mv /etc/rc3.d/S76snmpdx /etc/rc3.d/_S76snmpdx
```

※ rc*/_S**snmpdx 의 *수치는 각각 다름

● SOLARIS(5.10 이상 버전)

Step 1) SNMP 서비스 활성화 여부 확인

```
# svcs -a | grep snmp
```

Step 2) 불필요한 SNMP 서비스가 활성화 중인 경우 데몬 중지

```
# svcadm disable svc:/application/management/snmpd:default
```

● LINUX

Step 1) SNMP 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep snmpd
```

Step 2) 불필요한 SNMP 서비스가 활성화(loaded active running)인 경우 서비스 중지 및 비활성화

```
# systemctl stop snmpd
```

```
# systemctl disable snmpd
```

● AIX

Step 1) SNMP 서비스 활성화 여부 확인

```
# lssrc -a | grep snmp
```

Step 2) 불필요한 SNMP 서비스가 활성화(active) 중인 경우 서비스 중지

```
# stopsrc -s snmpd
```

Step 3) /etc/rc.tcpip 파일 내에 SNMP설정값 주석 처리

```
# start /usr/sbin/snmpd $src_running
```

Step 4) 설정 적용

```
# /etc/rc.tcpip
```

● HP-UX

Step 1) SNMP 서비스 활성화 여부 확인

```
# ps -ef | grep snmp
```

Step 2) 불필요한 SNMP 서비스가 활성화(active) 중인 경우 서비스 중지

```
# /sbin/init.d/snmpd stop
```

U-59 (상)	UNIX > 3. 서비스 관리
	안전한 SNMP 버전 사용
개요	
점검 내용	안전한 SNMP 버전 사용 여부 점검
점검 목적	안전한 SNMP 버전 사용으로 전송되는 데이터를 보호하기 위함
보안 위협	SNMP 버전이 기준보다 낮을 경우, 응답 패킷이 평문으로 전송되어 스니핑 위험이 존재함
참고	※ SNMP(Simple Network Management Protocol) : TCP/IP 기반 네트워크상의 각 호스트에서 정기적으로 여러 정보를 자동으로 수집하여 네트워크 관리를 하기 위한 프로토콜을 의미하며 v1, v2, v3 세 가지 버전이 존재하는데 v1, v2는 요청 및 응답 패킷이 평문으로 전송되기 때문에 스니핑이 가능하지만 v3 이상부터는 HMAC-MD5 또는 HMAC-SHA 알고리즘 기반의 인증을 제공함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : SNMP 서비스를 v3 이상으로 사용하는 경우
	취약 : SNMP 서비스를 v2 이하로 사용하는 경우
조치 방법	• SNMP 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 • SNMP 서비스 사용 시 SNMP 버전을 v3 이상으로 적용하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) SNMP v3 사용 여부 확인

```
# snmpwalk -v3 -l authPriv -u <사용자 이름> -a <사용자 인증 프로토콜> -A <사용자 인증 암호> -x <사용자 암호화 프로토콜> -X <사용자 암호화 암호> <SNMP 서버 IP주소>
(SHA 인증 프로토콜, AES 암호화 프로토콜 사용 예시)
```

```
# snmpwalk -v3 -l authPriv -u myuser -a SHA -A myauthpass -x AES -X myprivpass 192.168.18.190
```

Step 2) 사용하지 않을 경우 snmp v3 사용자 생성

```
# net-snmp-create-v3-user -ro -A <사용자 인증 암호> -X <사용자 암호화 암호> -a <사용자 인증 프로토콜> -x <사용자 암호화 프로토콜> <사용자 이름>
```

```
예시) # net-snmp-create-v3-user -ro -A myauthpass -X myprivpass -a SHA -x AES myuser
```

Step 3) /etc/snmp/snmpd.conf 파일 내의 SNMPv3 사용자 추가

```
# createUser <사용자 이름> <사용자 인증 프로토콜> <사용자 인증 암호> <사용자 암호화 프로토콜>  
<사용자 암호화 암호>
```

SHA 인증 프로토콜, AES 암호화 프로토콜 사용 예시)

```
# createUser myuser SHA myauthpass AES myprivpass
```

Step 4) SNMPv3 사용자 읽기/쓰기 권한 추가

```
<읽기/쓰기 권한> <사용자 이름>
```

```
# rouser myuser
```

Step 5) SNMP 서비스 실행

01. Unix 서버

U-60 (중)	UNIX > 3. 서비스 관리
	SNMP Community String 복잡성 설정
개요	
점검 내용	SNMP Community String 복잡성 설정 여부 점검
점검 목적	SNMP 서비스의 Community String의 복잡성 설정을 통해 비인가자의 비밀번호 추측 공격에 대비하기 위함
보안 위협	Community String에 복잡성 설정이 되어 있지 않을 경우, 비인가자가 비밀번호 추측 공격을 통해 계정 탈취 시 환경설정 파일 열람 및 수정, 각종 정보수집, 관리자 권한 획득 등 다양한 위협이 존재함
참고	※ NMS(Network Management System) : 네트워크상의 모든 장비의 중앙 감시 체제를 구축하여 모니터링, 플래닝, 분석을 시행하고 관련 데이터를 보관하여 필요 즉시 활용할 수 있게 하는 관리 시스템을 말함 ※ Community String : SNMP는 MIB라는 정보를 주고받기 위해 인증 과정에서 일종의 비밀번호인 Community String을 사용함 ※ 기반시설 시스템에서 SNMP 서비스의 이용은 원칙적으로 금지하나, 불가피하게 사용 시 기본 Community String 변경, 네트워크 모니터링 등의 보안 조치를 반드시 적용해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : SNMP Community String 기본값인 “public”, “private”이 아닌 영문자, 숫자 포함 10자리 이상 또는 영문자, 숫자, 특수문자 포함 8자리 이상인 경우 ※ SNMP v3의 경우 별도 인증 기능을 사용하고, 해당 비밀번호가 복잡도를 만족하는 경우 양호
	취약 : 아래의 내용 중 하나라도 해당되는 경우 1. SNMP Community String 기본값인 “public”, “private”일 경우 2. 영문자, 숫자 포함 10자리 미만인 경우 3. 영문자, 숫자, 특수문자 포함 8자리 미만인 경우
조치 방법	• SNMP 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 • SNMP 서비스 사용 시 SNMP Community String 기본값인 “public”, “private”이 아닌 영문자, 숫자 포함 10자리 이상 또는 영문자, 숫자, 특수문자 포함 8자리 이상으로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS(9 이하 버전)

Step 1) /etc/snmp/conf/snmpd.conf 파일 내의 Community String 설정 값 수정

read-community <변경 값>

```
write-community <변경 값>
```

Step 2) SNMP 서비스 재시작

● SOLARIS(10 버전)

Step 1) /etc/snmp/conf/snmpd.conf 파일 내의 Community String 설정 값 수정

```
rocommunity <변경 값>
```

```
rwcommunity <변경 값>
```

Step 2) 출력여부 확인

```
# svcs -a | grep snmpdx
```

```
예시) svcadm enable svc:/application/management/snmpdx:default
```

● SOLARIS(11 버전)

Step 1) /etc/net-snmp/snmp/snmpd.conf 파일 내의 Community String 설정 값 수정

```
rocommunity <변경 값> default
```

```
rwcommunity <변경 값> default
```

Step 2) 설정 적용 및 SNMP 서비스 재시작

```
# svcadm refresh net-snmp
```

● LINUX

[Redhat 계열]

Step 1) /etc/snmp/snmpd.conf 파일 내의 Community String 설정 값 수정

```
com2sec notConfigUser default <변경 값>
```

Step 2) 설정 적용 및 SNMP 서비스 재시작

```
# systemctl restart snmpd
```

[Debian 계열]

Step 1) /etc/snmp/snmpd.conf 파일 내의 Community String 설정 값 수정

```
rocommunity <변경 값> default
```

```
rwcommunity <변경 값> default
```

Step 2) 설정 적용 및 SNMP 서비스 재시작

```
# systemctl restart snmpd
```

- AIX

Step 1) /etc/snmpdv3.conf 파일 내의 Community String 설정 값 수정

```
COMMUNITY <새로운 Community String> <새로운 Community String> noAuthNoPriv 0.0.0.0 0.0.0.0 -
```

Step 2) SNMP 서비스 중지 및 실행

```
# stopsrc -s snmpd
```

```
# startsrc -s snmpd
```

- HP-UX

Step 1) /etc/snmpd.conf 파일 내의 Community String 설정 값 수정

```
get-community-name : <변경 값>
```

```
set-community-name : <변경 값>
```

Step 2) SNMP 서비스 재시작

U-61 (상)	UNIX > 3. 서비스 관리
	SNMP Access Control 설정
개요	
점검 내용	SNMP 접근 제어 설정 여부 점검
점검 목적	SNMP 접근 제어 설정을 통해 비인가자의 접근을 차단하기 위함
보안 위협	SNMP 서비스에 접근 제어가 설정되어 있지 않을 경우, 비인가자의 접근, 네트워크 정보 유출, 시스템 및 네트워크 설정 변경, DoS 공격 등의 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : SNMP 서비스에 접근 제어 설정이 되어 있는 경우
	취약 : SNMP 서비스에 접근 제어 설정이 되어 있지 않은 경우
조치 방법	• SNMP 서비스를 사용하지 않는 경우 서비스 중지 및 비활성화 설정 • SNMP 서비스 사용 시 SNMP 접근 제어 설정하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

Step 1) /etc/net-snmp/snmp/snmpd.conf 파일 내의 SNMP 접근 제어 설정

rocommunity <String값> <허용할 네트워크 주소 추가>

rwcommunity <String값> <허용할 네트워크 주소 추가>

Step 2) 설정 적용 및 SNMP 서비스 재시작

svcadm restart net-snmp

● LINUX

[Redhat 계열]

Step 1) /etc/snmp/snmpd.conf 파일 내의 SNMP 접근 제어 설정

com2sec notConfigUser <허용할 네트워크 주소 추가> <String값>

Step 2) 설정 적용 및 SNMP 서비스 재시작

systemctl restart snmpd

[Debian 계열]

Step 1) /etc/snmp/snmpd.conf 파일 내의 SNMP 접근 제어 설정

rocommunity <String값> <허용할 네트워크 주소 추가>

rwcommunity <String값> <허용할 네트워크 주소 추가>

Step 2) 설정 적용 및 SNMP 서비스 재시작

systemctl restart snmpd

● **AIX**

Step 1) /etc/snmpdv3.conf 파일 내의 SNMP 접근 제어 설정

COMMUNITY <String값> <String값> noAuthNoPriv <허용할 네트워크 주소> <허용할 넷마스크 주소>

Step 2) SNMP 서비스 중지 및 실행

stopsrc -s snmpd

startsrc -s snmpd

● **HP-UX**

Step 1) /etc/snmpd.conf 파일 내의 SNMP 접근 제어 설정

trap-dest : <허용할 네트워크 주소 추가>

Step 2) SNMP 서비스 재시작

U-62 (하)	UNIX > 3. 서비스 관리
	로그인 시 경고 메시지 설정
개요	
점검 내용	서버 및 서비스에 로그인 시 불필요한 정보 차단 설정 및 불법적인 사용에 대한 경고 메시지 출력 여부 점검
점검 목적	비인가자들에게 서버에 대한 불필요한 정보를 제공하지 않고, 서버 접속 시 관계자만 접속해야 한다는 경각심을 심어 주기 위함
보안 위협	로그온 시 경고 메시지가 설정되어 있지 않을 경우, 기본 설정값엔 서버 OS 버전 및 서비스 버전이 비인가자들에게 노출되어 해당 정보를 통해 서비스의 취약점을 이용하여 공격을 시도할 위험이 존재함
참고	※ 로그인 시 경고 메시지는 공격자의 활동을 주시하고 있다는 생각을 상기시킴으로써 간접적으로 공격 피해를 감소시키는 효과를 줄 수 있음
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 서버 및 Telnet, FTP, SMTP, DNS 서비스에 로그인 시 경고 메시지가 설정된 경우
	취약 : 서버 및 Telnet, FTP, SMTP, DNS 서비스에 로그인 시 경고 메시지가 설정되어 있지 않은 경우
조치 방법	Telnet, FTP, SMTP, DNS 서비스를 사용하는 경우 설정 파일을 통해 로그인 시 경고 메시지 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

[서버]

Step 1) /etc/motd 파일과 /etc/issue 파일 내에 로그인 시 경고 메시지 입력

[Telnet]

Step 1) /etc/issue.net 파일 내에 로그인 시 경고 메시지 입력

Step 2) /etc/default/telnetd 파일 내에 배너 경고 메시지 수정

BANNER=<로그온 시 경고 메시지>

[SSH]

Step 1) /etc/motd 파일 내 로그인 시 경고 메시지 입력

Step 2) /etc/ssh/sshd_config 파일 내에 배너 경고 메시지 수정

Banner <경고 메시지가 작성된 파일 경로>

- Step 3) <SSH Banner 설정 파일 경로> 파일 내에 로그인 경고 메시지 수정
(일반적으로 /etc/issue 또는 /etc/issue.net 파일 사용)

[Sendmail]

- Step 1) /etc/mail/sendmail.cf 파일 내에 SmtgGreetingMessage 로그인 경고 메시지 수정

SmtgGreetingMessage=<로그온 시 경고 메시지>

- Step 2) 설정 적용 및 재시작

svcadm refresh sendmail

[Postfix]

- Step 1) /etc/postfix/main.cf 파일 내에 SMTP 서버 로그인 경고 메시지 수정

smtpd_banner = <로그온 시 경고 메시지>

- Step 2) 설정 적용 및 재시작

svcadm refresh postfix

[Exim]

- Step 1) /exim/exim.conf 파일 내에 SMTP 서버 로그인 경고 메시지 수정

smtp_banner = <로그온 시 경고 메시지>

- Step 2) 설정 적용 및 재시작

svcadm refresh exim

[기본 FTP]

- Step 1) /etc/default/ftpd 파일 내에 경고 메시지 수정

BANNER="<로그온 시 경고 메시지>"

[vsFTP]

- Step 1) /etc/vsftpd/vsftpd.conf 파일 내에 FTP 서버 로그인 경고 메시지 수정

ftpd_banner=<변경할 배너>

- Step 2) 설정 적용 및 재시작

svcadm refresh vsftpd

[ProFTP]

Step 1) /etc/proftpd/proftpd.conf 파일 내에 welcome.msg 파일 경로 확인 및 수정

DisplayLogin <welcome.msg 파일 경로>

Step 2) <welcome.msg 파일 경로> 파일 내에 설정된 FTP 서버 로그인 경고 메시지 수정

Step 3) 설정 적용 및 재시작

svcadm refresh proftpd

● LINUX

[서버]

Step 1) /etc/motd, /etc/issue 파일 내에 경고 메시지 수정

[Telnet]

Step 1) /etc/issue.net 파일 내에 로그인 경고 메시지 수정

[SSH]

Step 1) /etc/ssh/sshd_config 파일 내에 설정된 배너 경고 메시지 파일 경로 확인 및 수정

Banner /etc/issue.net <경고 메시지가 작성된 파일 경로>

Step 2) <SSH 배너 설정 파일 경로> 파일 내에 경고 메시지 수정

(일반적으로 /etc/issue 또는 /etc/issue.net 파일 사용)

Step 3) 설정 적용 및 재시작

systemctl restart sshd

[Sendmail]

Step 1) /etc/mail/sendmail.cf 파일 내에 설정된 SMTP 서버 로그인 시 경고 메시지 수정

SmtpGreetingMessage=<경고 메시지>

Step 2) 설정 적용 및 재시작

systemctl restart sendmail

[Postfix]

Step 1) /etc/postfix/main.cf 파일 내에 설정된 SMTP 서버 로그인 시 경고 메시지 수정

smtpd_banner = <경고 메시지>

Step 2) 설정 적용 및 재시작

```
# systemctl restart postfix
```

[Exim]

Step 1) /exim/exim.conf 또는 /exim4/exim4.conf 파일 내에 설정된 SMTP 서버 로그인 시 경고 메시지 수정

Step 2) /exim/exim.conf 또는 /exim4/exim4.conf 파일 내에 설정된 SMTP 경고 메시지 수정

```
smtp_banner = <경고 메시지>
```

Step 3) 설정 적용 및 재시작

```
# systemctl restart exim
```

[vsFTP]

Step 1) /etc/vsftpd.conf 또는 /etc/vsftpd/vsftpd.conf 파일 내에 설정된 FTP 서버 로그인 시 경고 메시지 수정

```
ftpd_banner=<경고 메시지>
```

Step 2) 설정 적용 및 재시작

```
# systemctl restart vsftpd
```

[ProFTP]

Step 1) /etc/proftpd.conf 또는 /etc/proftpd/proftpd.conf 파일 내에 설정된 welcome.msg 파일 경로 확인 및 수정

```
DisplayLogin <welcome.msg 파일 경로>
```

Step 2) <welcome.msg 파일 경로> 파일 내에 설정된 FTP 서버 로그인 시 경고 메시지 수정

Step 3) 설정 적용 및 재시작

```
# systemctl restart proftpd
```

[DNS]

Step 1) /etc/named.conf 또는 /etc/bind/named.conf.options 파일 내에 설정된 경고 메시지 수정

```
version <경고 메시지>;
```

Step 2) 설정 적용 및 재시작

```
# systemctl restart named
```

● AIX

[서버]

Step 1) /etc/motd, /etc/issue 파일 내에 설정된 서버 로그인 경고 메시지 수정

[Telnet]

Step 1) /etc/security/login.cfg 파일 내에 설정된 경고 메시지 수정

default:

~~이하 생략~~

herald=<경고 메시지>

[SSH]

Step 1) /etc/ssh/sshd_config 파일 내에 설정된 경고 메시지 파일 경로 확인 및 수정

Banner <경고 메시지가 작성된 파일 경로>

Step 2) <SSH 배너 설정 파일 경로> 파일 내에 설정된 경고 메시지 수정

(일반적으로 /etc/issue 또는 /etc/issue.net 파일 사용)

Step 3) SSH 서비스 중지 및 실행

stopsrc -s sshd

startsrc -s sshd

[Sendmail]

Step 1) /etc/mail/sendmail.cf 파일 내에 설정된 SMTP 서버 로그인 시 경고 메시지 수정

SmtpGreetingMessage=<경고 메시지>

Step 2) Sendmail 서비스 중지 및 실행

stopsrc -s sendmail

startsrc -s sendmail

[Postfix]

Step 1) /etc/postfix/main.cf 파일 내에 설정된 SMTP 서버 로그인 시 경고 메시지 수정

smtpd_banner = <경고 메시지>

Step 2) Postfix 서비스 재시작

kill -1 <PID>

[Exim]

Step 1) /exim/exim.conf 파일 내에 설정된 SMTP 서버 로그인 시 경고 메시지 수정

```
smtp_banner = <경고 메시지>
```

Step 2) Exim 서비스 재시작

```
# kill -1 <PID>
```

[기본 FTP]

Step 1) 메시지 카탈로그 파일 생성

```
# dspcat -g /usr/lib/nls/msg/en_US/ftpd.cat > /tmp/ftpd.msg
```

Step 2) /tmp/ftpd.msg 파일 내에 설정된 FTP 서버 로그인 시 경고 메시지 수정

```
<변경할 배너>
```

Step 3) ftpd.cat 파일 생성

```
# gencat /usr/lib/nls/msg/en_US/ftpd.cat /tmp/ftpd.msg
```

[vsFTP]

Step 1) /etc/vsftpd.conf 파일 내에 설정된 FTP 서버 로그인 시 경고 메시지 수정

```
ftpd_banner=<경고 메시지>
```

Step 2) vsFTP 서비스 재시작

```
# kill -1 <PID>
```

[ProFTP]

Step 1) /etc/proftpd.conf 파일 내에 설정된 welcome.msg 파일 경로 확인 및 수정

```
DisplayLogin <welcome.msg 파일 경로>
```

Step 2) <welcome.msg 파일 경로> 파일 내에 설정된 FTP 서버 로그인 시 경고 메시지 수정

Step 3) ProFTP 서비스 재시작

```
# kill -1 <PID>
```

[DNS]

Step 1) /etc/named.conf 파일 내에 설정된 경고 메시지 수정

```
version <경고 메시지>;
```

Step 2) DNS 서비스 중지 및 실행

```
# stopsrc -s named
```

```
# startsrc -s named
```

● HP-UX

[서버]

Step 1) /etc/motd, /etc/issue 파일 내에 설정된 로그인 경고 메시지 수정

[Telnet]

Step 1) /etc/inetd.conf 파일 내에 설정된 경고 메시지 파일 경로 확인 및 수정

```
telnet stream tcp6 nowait root /usr/sbin/telnetd telnetd -b /etc/issue 또는 <Telnet 배너 설정 파일 경로>
```

Step 2) <Telnet 배너 설정 파일 경로> 파일 내에 설정된 경고 메시지 수정

(일반적으로 /etc/issue 파일 사용)

Step 3) inetd 설정 적용

```
# inetd -c
```

[SSH]

Step 1) /etc/ssh/sshd_config 파일 내에 설정된 경고 메시지 파일 경로 확인 및 수정

```
Banner <경고 메시지가 작성된 파일 경로>
```

Step 2) <SSH 배너 설정 파일 경로> 파일 내에 설정된 경고 메시지 수정

(일반적으로 /etc/issue 또는 /etc/issue.net 파일 사용)

Step 3) SSH 서비스 재시작

```
# kill -1 <PID>
```

[Sendmail]

Step 1) /etc/mail/sendmail.cf 파일 내에 설정된 SMTP 서버 로그인 시 경고 메시지 수정

```
SmtpGreetingMessage=<경고 메시지>
```

Step 2) Sendmail 서비스 재시작

```
# kill -1 <PID>
```

[Postfix]

Step 1) /etc/postfix/main.cf 파일 내에 설정된 SMTP 서버 로그인 시 경고 메시지 수정

```
smtpd_banner = <경고 메시지>
```

Step 2) Postfix 서비스 재시작

```
# kill -1 <PID>
```

[Exim]

Step 1) /exim/exim.conf 파일 내에 설정된 SMTP 서버 로그인 시 경고 메시지 수정

```
smtp_banner = <경고 메시지>
```

Step 2) Exim 서비스 재시작

```
# kill -1 <PID>
```

[기본 FTP]

Step 1) /etc/inetd.conf 파일 내에 설정된 FTP 설정 파일 경로 확인 및 수정

```
ftp stream tcp nowait root /usr/sbin/ftpd ftpd -a /etc/ftpd/ftpaccess
```

Step 2) <기본 FTP 배너 설정 파일 경로> 파일 내에 경고 메시지 수정

Step 3) /etc/ftpd/ftpaccess 파일 내에 설정값 수정

[Wu-ftp v2.4 미만인 경우]

```
suppresshostname yes
```

```
suppressversion yes
```

```
banner <경고 메시지가 작성된 파일 경로>
```

[Wu-ftp v2.4 이상인 경우]

```
greeting terse
```

```
banner <경고 메시지가 작성된 파일 경로>
```

```
# cp /usr/newconfig/etc/ftpd/examples/ftpaccess /etc/ftpd/ftpaccess
```

Step 4) inetd 설정 적용

```
# inetd -c
```

[vsFTP]

Step 1) /etc/vsftpd.conf 파일 내에 설정된 FTP 서버 로그인 시 경고 메시지 수정

```
ftpd_banner=<경고 메시지>
```

Step 2) vsFTP 서비스 재시작

```
# kill -1 <PID>
```

[ProFTP]

Step 1) /etc/proftpd.conf 파일 내에 설정된 welcome.msg 파일 경로 확인 및 수정

```
DisplayLogin <welcome.msg 파일 경로>
```

Step 2) <welcome.msg 파일 경로> 파일 내에 설정된 FTP 서버 로그인 시 경고 메시지 수정

Step 3) ProFTP 서비스 재시작

```
# kill -1 <PID>
```

[DNS]

Step 1) /etc/named.conf 파일 내에 설정된 경고 메시지 확인

```
version <경고 메시지>;
```

Step 2) DNS 서비스 실행

```
# kill -1 <PID>
```

01. Unix 서버

U-63 (중)	UNIX > 3. 서비스 관리
	sudo 명령어 접근 관리
개요	
점검 내용	/etc/sudoers 파일 권한 적절성 여부 점검
점검 목적	비인가자가 관리자 권한을 남용하여 시스템 손상, 악성 코드 실행, 민감한 데이터 유출 등의 보안 위협을 방지하기 위함
보안 위협	sudo 명령어 접근을 제한하지 않을 경우, 비인가자가 관리자 권한으로 허가되지 않은 명령어를 사용하여 루트 권한 오용, 악성 코드 실행, 데이터 유출 등의 시도를 할 위험이 존재함
참고	※ sudo(SuperUser DO): root 권한으로 명령어를 실행함 ※ /etc/sudoers: sudo 명령을 사용하여 다른 명령을 실행할 수 있는 사용자를 지정하는 파일
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : /etc/sudoers 파일 소유자가 root이고, 파일 권한이 640인 경우
	취약 : /etc/sudoers 파일 소유자가 root가 아니거나, 파일 권한이 640을 초과하는 경우
조치 방법	/etc/sudoers 파일 소유자 및 권한 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) /etc/sudoers 파일 소유자 및 권한 확인

ls -l /etc/sudoers

Step 2) /etc/sudoers 파일 소유자를 root, 권한 640으로 변경

chown root /etc/sudoers

chmod 640 /etc/sudoer

Step 3) s

U-64 (상)	UNIX > 4. 패치 관리
	주기적 보안 패치 및 벤더 권고사항 적용
개요	
점검 내용	시스템에서 최신 패치가 적용 여부 점검
점검 목적	주기적인 패치 적용을 통해 시스템 안정성 및 보안성을 확보하기 위함
보안 위협	최신 보안패치가 적용되지 않을 경우, 이미 알려진 취약점을 통하여 공격자에 의해 시스템 침해사고 발생할 위험이 존재함
참고	※ 최신 버전의 Kernel을 사용하도록 권고하고 있으나, 시스템 운영상 적용이 어려운 경우 최신 버전이 아닌 취약점이 존재하지 않는 Kernel 버전도 허용하고 있음
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 패치 적용 정책을 수립하여 주기적으로 패치 관리를 하고 있으며, 패치 관련 내용을 확인하고 적용하였을 경우
	취약 : 패치 적용 정책을 수립하지 않고 주기적으로 패치 관리를 하지 않거나, 패치 관련 내용을 확인하지 않고 적용하지 않고 있는 경우
조치 방법	OS 관리자, 서비스 개발자가 패치 적용에 따른 서비스 영향 정도를 파악하여 OS 관리자 및 벤더에서 적용하도록 설정 ※ OS 패치의 경우 지속해서 취약점이 발표되고 있으므로 O/S 관리자, 서비스 개발자가 패치 적용에 따른 서비스 영향 정도를 정확히 파악하여 주기적인 패치 적용 정책을 수립하여 적용해야 함
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

[Oracle support이 존재하지 않는 경우]

Step 1) IFO에 'i'가 있는 곳에 설치된 패키지 확인

```
# pkg list -af entire | head -5 IFO
```

예시)	NAME (PUBLISHER)	VERSION	IFO
	entire	11.4-11.4.42.0.0.11.0	i--
	entire	11.4-11.4.0.0.1.15.0	---
	entire	0.5.11-0.175.3.1.0.5.3	---
	entire	0.5.11-0.175.3.1.0.5.2	---

Step 2) 최신 패키지 확인

```
# pkg list -af entire@latest
```

예시) NAME (PUBLISHER)	VERSION	IFO
entire	11.4-11.4.42.0.0.11.0	i--

Step 3) OS 버전으로 업데이트 후 재부팅

```
# pkg update --accept
```

[Oracle support이 존재하는 경우]

Step 1) IFO에 'i' 가 있는 곳에 설치된 패키지 확인

```
# pkg list -af entire | head -5
```

예시) NAME (PUBLISHER)	VERSION	IFO
entire	11.4-11.4.42.0.0.11.0	i--
entire	11.4-11.4.0.0.1.15.0	---
entire	0.5.11-0.175.3.1.0.5.3	---
entire	0.5.11-0.175.3.1.0.5.2	---

Step 2) 최신 패키지 확인

```
# pkg list -af entire@latest
```

예시) NAME (PUBLISHER)	VERSION	IFO
entire	11.4-11.4.42.0.0.11.0	i--

Step 3) 업데이트 프리뷰

```
# pkg update -nv entire@버전 이름
```

Step 4) 업데이트 후 재부팅

```
# pkg update --accept entire@버전 이름
```

※ Oracle support 있는지 구분하려면 pkg publisher 명령어를 사용하여 support 리포지토리(repository)가 있어야

<https://pkg.oracle.com/solaris/support/>

※ Oracle support 없으면 분기별로만 업데이트가 가능함

※ Oracle support 있다면 매달 업데이트(SRU)와 Critical Patch Updates가 support 리포지토리에 담겨 있음

※ Critical Patch Updates에 대하여 자세한 사항은 아래 링크 참고

<https://docs.oracle.com/en/operating-systems/solaris/oracle-solaris/11.4/update-sys-add-sw/critical-patch-updates-packages.html>

※ 자세한 Oracle support 내용은 아래 링크 참고

<https://docs.oracle.com/en/operating-systems/solaris/oracle-solaris/11.4/update-sys-add-sw/accessing-support-updates.html>

● LINUX

Step 1) OS 및 커널 버전 확인

```
# hostnamectl
```

Step 2) EOL 상태가 아닌 Linux OS 버전으로 업데이트

Step 3) 최신 보안 패치가 적용된 Kernel 버전으로 업데이트

● AIX

[패치 적용 방법]

Step 1) 설치된 OS 또는 버전 확인

```
# oslevel -s
```

Step 2) 서버에 적용되어 있는 패치 리스트 확인

```
# instfix -i | grep ML
```

```
# instfix -i | grep SP
```

Step 3) 아래 사이트에 접속하여 최신 패치를 찾아 업데이트

<https://www.ibm.com/support/fixcentral>

Step 4) 최신 패치를 다운로드 받은 후 OS 패치 설치 진행

```
# smitty installp
```

Step 5) Install Software 선택 후 INPUT device / directory for software 항목에 패치 파일 경로 입력

Step 6) SOFTWARE to install 항목에서 all-latest 선택

Step 7) ACCEPT new license agreements 항목을 yes로 설정 후 설치 진행

※ 패치 진행 중 문제가 발생한 경우, Apply 설치만 기본 버전으로 재설정 가능

※ Apply, Commit 된 패키지 확인은 `lspp -l` 명령어로 확인 가능

[패치 롤백 적용 방법]

Step 1) 설치된 OS 또는 버전 확인

```
# oslevel -s
```

Step 2) 서버에 적용되어 있는 패치 리스트 확인

```
# instfix -i | grep ML
```

```
# instfix -i | grep SP
```

Step 3) OS 패치 롤백 진행

```
# smitty install_reject
```

Step 4) SOFTWARE name 항목에서 Apply 설치된 OS Patch 선택

Preview 항목 Yes로 설정

Step 5) 소프트웨어 제거에 문제가 없는지 확인 후 진행

● HP-UX

[패치 적용 방법]

Step 1) 서버에 적용된 패치 리스트 확인

```
# swlist -l product
```

Step 2) 아래 사이트에 접속 후 패치를 찾아 업데이트

<https://support.hpe.com/hpsc/patch/content?action=home>

Step 3) patch 파일을 /tmp 디렉터리 내 저장

예시) /tmp/patch_10

Step 4) HP-UX에서 shell archive를 풀

```
# sh patch_10
```

- patch_10.depot, patch_10.text가 생성됨

Step 5) patch_10.depot 설치

```
# swinstall -s /tmp/patch_10.depot (절대경로 입력)
```

```
# swinstall -x autoreboot=true -x patch_match_target=true \ -s /tmp/patch_10.depot
```

U-65 (중)	UNIX > 5. 로그 관리
	NTP 및 시각 동기화 설정
개요	
점검 내용	NTP 및 시각 동기화 설정 여부 점검
점검 목적	인증 및 감사 목적을 위한 시간 동기화는 필수적이며, 안전하고 승인된 NTP 서비스와 동기화하기 위함
보안 위협	시스템 간 시간 동기화 미흡으로 보안 사고 및 장애 발생 시 로그에 대한 신뢰도 확보 미흡 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : NTP 및 시각 동기화 설정이 기준에 따라 적용된 경우
	취약 : NTP 및 시각 동기화 설정이 기준에 따라 적용되어 있지 않은 경우
조치 방법	NTP 설정 및 동기화 주기 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, AIX, HP-UX

Step 1) 동기화된 NTP 서버 확인

```
# ntpq -pn
```

예시) <IP 주소1> <IP 주소2> 3 u 67 64 12 3.11 -425167 7877.17

Step 2) /etc/ntp.conf 파일 내의 NTP 설정값 수정(필요시 기존 서버 제거 후 새로운 NTP 서버 추가)

```
server <NTP 서버>
```

Step 3) NTP 서비스 재시작

● LINUX

[NTP]

Step 1) NTP 서비스 활성화 여부 확인

```
# systemctl list-units --type=service | grep ntp
```

Step 2) 동기화된 NTP 서버 확인

```
# ntpq -pn
```

01. Unix 서버

예시) * <IP 주소1> 133.243.238.244 2 u 53 64 377 5.730 +2.025 8.323

+ <IP 주소2> <IP 주소3> 3 u 49 64 377 5.838 -16.050 16.484

- <IP 주소4> <IP 주소5> 2 u 2 64 377 187.934 -8.059 81.846

(이하 생략)

Step 3) /etc/ntp.conf 파일 내에 NTP 서버 추가

server <NTP 서버>

Step 4) 설정 적용 및 재시작

systemctl restart ntp

※ Redhat 계열 리눅스는 RHEL 8 버전부터 Chrony 서비스로 변경

[Chrony]

Step 1) Chrony 서비스 활성화 여부 확인

systemctl list-units --type=service | grep chrony

Step 2) 동기화된 Chrony 서버 확인

chronyc sources

예시) ^- <IP 주소> 3 6 37 4 -135us[+209us] +/- 56ms

^- <IP 주소> 3 6 37 5 +841us[+1184us] +/- 57ms

(이하 생략)

Step 3) /etc/chrony.conf 파일 내에 NTP 서버 추가

server <NTP 서버>

Step 4) 설정 적용 및 재시작

systemctl restart chrony

U-66 (중)	UNIX > 5. 로그 관리
	정책에 따른 시스템 로깅 설정
개요	
점검 내용	내부 정책에 따른 시스템 로깅 설정 여부 점검
점검 목적	보안 사고 발생 시 원인 파악 및 각종 침해 사실 확인을 하기 위함
보안 위협	로깅 설정이 되어 있지 않을 경우, 원인 규명이 어려우며 법적 대응을 위한 충분한 증거로 사용할 수 없는 위험이 존재함
참고	※ 감사 설정이 너무 높으면 보안 로그에 불필요한 항목이 많이 기록되어 매우 중요한 항목과 혼동할 수 있으며 시스템 성능에도 심각한 영향을 줄 수 있으므로 법적 요구 사항과 조직의 정책에 따라 필요한 로그를 남기도록 설정해야 함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 로그 기록 정책이 보안 정책에 따라 설정되어 수립되어 있으며, 로그를 남기고 있는 경우
	취약 : 로그 기록 정책 미수립 또는 정책에 따라 설정되어 있지 않거나, 로그를 남기고 있지 않은 경우
조치 방법	로그 기록 정책을 수립하고, 정책에 따라 (r)syslog.conf 파일을 설정
조치 시 영향	아래 제시한 모든 로그를 설정할 경우, 시스템 성능과 로그 저장에 따른 서버 용량 부족 문제가 발생할 수 있으므로 시스템 운영 환경과 특성을 고려하여 적용

점검 및 조치 사례

● SOLARIS

[syslog]

Step 1) /etc/syslog.conf 파일 내에 설정된 로그 기록 정책 수정

로그	로그 파일 경로
mail.debug	/var/log/mail.log
*.info	/var/log/syslog.log
*.alert	/var/log/syslog.log
*.alert	/dev/console
*.alert	root
*.emerg	*

Step 2) 설정 적용 및 재시작

```
# svcadm refresh svc:/system/system-log:default
```

[rsyslog]

Step 1) /etc/rsyslog.conf 파일 내에 설정된 로그 기록 정책 수정

로그	로그 파일 경로
*.info;mail.none;authpriv.none;cron.none	/var/log/messages
authpriv.*	/var/log/auth.log
mail.*	/var/log/mail.log
cron.*	/var/log/cron.log
alert.*	/dev/console
emerg.*	*

Step 2) 설정 적용 및 재시작

```
# svcadm refresh svc:/system/system-log:rsyslog
```

● LINUX

Step 1) /etc/rsyslog.conf 또는 /etc/rsyslog.d/default.conf 파일 내에 설정된 로그 기록 정책 수정

로그	로그 파일 경로
*.info;mail.none;authpriv.none;cron.none	/var/log/messages
auth,authpriv.*	/var/log/secure
mail.*	/var/log/maillog
cron.*	/var/log/cron
*.alert	/dev/console
*.emerg	*

Step 2) 설정 적용 및 재시작

```
# systemctl restart rsyslog
```

● AIX

Step 1) /etc/syslog.conf 파일 내에 설정된 로그 기록 정책 수정

로그	로그 파일 경로
*.emerg	*
*.alert	/dev/console
*.alert	/var/adm/alert.log
*.err	/var/adm/error.log
mail.info	/var/adm/mail.log
auth.info	/var/adm/auth.log
daemon.info	/var/adm/daemon.log
.emerg;.alert;*.crit;*.err;*.warning;*.notice;*.info	/var/adm/messages

Step 2) 설정 적용

refresh -s syslogd

● HP-UX

Step 1) /etc/syslog.conf 파일 내에 설정된 로그 기록 정책 수정

로그	로그 파일 경로
*.emerg	*
*.alert	/dev/console
*.alert	root
*.err	/var/adm/syslog/error.log
mail.info	/var/adm/syslog/mail.log
auth.info	/var/adm/syslog/auth.log
.emerg;.alert;*.crit;*.err;*.warning;*.notice;*.info	/var/adm/syslog/syslog.log

Step 2) SYSLOG 데몬 재시작

kill -1 <PID>

01. Unix 서버

구분	왼쪽 필드	오른쪽 필드
형식	A, B	C
예시	mail.debug;cron.crit;auth.info	/var/log/syslog.log
설명	A 서비스 데몬의 B 로그 레벨 이상	A 서비스 데몬의 B 로그 레벨 이상

[syslog.conf 파일 형식]

[오른쪽 필드 로그 형식 종류]

/var/log/syslog.log : 해당 파일에 로그를 기록

/dev/console : 모니터 화면과 같은 지정된 콘솔로 메시지 출력

user : 지정된 사용자의 화면에 메시지 출력

* : 현재 로그인되어 있는 모든 사용자의 화면에 메시지 출력

@192.168.0.1 : 지정된 호스트로 로그 전송

서비스 데몬 종류	
메시지	설명
auth	로그인 등의 인증 프로그램 유형에서 발행된 메시지
authpriv	개인 인증을 요구하는 프로그램 유형에서 발행된 메시지
cron	cron, at 데몬에서 발행된 메시지
daemon	Telnet, FTP 등 데몬에서 발행한 메시지
kern	커널에서 발행된 메시지
lpr	프린터 유형의 프로그램에서 발행된 메시지
mail	메일 시스템에서 발행된 메시지
news	유즈넷 뉴스 프로그램에서 발행된 메시지
syslog	syslog 프로그램 유형에서 발행된 메시지
user	사용자 프로세스 관련 메시지
uucp	시스템에서 발행된 메시지
local0	여분으로 남겨둔 유형

메시지 우선 순위		
등급	메시지	설명
4 (높음)	Emergency[emerg]	매우 위험한 상황
3	Alert[alert]	즉각적인 조치를 해야 하는 상황
2	Critical[crit]	하드웨어 등의 심각한 오류가 발생한 상황
1	Error[err]	에러 발생 시
0	Warning[warning]	주의를 요구하는 메시지
-1	Notice[notice]	에러가 아닌 알림에 관한 메시지
-2	Information[info]	단순한 프로그램에 대한 정보 메시지
-3 (낮음)	Debug[Debug]	프로그램 실행 오류 발생 시

U-67 (중)	UNIX > 5. 로그 관리
	로그 디렉터리 소유자 및 권한 설정
개요	
점검 내용	로그에 대한 접근 통제 및 관리 여부 점검
점검 목적	로그 파일을 관리자만 제어할 수 있게 하여 비인가자의 임의적인 파일 훼손 및 변조를 방지하기 위함
보안 위협	로그에 대한 접근 통제가 미흡할 경우, 비인가자가 로그에서 정보를 획득하거나 로그 자체를 변조할 수 있는 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 디렉터리 내 로그 파일의 소유자가 root이고, 권한이 644 이하인 경우
	취약 : 디렉터리 내 로그 파일의 소유자가 root가 아니거나, 권한이 644를 초과하는 경우
조치 방법	디렉터리 내 로그 파일 소유자 및 권한 변경 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX

Step 1) /var/log/ 디렉터리 내 로그 파일의 소유자 및 권한 변경

```
# chown root /var/log/<파일 이름>
```

```
# chmod 644 /var/log/<파일 이름>
```

● AIX

Step 1) /var/adm/ 디렉터리 내 로그 파일의 소유자 및 권한 변경

```
# chown root /var/adm/<파일 이름>
```

```
# chmod 644 /var/adm/<파일 이름>
```

● HP-UX

Step 1) /var/adm/syslog/ 디렉터리 내 로그 파일의 소유자 및 권한 변경

```
# chown root /var/adm/syslog/<파일 이름>
```

```
# chmod 644 /var/adm/syslog/<파일 이름>
```